QA Test Guide — Step by Step

Printable walkthrough generated from docs/QA_TEST_PLAN.md. Each case shows its Gherkin scenario and the plain-English steps. Record results on the companion QA Run Log sheet. Generated 2026-11-06.

> End-to-end manual test plan covering the **entire** functionality of the app across all three clients: **Web** (Blazor WASM), **Desktop** (MAUI / Windows), and **Android** (MAUI). Each case is written twice — a **Gherkin** scenario (Given/When/Then, matching this project's convention so it can later seed the automated `E2E.Tests` Playwright suite) and a **plain-English walkthrough** a manual tester can follow step by step.
>
> Brand in examples is "Perezosoft"; substitute your app's brand if rebranded.

How to use this document

- **Run the Smoke suite (§4) first.** It's the ~15-minute critical path. If any smoke case fails, stop and report — deeper suites will likely cascade.
- **Each case has an ID** (e.g. `QA-AUTH-03`). Record the result against the ID using the **sign-off sheet (§16)**: Pass / Fail / Blocked / N-A, plus tester, build/commit, date, notes.
- **Priority:** • Smoke Smoke (critical path) · • Core Core (run every regression) · • Edge Edge (run on full regression or when the area changed).
- **Automated in CI** on a case title means a Playwright journey in `tests/E2E.Tests` now exercises the same path on every push (the `e2e` job in `.github/workflows/ci.yml`). Human QA can **spot-check** these rather than run them in full each cycle; they still need a manual pass on Desktop/Android (the E2E job runs Web only) and whenever the area changes. The marker on each case title is authoritative (≈35 cases); §15 maps the major journeys. See §17 for the run procedure.
- **Both formats describe the same test.** Read whichever suits you; the Gherkin is the source of truth for automation.
- **"App" = whichever client the suite header names.** Most behavior is identical across clients (same API, same shared RCL UI); the per-client suites (§12–§13) cover the auth transport and session persistence **plus the full per-feature native parity added by NATIVE-6** (share-sheet downloads, hardware back, refresh-on-return, theme/locale persistence — QA-DSK-08..15, QA-AND-07..15).

1. Environment & prerequisites

1.1 Backing services + API (host machine)

```
docker compose up -d # Postgres + Mailpit
dotnet run --project src/Host --launch-profile https # binds https:7260 (web/desktop) AND http:5338 (android)
```

- API health/liveness check: `curl -k https://localhost:7260/health` -> **200** (`Healthy`); `curl -k https://localhost:7260/health/ready` -> **200** when the database is reachable (503 if not). *(The older `curl -k -X POST https://localhost:7260/api/auth/refresh` -> **401** reachability check still works.)*
- **Mailpit UI: http://localhost:8025** — this is the dev mail trap. Every magic link, OTP code, and invitation email lands here. Keep it open in a tab throughout testing.

(!) **Email only reaches Mailpit if SMTP points at it.** If your repo-root `.env` has the `Email__Smtp__*` lines set to a real provider (e.g. Brevo), the API sends auth emails there and **Mailpit stays empty** — every email-based case below will appear to "fail." For QA, route mail to Mailpit by **either**:
- commenting out the `Email__Smtp__*` lines in `.env` (unset -> defaults to Mailpit `localhost:1025`), **or**
- leaving `.env` untouched and overriding on the command line (command-line config beats `.env`):

```bash
dotnet run --project src/Host --launch-profile https -- \
--Email:Smtp:Host=localhost --Email:Smtp:Port=1025 --Email:Smtp:Username= --Email:Smtp:Password=
```

Verify by triggering one OTP (QA-SMK-01) and confirming it appears in Mailpit before running the suite.
(!) **Email delivery is now asynchronous.** Requesting a code/link/invite **enqueues** the email and a background dispatcher (the outbox) sends it — so it appears in Mailpit **a few seconds later, not instantly**. **Wait briefly before assuming failure. The send request now** always returns success** (reliability moved to the background): if an email never arrives while SMTP points at Mailpit, the message is retrying or dead-lettered in the `OutboxMessages` table — it is **no longer** surfaced as a request error.

- Web app: `dotnet run --project src/Web --launch-profile https` -> **https://localhost:7108**.

(!) Always use the **https** profile for both web and API. Chrome treats `http://localhost` and `https://localhost` as different sites, so the refresh cookie is dropped over http and sign-in silently fails to persist. (See `docs/DECISIONS.md` / the schemeful-same-site note.)
(!) **The passwordless endpoints are rate-limited** per client IP: the **send** endpoints (`/otp/send`, `/magic-link/send`) default to **5/minute**; the **verify** endpoints (`/otp/verify`, `/mfa/verify`) have their **own, larger budget** (the OTP attempt cap + headroom, default **10/minute**) so the cumulative lockout's distinct message (QA-AUTH-04) surfaces before the throttle can mask it. Exceeding a budget returns **HTTP 429**, shown on `/login` as "Too many requests. Please wait a minute, then try again." — that's the abuse guard working (QA-AUTH-11), **not** a bug. Pace requests, or wait ~1 minute for the window to reset.

1.2 Test accounts & data

Need	What to prepare
Two real Google accounts	e.g. `qa.owner@gmail.com`, `qa.member@gmail.com` — for OAuth + linking + multi-user household flows.
One Microsoft personal account	for the Microsoft OAuth path (provider pinned to the *consumers* tenant).
Throwaway email addresses	any address works for magic-link / OTP — mail is trapped by Mailpit, so the address need not be real. Use distinct ones per test to keep inboxes clean.
Two browser contexts	a normal window **and** an incognito/second-profile window. The household invite flow needs two *different* signed-in users at once; incognito gives you an isolated session + cookie jar.

Database reset between full runs (optional but recommended): to retest "new user" onboarding cleanly, you need users that don't yet exist. Either use fresh email addresses each run, or reset the dev DB: `docker compose down -v && docker compose up -d`, then re-apply migrations by starting the API. A volume wipe destroys all test data — only do it on the dev environment.

1.3 Desktop (MAUI Windows) — additional setup

- Run the app from Visual Studio (Windows Machine target) or `dotnet build src/Maui -t:Run -f net10.0-windows...`.
- API must be running on `https://localhost:7260` (the desktop client's base URL).
- OAuth uses a **loopback browser flow** — your default system browser will open a tab during OAuth.

1.4 Android (MAUI) — additional setup

Follow the platform's MOBILE_TESTING. The essential bits:

- Emulator (AVD) or USB device running.

- **`adb reverse tcp:5338 tcp:5338` — re-run every time the device/emulator restarts** (it does not persist). Verify with `adb reverse --list`.
- API started with the **https** profile (binds the cleartext `:5338` leg the device uses).
- Provider redirect URIs registered: `http://localhost:5338/signin-google` and `http://localhost:5338/signin-microsoft`.

1.5 Environment B — deployed staging (DEPLOY, ADR-017)

Everything above is **Environment A** (local). The same suite also runs against the **deployed staging** environment — one Render container serving the API + WASM **single-origin** over real HTTPS, backed by Neon Postgres and Brevo email. Point the browser at the staging URL (e.g. `https://<app>-staging.onrender.com`) and execute the cases exactly as written. What differs from local:

- **One origin, real TLS.** Web + API share the host, so there's no separate API port and no CORS step.
- **Email is real (Brevo), not Mailpit.** Use **real or plus-addressed inboxes** you can open (e.g. `you+qa1@gmail.com`); there's no mail-trap UI. If a code/link doesn't arrive, check **Brevo -> Transactional -> Logs** (and that a verified sender + `Email__Smtp__FromAddress` are set). Email cases are therefore slower than local — pace them (the passwordless rate limit still applies).
- **Cold start.** Free instances sleep after ~15 min idle; the **first** request of a session can take ~30–60 s. That's expected, not a failure — retry once it wakes.
- **OAuth** buttons appear **only** for providers configured on staging (Google/Microsoft need their redirect URIs registered against the staging host). If unconfigured, the buttons are simply absent (by design) — record those provider cases **N-A** for this environment.
- **Billing** uses Stripe **test mode** — exercise webhooks with `stripe trigger …` against the staging `/api/billing/webhook`.

Deploy + smoke gate (ADR-031). A merge to `develop` deploys nothing. Staging is deployed from **GitHub** -> Actions -> `CI` -> *Run workflow* on `develop` with `deploy` = staging: the run re-runs every web gate, and only if all pass fires the Render hook, waits for the new build to be live (`/api/version` reports the commit) and runs the automated post-deploy smoke (liveness/readiness, SPA shell + deep-link, `/api` returns an API-shaped 404, `/api/auth/providers`). A red gate or smoke blocks — so a broken deploy is caught before manual QA starts. Manual QA on staging complements it (the human-only paths: real email, OAuth, billing, visual checks).

2. Scope

In scope: authentication (all methods, all clients), new-user onboarding, household/tenant management, invitations & joining, account settings (linked providers), localization (EN/ES), transactional emails, cross-cutting security (tenant isolation, auth guards, token lifecycle), and **native (MAUI) feature parity** — the shared-RCL feature surface exercised per platform on Windows + Android (§12–13) with a first-run iOS/macCatalyst smoke (§13b) and a per-release native checklist (§13c).

Out of scope (per `docs/PROJECT_BRIEF.md` OUT list & current state): SMS OTP, OAuth providers beyond Google/Microsoft, FR/DE/PT languages (scaffolded but not translated — see the platform's LOCALIZATION), and any app-specific domain features not yet built on this platform.

Platform services with no client UI (API-/operational-level, not manually testable through the app yet): the append-only audit log, OpenTelemetry telemetry, the health endpoints, the background outbox/inbox/scheduled-jobs, and **file storage** — the `IFileStorage` seam + the signed download endpoint `GET /api/files/{token}` (anonymous, the token *is* the authorization; local-disk only — cloud backends hand out native presigned URLs). These are **covered by automated tests** (`tests/Api.Tests`); browser E2E for them is deliberately out of scope (headless machinery). The **billing page** is NO longer in this list — BILLING-8 shipped `/billing` (§10c, QA-BILL-01/02) with the fake-provider E2E journey (`BillingJourneyTests`). Health has a smoke check (QA-SMK-07); manual cases for the rest will be added when client UI exists. **GDPR data export** (`POST /api/household/export`) and **account erasure** (`DELETE /api/auth/me`) now **have a web UI** (UI-1: owner Household -> Data, Settings -> Danger zone) — covered by the manual cases QA-HH-13 + QA-SET-07. **RBAC role management now has a web UI** (RBAC-3) — covered by the household cases QA-HH-09..12. **MFA now has a web UI** (UI-2) — enrollment/ disable in Settings and the sign-in step-up on Login — covered by QA-MFA-01..03. The **in-app notification center now has a web UI** (UI-3) — the header bell (list, unread count, mark-read, delete/clear) and Settings delivery-preference switches — covered by QA-NOTIF-01..04. The **platform-staff admin surface now has a web UI** (UI-4) — a staff-only `/admin` console (tenant

list/detail + impersonation + targeted/broadcast announcements + plan comp/revert + MFA reset) — covered by QA-ADMIN-01..07. The **public API (PUBAPI)** and **outbound webhooks (HOOKS)** are intentionally UI-less (they're for machines) and **config-gated off** — they have **manual curl/Postman cases in §14b** (QA-API-01..06), in addition to automated tests.

Automated in CI (Web): a Playwright/NUnit E2E suite (`tests/E2E.Tests`, currently 37 journeys) runs against the real booted stack on every push — the `e2e` job in `.github/workflows/ci.yml`. Every case it covers is marked **Automated in CI** on its title (≈35 cases across auth, MFA, i18n, household/roster, invitations, notifications, admin, billing, theme, and GDPR — the case titles are authoritative; §15 maps the major journeys). Human QA can spot-check those on Web and focus effort on the un-automated cases and the native clients — where CI runs two smoke canaries (Android boots the real app and drives the OTP journey on an emulator; Windows is a boot-to-login probe only).

3. Test data conventions

- **Owner user** = the account you sign in with first; it auto-creates and owns a household.
- **Member user** = a second account invited into the owner's household.
- Household auto-named on creation; rename it to something recognizable (e.g. "QA House") early so you can spot it in the header tenant badge.

4. Smoke suite • Smoke (run first — ~15 min)

The critical path: can a user get in by each method, reach the app, and get out.

QA-SMK-01 — Web: OTP sign-in happy path • Smoke (Web) Automated in CI

Gherkin

```
Given I am an anonymous user on the /login page of the web app
When I enter my email and request a 6-digit code
And I retrieve the code from Mailpit and submit it
Then I am signed in and land on the home page
And the header shows my household name and my display name
```

Walkthrough

1. Open https://localhost:7108 -> you're redirected to `/login`.
2. In the email field enter `qa-smoke@example.com`; click **Email me a 6-digit code**.
3. **Expected:** the form switches to a code-entry view ("Enter the 6-digit code sent to …").
4. Open Mailpit (http://localhost:8025); open the newest mail; copy the 6-digit code.
5. Enter the code; click **Verify code**.
6. **Expected:** you land on the home page; the top header shows the nav (the active item as a filled white pill) and, on the right, the bell and a **user menu** — the tenant chip plus your display name. Opening it shows the theme switcher, then **Household**, **Billing**, **Settings** and **Sign out**. (SKIN-4: those used to sit loose in the bar; the bell stays outside the menu because an unread count you have to open a menu to see is not an indicator.)

QA-SMK-02 — Web: Google OAuth sign-in • Smoke (Web)

Gherkin

```
Given I am on the /login page
When I click "Continue with Google" and complete Google consent
Then I am returned to the app, signed in, on the home page
```

Walkthrough

1. From `/login`, click **Continue with Google**.
2. **Expected:** full-page redirect to Google's consent screen.
3. Choose `qa.owner@gmail.com`, approve.
4. **Expected:** redirected back into the app, signed in, on the home page with the header chrome.

QA-SMK-03 — Web: Sign out • Smoke (Web) Automated in CI

Gherkin

```
Given I am signed in to the web app
When I click "Sign out"
Then I am returned to the /login page
And navigating to /settings redirects me back to /login
```

Walkthrough

1. While signed in, open the **user menu** (the tenant chip / your name, top right) and click **Sign out**. Escape closes the menu without signing out; navigating anywhere closes it too.
2. **Expected:** you land on `/login`.
3. In the address bar go to `/settings`.
4. **Expected:** you're bounced back to `/login` (no access without a session).

QA-SMK-04 — Web: Session persists across reload ("remember me") • Smoke (Web)

Gherkin

```
Given I am signed in to the web app
When I reload the page (or reopen the tab)
Then I am still signed in without re-authenticating
And a tab left open past the access token's hour stays signed in
And a server that is still starting up does not sign me out
```

Walkthrough

1. Signed in, press F5 / reload.
2. **Expected:** brief load, then the app shell — still signed in, no trip to `/login`. (A silent refresh exchanges the refresh cookie for a new access token on load.)
3. Leave the tab open and untouched for **more than 65 minutes** (the access token lives 60), then navigate to another page. **Expected:** the page loads its data; no trip to `/login`, no error toast. (The session renewed itself a minute before expiry — ADR-002 addendum 2026-09-22.)
4. Stop the API, reload the tab: the loading spinner stays up for about 30 s, then `/login`. Start the API again and reload. **Expected:** signed in without re-authenticating — a server that couldn't be reached never cost the session. *(Native: `SessionKeepAliveTests` pin the same for the stored token.)*

QA-SMK-05 — Desktop: OTP sign-in • Smoke (Desktop) — see QA-DSK-01

QA-SMK-06 — Android: OTP sign-in • Smoke (Android) — see QA-AND-01

QA-SMK-07 — API health & readiness • Smoke (Platform)

Gherkin

```
Given the API is running
When I GET /health and /health/ready
Then /health returns 200 "Healthy"
And /health/ready returns 200 when the database is reachable, 503 when it is not
```

Walkthrough

1. `curl -k https://localhost:7260/health` -> **200**, body `Healthy` (liveness — process up).
2. `curl -k https://localhost:7260/health/ready` -> **200** (readiness — Postgres reachable).
3. *(Optional)* stop the DB (`docker compose stop db`) and re-run step 2 -> **503**; then `docker compose start db` and confirm it returns to **200**.
4. **Expected:** liveness is 200 whenever the process runs; readiness tracks DB reachability. Responses are **status-only** (no connection details leaked).

5. Web — Authentication • Core

QA-AUTH-01 — Magic-link sign-in happy path • Core (Web) Automated in CI

Gherkin

```
Given I am an anonymous user on /login
When I enter my email and request a magic link
And I open the emailed link from Mailpit
Then I am signed in and landed in the app
```

Walkthrough

1. On `/login` enter `qa-magic@example.com`; click **Email me a magic link**.
2. **Expected:** a success panel — "Check your inbox." + "A sign-in link was sent to qa-magic@example.com. It expires in 15 minutes." — with a **Use a different email** link.
3. In Mailpit open the newest mail; click the sign-in link (or copy it into the same browser).
4. **Expected:** the link resolves and you end up signed in, in the app.

QA-AUTH-02 — Microsoft OAuth sign-in • Core (Web)

Gherkin

```
Given I am on /login
When I click "Continue with Microsoft" and complete consent
Then I am returned signed in
```

> **Account resolution (read before testing):** signing in with a provider whose email matches an existing account links the provider to that account rather than creating a duplicate — but only when the email is **verified**. Google asserts this; Microsoft on the **`consumers`** (personal MSA) tenant is trusted to have a verified email even though it omits the claim (`IProviderEmailTrust`). For **work/school** tenants (`organizations`/`common`/a tenant GUID) and any other provider, a same-email auto-link is **refused** (fail-closed takeover guard, audit MITI-3) — the user signs in with their original method and links the provider from **Settings** instead (QA-SET-02). To test the plain first-time path below, use a Microsoft account whose email has **no** prior account.

Walkthrough

1. Click **Continue with Microsoft**; sign in with a **personal** Microsoft account.
2. **Expected:** returned to the app signed in. A brand-new email creates a new account; a personal Microsoft account whose email already exists auto-links to that account (consumers tenant). (If you see a tenant/reply-URL error, the provider registration is the cause — out of app scope, note it.)

QA-AUTH-03 — OTP wrong code is rejected • Core (Web)

Gherkin

```
Given I requested an OTP code for my email
When I submit an incorrect 6-digit code
Then I see an "incorrect code" error and remain on the code-entry screen
```

Walkthrough

1. Request an OTP (as QA-SMK-01) but **do not** use the real code.
2. Enter `000000`; click **Verify code**.
3. **Expected:** inline error ("code is incorrect / verification failed"); you stay on the code-entry view and can retry. You are **not** signed in.

QA-AUTH-04 — OTP cumulative lockout & code expiry • Edge (Web)

Gherkin

```
Given I requested an OTP code
When I submit wrong codes up to the cumulative limit (default 5 failures per email within a 15-min
window)
Then the email is locked — further attempts, INCLUDING a freshly requested code, are rejected until
the window elapses
And separately, an unused code is rejected once it passes its lifespan (default 10 minutes)
```

Walkthrough

1. Request an OTP for an email; enter a **wrong** 6-digit code until you hit the cumulative limit (default 5, `Auth:Otp:MaxAttempts`, counted **per email across the `Auth:Otp:LockoutWindowMinutes` = 15-min window**, not per code).
2. **Expected:** after the limit, a "too many attempts" lockout error.
3. Now request a **fresh** code and submit it — even the **correct** one.
4. **Expected:** still rejected — requesting a new code does **NOT** reset the budget (this is the brute-force defense; a resend can't hand the attacker another N guesses). The lock clears after the 15-min window.
5. **Expiry sub-case:** separately, request a code and wait past `Auth:Otp:CodeLifespanMinutes` (default 10) — the stale code is rejected.

> **Note (enumeration):** OTP verify returns the **same** generic "invalid code" error whether the code was wrong or there is no active code — it never reveals whether an address has an outstanding OTP. *(Long-wait cases — lower the config to test fast. The verify throttle's budget deliberately sits **above** the attempt cap — QA-AUTH-11 — so you reach this lockout and see its distinct message before any 429; only hammering faster than ~10 verifies/minute trips the throttle.)*

QA-AUTH-11 — Passwordless endpoints are rate-limited • Core (Web)

Gherkin

```
Given I rapidly request codes/links for the same client
When I exceed the per-IP send limit (default 5 per minute)
Then further requests are rejected with HTTP 429 until the window resets
```

Walkthrough

1. From `/login`, request an OTP (or magic link) repeatedly in quick succession — more than 5 within a minute.
2. **Expected:** after the limit the request is throttled (**HTTP 429**), surfaced on `/login` as **"Too many requests. Please wait a minute, then try again." OTP verify** has its own, larger per-IP budget — max(send limit, OTP attempt cap + 5) = 10/min by default (so the lockout cap in QA-AUTH-04 is reachable) — with the same 429 + message when exceeded.
3. Wait ~1 minute; requests succeed again.

> Protects against email-bombing and OTP brute-forcing. Expected behavior, not a defect — see the §1.1 pacing note.

QA-AUTH-05 — Magic link is single-use • Edge (Web) Automated in CI

Gherkin

```
Given I signed in by clicking a magic link
When I click the same link a second time
Then it is no longer valid
```

Walkthrough

1. Complete QA-AUTH-01. Then revisit the *same* link from Mailpit.
2. **Expected:** it does not grant a second session — you're sent to `/login` with an invalid-link indication (or simply not signed in). The token is consumed on first use.

QA-AUTH-06 — Magic link expiry • Edge (Web)

Walkthrough: request a link, wait past `Auth:MagicLink:TokenLifespanMinutes` (default 15), then open it.
Expected: rejected as expired; user lands on `/login`. *(Lower the config to test fast.)*

QA-AUTH-07 — User-enumeration protection • Core (Web)

Gherkin

```
Given an email address that has no account
When I request a magic link or OTP for it
Then the UI shows the same success/"check your inbox" response as for a real account
```

Walkthrough

1. Request a magic link **and** an OTP for a never-before-used address.
2. **Expected:** identical success messaging to a known address — the app never reveals whether an account exists. (Mailpit will still show whatever the system chose to send.)

QA-AUTH-08 — Login error banners • Edge (Web)

Gherkin

```
Given the login page is loaded with an error query parameter
Then a human-readable error banner is shown
```

Walkthrough — visit each URL and confirm a red banner with sensible copy:

- `/login?error=external_failed` -> external sign-in failed message.
- `/login?error=email_unverified` -> email-unverified message.
- `/login?error=invalid_link` -> invalid/expired link message.
- `/login?error=somethingelse` -> generic "something went wrong" fallback.

QA-AUTH-09 — Email-format validation • Edge (Web) Automated in CI

Walkthrough: on `/login`, click a send button with an empty or malformed email (e.g. `abc`). **Expected:** inline "enter a valid email" validation; no request sent.

QA-AUTH-10 — Magic link & OTP available on web; OAuth always • Edge (Web)

Walkthrough: confirm the web login page shows **both** "Email me a magic link" and "Email me a 6-digit code", plus Google/Microsoft buttons — all on the form pane, in that order, at every width. (Native clients hide magic link — covered in §11–12.)

6. Web — Onboarding & new tenant • Core

QA-ONB-01 — First-ever sign-in auto-creates a household, user is owner • Smoke (Web)

Gherkin

```
Given an email/account that has never signed in before
When I authenticate for the first time (any method)
Then a new household is created and I am its owner
And the header shows that household and my name
```

Walkthrough

1. Sign in with a brand-new account/email (fresh address or post-DB-reset).
2. **Expected:** you reach the app immediately (no "create household" prompt — provisioning is automatic). Open **Household**: you are listed with the **Owner** badge and are the only member.

QA-ONB-02 — Returning user keeps their household • Core (Web)

Walkthrough: sign out and back in with the same account. **Expected:** same household, same role, data intact.

7. Web — Household management • Core

> Roles: **owner** > **admin** > **member** (ADR-009). **Owner + admin** can rename and invite/remove members; **owner-only**: change member roles (promote/demote), transfer ownership, dissolve. Members see a read-only name and a **Leave** button. The owner's row never shows action buttons.

QA-HH-01 — Owner renames the household • Core (Web)

Gherkin

```
Given I am the household owner on /household
When I change the name and click Rename
Then the new name is saved and reflected in the header tenant badge
```

Walkthrough

1. **Household** -> edit the name field (e.g. "QA House") -> **Rename**.
2. **Expected:** success banner; the header tenant badge updates to the new name (a silent refresh updates the claim).

QA-HH-02 — Member sees read-only household, no owner controls • Core (Web) Automated in CI

Precondition: signed in as a *member* (use QA-INV flow to create one). **Walkthrough:** open **Household**. **Expected:** household name shown as read-only heading; no rename/invite/transfer controls; a **Leave** button is present.

QA-HH-03 — Owner removes a member • Core (Web) Automated in CI

Gherkin

```
Given I am the owner and another member exists
When I click Remove next to that member and confirm
Then they are removed from the household member list
```

Walkthrough

1. As owner with a member present, click **Remove** by the member's row.
2. **Expected:** a confirm dialog ("Remove <name>?"); on confirm, success banner and the member disappears from the list. (The removed user is re-homed to a fresh solo household — verify by signing in as them: they now own an empty household — see QA-HH-08.)

QA-HH-04 — Owner cannot remove themselves • Edge (Web)

Walkthrough: as owner, confirm there is **no Remove button on your own row**. (Owner departs via transfer or dissolve, not removal.)

QA-HH-05 — Transfer ownership • Core (Web) Automated in CI

Gherkin

```
Given I am the owner and at least one other member exists
When I select that member and click Transfer
Then they become owner and I become a regular member
```

Walkthrough

1. As owner with >=1 other member, in **Transfer ownership** pick the member -> **Transfer**.
2. **Expected:** success banner. The chosen member now shows the **Owner** badge; your row shows **Member**. The owner-only controls (invite/transfer/dissolve) are no longer available to you, and a **Leave** button now is.

QA-HH-06 — Owner with other members cannot directly leave/dissolve • Edge (Web)

Walkthrough: as owner **with** other members present, confirm the bottom card shows the **Transfer ownership** control (with "you must transfer before leaving" note) — **not** a leave/dissolve button. The single-owner invariant is enforced in the UI.

QA-HH-07 — Sole owner dissolves the household • Core (Web) Automated in CI

Gherkin

```
Given I am the only member and owner of my household
Then the bottom card states, above the button and before any dialog, that leaving permanently deletes
this household and its data
When I click "Leave and delete" and confirm
Then the household is dissolved and I am re-homed to a fresh solo household
```

Walkthrough

1. As sole owner (no other members), bottom card ("Leave & dissolve") -> **Expected (SKIN-11):** a "This will" panel with the consequence in words sits above **Leave and delete** — the same card shows "This will" above **Transfer** for an owner with members, and above **Leave** for a plain member. Click **Leave and delete**.
2. **Expected:** a confirm dialog warning the household will be deleted; on confirm, the app reloads and you land signed in with a **new empty household you own** (you're never left tenant-less).

QA-HH-08 — Member leaves the household • Core (Web) Automated in CI

Gherkin

```
Given I am a non-owner member
When I click Leave and confirm
Then I leave the household and am re-homed to a fresh solo household I own
```

Walkthrough

1. As a member, **Household** -> **Leave** -> confirm.
2. **Expected:** app reloads; you now own a brand-new empty household. The household you left still exists for its remaining members (verify as the owner: the leaver is gone from the member list).

QA-HH-09 — Owner promotes a member to admin • Core (Web) Automated in CI

Precondition: signed in as the owner with at least one **member** present (use the QA-INV flow). **Gherkin**

```
Given I am the owner and another member exists
When I click "Make admin" next to that member
Then their badge changes to Admin
```

Walkthrough

1. On **Household**, find a member's row -> click **Make admin**.
2. **Expected:** success banner ("Role updated."); the member's badge flips from **Member** to **Admin**, and the button becomes **Make member**. (Verify as that user — see QA-HH-11.)

QA-HH-10 — Owner demotes an admin to member • Core (Web) Automated in CI

Gherkin

```
Given I am the owner and an admin exists
When I click "Make member" next to that admin
Then their badge changes back to Member
```

Walkthrough

1. On **Household**, on an **Admin** row -> click **Make member**.
2. **Expected:** success banner; the badge returns to **Member** and the button becomes **Make admin**.

QA-HH-11 — Admin sees management controls but not role/ownership controls • Core (Web) Automated in CI

Precondition: signed in **as the admin** promoted in QA-HH-09. **Gherkin**

```
Given I am an admin (not the owner)
When I open Household
Then I can rename the household and invite/remove members
But I see no promote/demote (role) controls and no transfer/dissolve — only Leave
```

Walkthrough

1. As the admin, open **Household**.
2. **Expected:** the **rename** field and the **Invitations** card are available; member rows show a **Remove** button **but no Make admin/Make member** buttons (role changes are owner-only). The bottom card shows **Leave** (no Transfer ownership / Leave & delete). The owner's row shows **no** action buttons.

QA-HH-12 — Member sees no management controls • Edge (Web) Automated in CI

Walkthrough: signed in as a plain **member**, open **Household**. **Expected:** read-only name, no Invitations card, no per-row action buttons (no Remove/role controls), only a **Leave** button — unchanged from QA-HH-02 (a member is never shown management controls regardless of the admin tier).

QA-HH-13 — Owner exports household data • Core (Web)

Gherkin

```
Given I am the household owner on /household
When I click "Download household data"
Then I get a link to a JSON export of the household's data
```

Walkthrough

1. As owner, open **Household** -> the **Data** card -> **Download household data**.
2. **Expected:** a success row with a **Download** link; following it downloads a JSON bundle containing the tenant, members and invitations (and each feature's data). Members/admins don't see the Data card (owner-only). No secrets (invitation token hashes) appear in the file.

QA-HH-14 — Seat quota blocks inviting past the plan limit • Core (Web) Automated in CI

Precondition: the platform ships example seat caps (Free = 3 seats, counting members + pending invites; `PlanCatalog`). A Free household at its cap (e.g. 3 members, or 2 members + 1 pending invite). **Gherkin**

```
Given my Free plan's seats are all used (members + pending invites)
When I invite another member
Then I'm told my seat limit is reached and to upgrade (nothing is invited)
And raising the limit (Pro plan / editing PlanCatalog) lets the invite through
```

Walkthrough

1. As owner of a Free household at the seat cap, **Household** -> invite a new email.
2. **Expected:** an error — "Your plan's seat limit is reached. Upgrade your plan to invite more members." (HTTP **402**); no invitation is created and no email is sent.
3. Free up a seat (revoke a pending invite / remove a member) **or** move to a higher-seat plan — the next invite succeeds. (Seats count members **plus** pending invites, so invites can't over-provision.)
4. **Note:** limits are `PlanCatalog` data; `null`/absent = unlimited. Metered-usage caps (`IQuotaService.TryConsumeAsync`, monthly) are wired the same way where an app calls them.

8. Web — Invitations & joining • Core

QA-INV-01 — Owner invites by email; token revealed + email sent • Smoke (Web) Automated in CI

Gherkin

```
Given I am the household owner
When I invite an email address
Then an invitation appears in the pending list with an expiry date
And a one-time join token is revealed in the UI
And an invitation email with a /join link is delivered to Mailpit
```

Walkthrough

1. **Household** -> Invitations -> enter `qa.member@gmail.com` -> **Invite**.
2. **Expected:** a green panel reveals the raw token + a **Copy** button and notes a join link was emailed; the address shows under **Pending** with an expiry date.
3. Check Mailpit: an invitation email addressed to that user, containing a `/join?token=…` link.

QA-INV-02 — Invitee accepts and joins (two-user flow) • Smoke (Web) Automated in CI

Gherkin

```
Given an invitation exists for a second user
When that user opens the /join link, signs in, and accepts
Then they become a member of the inviter's household
```

Walkthrough

1. Copy the `/join?token=…` link from QA-INV-01.
2. In an **incognito window**, open the link.

3. **Expected:** "You've been invited… sign in to accept." Click **Sign in to accept**; complete any sign-in method as `qa.member@gmail.com`.
4. **Expected:** after sign-in you're returned to the join flow automatically, it processes, and you see **"You're in"** with a **Go to household** button.
5. Click it -> **Household** shows you as a **Member** of "QA House".
6. Back in the owner window, reload **Household**: the new member appears and the pending invite is gone.

QA-INV-03 — Already-authenticated user accepts directly • Core (Web)

Walkthrough: while already signed in as a *different* fresh user, open a valid `/join?token=…`. **Expected:** it accepts immediately (no sign-in step) and shows success. *(Note: a user already in a household who accepts another invite moves to the new household — verify their old membership is replaced, honoring the one-tenant invariant.)*

QA-INV-04 — Join page with no token offers manual code entry • Edge (Web)

Walkthrough: open `/join` with no `?token=`. **Expected:** the **manual invite-code entry** state ("Join with an invite code" + input + submit — the NATIVE-4b path for emailed codes), no crash. Pasting a garbage code shows the inline error and lets you retry (automated: `MembershipLifecycleTests.Pasting_An_Invalid_Code_Shows_An_Inline_Error`).

QA-INV-05 — Join with invalid/expired/used token • Core (Web)

Gherkin

```
Given an invitation token that is invalid, already used, or expired
When an authenticated user opens its /join link
Then they see an error state, not a successful join
```

Walkthrough: while signed in, open `/join?token=garbage123` (or reuse a token already accepted in QA-INV-02). **Expected:** the error state with a **Back to household** link; no membership change.

QA-INV-06 — Invite an existing member is rejected • Core (Web)

Gherkin

```
Given a user is already a member of my household
When I invite their email again
Then I get an "already a member" error and no duplicate invite is created
```

Walkthrough: as owner, invite the email of someone already in the household. **Expected:** a red "already a member" status (HTTP 409); nothing added to pending.

QA-INV-07 — Regenerate a pending invitation • Core (Web)

Gherkin

```
Given a pending invitation exists
When I click Regenerate
Then a new token is issued (revealed) and the old token no longer works
```

Walkthrough

1. On a pending invite, click **Regenerate**.
2. **Expected:** a new token is revealed. The **previous** token's `/join` link now fails (QA-INV-05), the new one works.

QA-INV-08 — Revoke a pending invitation • Core (Web) Automated in CI

Gherkin

```
Given a pending invitation exists
When I click Revoke
Then it is removed from pending and its token no longer works
```

Walkthrough: click **Revoke** on a pending invite. **Expected:** "invitation revoked" status; it leaves the pending list; opening its old link gives the error state.

QA-INV-09 — Copy token button • Edge (Web)

Walkthrough: click **Copy** on a revealed token; paste elsewhere. **Expected:** the token is on the clipboard. (If the browser blocks clipboard access, the token is still visible to copy manually — no error shown.)

QA-INV-10 — Accepting an invite after a downgrade is refused (seat re-check) • Core (Web) Automated in CI

Precondition: a way to change the tenant's plan — staff comp/revert (QA-ADMIN-06) or the fake provider webhook (E2E does the latter). **Gherkin**

```
Given a household on Pro invited more members than the Free plan allows
And the subscription has since lapsed or been reverted to Free
When an invitee opens a still-valid invitation link
Then joining is refused with a "This household is full" message
And the invitation stays pending (it works again if the owner re-upgrades)
```

Walkthrough

1. Comp the household to Pro (QA-ADMIN-06); as the owner, invite members until members + pending exceeds the Free limit (currently 3).
2. Revert the household to Free.
3. Sign in as an invitee (fresh browser) and open the invite link / paste the code on `/join`.
4. **Expected:** the join page shows **"This household is full"** (402 `seat_limit_reached`) — the invitee does not join and no membership changes. Existing members are untouched; new invites are also blocked (QA-HH-14).
5. Comp back to Pro and retry the same link. **Expected:** it joins — the refused token self-heals (BILLING-9, ADR-006 addendum).

9. Web — Settings / linked accounts • Core

QA-SET-01 — View linked providers • Core (Web)

Gherkin

```
Given I signed up with Google
When I open /settings
Then Google shows as "Connected" and Microsoft shows a "Link" button
```

Walkthrough: sign in with Google, open **Settings**. **Expected:** a row per provider; the one you used shows a **Connected** badge + **Unlink**; the other shows **Link**.

QA-SET-02 — Link a second provider • Core (Web)

Gherkin

```
Given I am signed in and Microsoft is not linked
When I click Link on Microsoft and complete consent
Then Microsoft becomes Connected on my account (no new account is created)
```

Walkthrough

1. **Settings** -> **Link** on Microsoft -> complete consent with a Microsoft account **whose email isn't already used by another app user**.
2. **Expected:** returned to Settings with a success banner ("Microsoft linked"); Microsoft now shows **Connected**. You can subsequently sign in with either provider into the *same* account.

QA-SET-03 — Linking a provider already used by another account is rejected • Core (Web)

Gherkin

```
Given a provider identity is already linked to a different user
When I try to link it to my account
Then I get an "already in use" error and it is not linked
```

Walkthrough: try to **Link** a Google/Microsoft identity that another app user already owns. **Expected:** Settings shows an "already in use" banner (`?link_error=in_use`); no link made. *(Expired link-token path shows `?link_error=expired` — exercise if you can stall the flow past the token lifetime.)*

QA-SET-04 — Unlink a provider • Core (Web)

Gherkin

```
Given two providers are linked to my account
When I click Unlink on one and confirm the dialog
Then it returns to a "Link" state
```

Walkthrough: with two providers connected, click **Unlink** on one. **Expected:** a confirm dialog ("Unlink this sign-in method?"); on **confirm** the row reverts to **Link**. **Cancelling** the dialog leaves it **Connected** — no change. *(The confirm fails closed: if the browser dialog can't run, the unlink is cancelled, never silently performed. The same guarded confirm protects remove-member / leave / dissolve in §7.)*

QA-SET-05 — Unlinking your only provider never locks you out • Edge (Web)

Gherkin

```
Given Google is my only linked provider
When I unlink it
Then I can still sign in by email (magic link / OTP)
```

Walkthrough: unlink your sole provider, sign out, and sign back in with **OTP/magic link** using the same email. **Expected:** you reach the **same** account/household. (Email sign-in is always available by design, so provider removal can't lock you out.)

QA-SET-06 — Settings requires auth • Edge (Web)

Walkthrough: signed out, navigate to `/settings`. **Expected:** redirect to `/login`.

QA-SET-07 — Delete my account • Core (Web) Automated in CI

Precondition: use a **throwaway** account (this is destructive). Easiest: a member of another owner's household (so no dissolve). **Gherkin**

```
Given I am signed in on /settings
Then the Danger zone states, above the button and before any dialog, that deleting permanently
removes my account and personal data
When I use the Danger zone "Delete my account" and confirm
Then my account and personal data are deleted and I'm signed out
```

Walkthrough

1. **Settings** -> **Danger zone** -> **Expected (SKIN-11):** a "This will" panel stating the consequence above **Delete my account**. Click it -> confirm the dialog.
2. **Expected (member):** account deleted; you're signed out and land on `/login`. Signing in again creates a brand-new account.
3. **Owner with other members:** an error tells you to **transfer ownership first** (nothing deleted).
4. **Sole owner:** a second confirm warns it also **dissolves the household**; on confirm, the account + household are deleted.

QA-SET-08 — Theme: dark mode applies, persists, and follows the user • Core (Web) Automated in CI

Gherkin

```
Given I am signed in
When I pick "Dark" in the header theme switcher
Then the app restyles dark immediately without a reload
And a reload first-paints dark (no light flash)
And signing in on a fresh browser profile renders dark as part of the sign-in
```

Walkthrough

1. Signed in, pick **Dark** in the header switcher (login page and **Settings -> Preferences** have the same control). **Expected:** the page flips dark instantly — background, cards, buttons, and the brand lockup swaps to its dark variant; no reload.
2. Reload. **Expected:** the very first paint is dark — no white flash.

3. Sign in as the same user in a fresh browser profile (or private window). **Expected:** dark applies as part of signing in, no reload needed — the choice is stored per user server-side (PREFS-1, ADR-022).
4. Pick **Auto**. **Expected:** the app follows the OS scheme live (flip the OS setting to check). Auto is stored per user too: a second browser showing Dark returns to the OS scheme on its next sign-in/reload.

QA-SET-10 — Cards fold to their heading and stay folded on this device • Edge (Web + Android)

Gherkin

```
Given I am on Settings
Then every card (Preferences, Budget, Catalog, Email, Merchant suggestions, Notifications,
Two-factor, Danger zone) has a fold button at the right of its heading
When I fold Catalog and Danger zone and reload
Then they are still folded, and only their headings show
When I unfold Catalog
Then its links are back
And the same holds for the Reports cards (pace and every chart), the Household's Members, Invitations
and Data cards, and the Dashboard's Fixed, Variable and "Where it went" panels
And the fold button is reachable with Tab, toggled with Enter or Space, and announces "Collapse
<card>" / "Expand <card>"
```

Walkthrough: Settings -> **Expected:** a small chevron at the right of each card heading. Click **Catalog**'s -> **Expected:** only the heading remains, the chevron turns. Fold **Danger zone** too -> reload -> **Expected:** both still folded, the others open. Tab to a chevron -> **Space** -> **Expected:** it folds; a screen reader announces the button as "Collapse Catalog" (expanded) / "Expand Catalog" (collapsed). **Reports** (chart view) -> fold **Spend by bank** and the pace -> reload -> **Expected:** still folded. **Household** -> fold **Members** -> reload -> still folded. **Dashboard** -> fold **Where it went** -> its switch stays visible in the heading, the table is gone; reload -> still folded. On the phone app the same, and a fold on the phone does not fold the web (it is a device preference).

QA-SET-11 — On a phone no page scrolls sideways; tables fit or scroll inside their card • Core (Web + Android) Automated in CI

Gherkin

```
Given a household with two months of purchases, refunds pending and received, budget lines and income
When I open each main page at phone width (375 px): Dashboard (all four "Where it went" cuts), a
month, Months, Budget,
Refunds, Reports, Settings, Household, Review and New transaction
Then none of them can be dragged sideways
And on the dashboard a "both" amount reads ■ over $ in the breakdown tables, and a budget line's name
has its own line
And on Refunds each row reads tick · payee (date · month · status under it) · amount
And on a desktop the same tables read "■x · $y" on one line as before
```

Walkthrough: open the app on the phone (or a browser at 375 px). On each page above try to drag the page left -> **Expected:** it does not move; a table wider than the screen (none should be, with ordinary amounts) scrolls inside its own card instead. **Dashboard -> Where it went** -> each of **By week**, **By bank**, **By card**, **Unbudgeted** -> the amounts stack ■ over $ and every column is visible. **Fixed** / **Variable** -> each line's name is whole on its own line, budget and delta under it. **Household** with a long member email -> it wraps. Back on a desktop -> the same dashboard tables keep ■ and $ on one line. Automated by `PhoneLayoutTests` (E2E).

QA-MFA-01 — Enable two-factor (authenticator TOTP) • Core (Web) Automated in CI

Precondition: signed in; an authenticator app (Google Authenticator, 1Password, Authy, …) to hand. **Gherkin**

```
Given I am signed in on /settings with two-factor Off
When I enable it, scan the QR (or enter the key) and confirm with a 6-digit code
Then two-factor turns On and I'm shown one-time recovery codes
```

Walkthrough

1. **Settings** -> **Two-factor authentication** shows an **Off** badge -> **Enable two-factor**.
2. A **QR code** renders next to a **manual key** (Base32). Scan it (or type the key) into the app.
3. Enter the app's current **6-digit code** -> **Verify & enable**.

4. **Expected:** a success banner, the badge flips to **On**, and a grid of 10 **recovery codes** appears (shown once) — short, typeable `xxxxx-xxxxx` codes (e.g. `k7m2q-9xr4t`; no ambiguous `0/O/1/I/L` glyphs). **I've saved my codes** returns to the On state.
5. **Wrong code:** an inline error ("that code is incorrect or has expired"); nothing changes.

QA-MFA-02 — Two-factor is required at sign-in • Core (Web) Automated in CI

Precondition: an account with two-factor **On** (QA-MFA-01). **Gherkin**

```
Given my account has two-factor enabled
When I sign in with an email OTP
Then I'm asked for an authenticator code before the session starts
And entering a valid code completes sign-in
```

Walkthrough

1. Sign out. On `/login`, request an **email code**, enter it.
2. **Expected:** instead of landing signed-in, a **second prompt** asks for the authenticator code.
3. Enter the current 6-digit code -> you're signed in (lands on `/`).
4. **Wrong/expired code:** an inline error; you stay on the step-up prompt (no session).
5. **Note:** OAuth and magic-link sign-ins enforce the step-up too (QA-MFA-04); native (MAUI) too (QA-MFA-05).

QA-MFA-03 — Use a recovery code, then disable two-factor • Core (Web)

Gherkin

```
Given my account has two-factor enabled
When I sign in and enter a recovery code at the step-up
Then sign-in completes (that code is now spent)
And I can disable two-factor from Settings with a valid code
```

Walkthrough

1. Sign in as in QA-MFA-02; at the step-up, enter one **recovery code** instead of a TOTP -> signs in. Entry is forgiving: wrong case, a dropped hyphen, or stray spaces still match (`K7M2Q9XR4T` ≡ `k7m2q-9xr4t`).
2. **Settings** -> **Two-factor authentication** (On) -> **Disable two-factor** -> enter a current TOTP (or another recovery code) -> **Disable**.
3. **Expected:** the badge flips to **Off**; a subsequent sign-in no longer asks for a second step.

QA-MFA-04 — Redirect logins (OAuth / magic link) enforce the step-up • Core (Web)

Precondition: an account with two-factor **On**, reachable via an OAuth provider and/or magic link. **Gherkin**

```
Given my account has two-factor enabled
When I sign in with Google/Microsoft or a magic link
Then I am redirected to the authenticator step-up before any session is issued
And entering a valid code completes sign-in
```

Walkthrough

1. Sign out. Sign in via **Google/Microsoft** (or click a **magic link**).
2. **Expected:** instead of landing signed-in, you arrive on `/login` showing the **authenticator code prompt** (the URL carries a one-time `?mfa=` challenge). No session exists yet.
3. Enter the current 6-digit code (or a recovery code) -> you're signed in (`/auth-callback` -> `/`).
4. **Security check:** confirm you are **not** signed in until the code is accepted — a wrong/expired code keeps you on the prompt with no session. (This closes the gap where redirect logins skipped MFA.)

QA-MFA-05 — Native (MAUI) sign-in enforces the step-up • Core (Desktop/Android)

Precondition: an account with two-factor **On**; run the desktop/Android shell (see the platform's MOBILE_TESTING). Native has no magic link — use **email OTP** or **OAuth**. **Gherkin**

```
Given my account has two-factor enabled
When I sign in on the native app with an email code or OAuth
Then the app shows the authenticator step-up in-app before completing sign-in
And a valid code (or recovery code) finishes sign-in
```

Walkthrough

1. In the native app, sign in with an **email code** (or a provider).
2. **Expected:** the app stays on the login screen and shows the **authenticator code prompt** (it does not sign in yet). No session/token is stored.
3. Enter the current 6-digit code (or a recovery code) -> you're signed in (lands on `/`).
4. **Wrong/expired code:** inline error; you remain on the prompt (no session). Tokens arrive in the response body (native transport), same as a normal native login.

QA-NOTIF-01 — Notification bell + list • Core (Web) Automated in CI

Note: the platform has no built-in producer; to see items, a feature must call `INotificationService.NotifyAsync` (seed one in dev, or exercise a downstream feature that notifies). **Gherkin**

```
Given I am signed in
When I open the notification bell in the header
Then I see my notifications newest-first, with unread ones marked
And the bell shows an unread count when I have unread notifications
```

Walkthrough

1. In the header, click the **bell**. **Expected:** a dropdown opens; with none, it reads "You're all caught up."
2. With unread notifications present: a red **count badge** shows on the bell; unread rows carry a dot + bold title; each shows a relative time ("just now", "5m", "3h", "2d").
3. Click the backdrop (outside the panel) -> it closes.

QA-NOTIF-02 — Mark read / mark all read • Core (Web) Automated in CI

Precondition: at least one unread notification (see QA-NOTIF-01 note). **Gherkin**

```
Given I have unread notifications
When I click one (and, separately, "Mark all read")
Then that one clears its unread mark and the count drops
And "Mark all read" zeroes the count
```

Walkthrough

1. Open the bell -> click an **unread** row. **Expected:** its dot/bold clears; the count decrements.
2. Click **Mark all read**. **Expected:** the count badge disappears; all rows show as read.
3. Reload the page -> the counts/read state persist (server-side).

QA-NOTIF-04 — Delete a notification / clear read / clear all • Edge (Web)

Precondition: a mix of read and unread notifications (see QA-NOTIF-01 note). **Gherkin**

```
Given I have read and unread notifications
When I click a row's trash icon (and, separately, "Clear read" / "Clear all")
Then that row is removed (unread ones also drop the count)
And "Clear read" removes only the read rows; "Clear all" empties the list
```

Walkthrough

1. Open the bell -> click the **trash icon** on the left of a row. **Expected:** the row disappears (without marking anything read — the trash doesn't trigger the row click); if it was unread the count decrements.
2. Footer -> **Clear read**. **Expected:** only the already-read rows vanish; unread ones (and the badge) survive. The button is disabled when nothing is read.
3. Footer -> **Clear all**. **Expected:** the list empties ("You're all caught up."), badge gone.
4. Reload -> deletions persist (server-side; `DELETE /api/notifications/{id}`; bulk requires an explicit scope — `?read=true` clears read, `?read=false` clears all, omitted -> 400 `scope_required`).

QA-NOTIF-03 — Delivery preferences • Core (Web) Automated in CI

Gherkin

```
Given I am signed in on /settings
When I toggle the In-app or Email notification switches
Then the choice is saved and survives a reload
```

Walkthrough

1. **Settings** -> **Notifications** card shows two switches (**In-app**, **Email**), both on by default.
2. Toggle one off. **Expected:** it saves immediately (optimistic; reverts with an error if it fails).
3. Reload -> the switch keeps its new state. (Email-off suppresses the email channel on future notifies; in-app-off suppresses the in-app row.)

10. Web — Localization (i18n) • Core

QA-I18N-01 — Switch language on the login page • Core (Web) Automated in CI

Gherkin

```
Given I am on /login in English
When I choose Español in the language switcher
Then the page text renders in Spanish
```

Walkthrough: on `/login`, use the language select — beside the theme select, under the sign-in controls on the form pane (SKIN-3: at desktop width the page is a split, brand panel left and the form pane right; below that the panel drops out and the lockup sits above the heading) -> **Español**. **Expected:** titles, button labels, and prompts switch to Spanish; the choice persists on reload.

QA-I18N-02 — Language persists per user across sessions • Core (Web) Automated in CI

Gherkin

```
Given I am signed in and set my language to Spanish
When I sign out and sign back in (even in a fresh browser)
Then the app loads in Spanish
```

Walkthrough

1. Signed in, switch to **Español** in **Settings -> Preferences**. (This saves the locale to your user record via `PUT /api/auth/locale` and into the JWT. A pre-auth pick on the login page also works: it's adopted into your user record when you sign in — PREFS-1, ADR-022.)
2. Sign out; sign back in (a fresh browser/private window is the stronger check).
3. **Expected:** app comes up in Spanish — the preference followed the *user*, not just the browser. On a mismatch the app persists the saved locale and reloads once.

QA-I18N-03 — In-app UI is fully translated (no English leaks) • Edge (Web)

Walkthrough: in Spanish, walk Dashboard (the root) -> Household -> Settings -> invite flow. **Expected:** all visible labels/buttons/validation/status messages are Spanish; flag any English string that leaks.

QA-I18N-04 — Email language matches the requester's UI language • Core (Web)

Gherkin

```
Given my UI language is Spanish
When I trigger an OTP / magic link / invitation email
Then the email arrives in Spanish
```

Walkthrough

1. Set UI to **Español**. Trigger an OTP (and a magic link, and send an invite).
2. In Mailpit, open each. **Expected:** subject + body in Spanish. Repeat in English to confirm both.

10b. Web — Admin console (platform staff) • Core

Precondition: your account's email must be in the staff allowlist — set `Admin__StaffEmails__0` in the repo-root `.env` (see `.env.example`) and restart the API. Non-staff accounts must **not** see any of this.

QA-ADMIN-01 — Staff sees the console; non-staff don't • Core (Web) Automated in CI

Gherkin

```
Given I am signed in as a platform-staff user
When I look at the header
Then I see an "Admin" link, and /admin lists every tenant with member counts
And a non-staff user sees no Admin link and is refused at /admin
```

Walkthrough

1. Signed in as **staff**: an **Admin** button shows in the header -> open it (or go to `/admin`).
2. **Expected:** the **Tenants** list shows every tenant (name + member count). Click one -> detail panel shows members (name/email + role), subscription status, created date, audit-event count.
3. Sign in as a **non-staff** user: **no Admin link**; navigating directly to `/admin` shows "You don't have access to the admin console."

> Automated: staff console + tenant list (announcement journey) and the non-staff `/admin` refusal.
> The header **Admin-link visibility** checks (steps 1 and 3's "no Admin link") remain manual.

QA-ADMIN-02 — View a tenant is audited in that tenant • Core (Web)

Gherkin

```
Given I am staff viewing a tenant's detail in /admin
When the detail loads
Then an audit event (admin.tenant.viewed) is recorded in that tenant
```

Walkthrough

1. As staff, open a tenant's detail in `/admin`.
2. **Expected:** an `admin.tenant.viewed` event is written **in that tenant** (visible to that tenant's own audit trail) — the global tenant filter is never loosened; the read enters the target tenant.

QA-ADMIN-03 — Impersonate a user, then stop • Core (Web)

Gherkin

```
Given I am staff on a tenant's detail
When I "Sign in as" a member and confirm
Then I browse the app as that user with a persistent impersonation banner
And "Stop impersonating" returns me to my own staff identity
```

Walkthrough

1. In a tenant detail, click **Sign in as** on a member -> confirm the dialog.
2. **Expected:** you land on `/` **as that user** (their name/household in the header); a yellow **impersonation banner** is pinned at the top; the **Admin** link is hidden while impersonating.
3. Click **Stop impersonating**. **Expected:** you're back as yourself (staff); the banner is gone.
4. The impersonation token is **short-lived (15 min) and non-refreshable** — a full page reload also returns you to your own identity. When it **expires** (leave the impersonated session open 15 min), the app reloads to `/` as yourself: no call from the target's page is ever made as staff, and the client never renews the impersonation (v4 T31, `SessionKeepAliveTests.ImpersonationExpiry_*`). Impersonation is **audited** in the target's tenant.

QA-ADMIN-04 — Staff announcement reaches a tenant's members • Edge (Web) Automated in CI

Gherkin

```
Given I am staff on a tenant's detail in /admin
When I send an announcement (title + body) and confirm
Then every member of that tenant is notified through their preferred channels
And each member's bell shows the announcement; reading it clears the badge
And an admin.announcement.sent audit event is recorded in that tenant
```

Walkthrough

1. As staff, open a tenant's detail in `/admin` -> fill **Send announcement** (title + message) -> **Send to all members** -> confirm. **Expected:** "Announcement sent to N member(s)."
2. Sign in as a member of that tenant. **Expected:** the bell badge shows the unread announcement; opening it shows title + message; clicking it marks it read and the badge clears. Members with email delivery on also get the email (Mailpit).
3. The send is audited **in that tenant** (`admin.announcement.sent`, with the member count).
4. **Targeted variant:** check one or more member rows (new checkbox column) — the button becomes **"Send to N selected"** and only those members are notified (the count in the confirmation and the "sent to N" ack match the selection). Unchecking all reverts to all-members. The selection clears after a send and when switching tenants.

QA-ADMIN-05 — Platform-wide broadcast reaches every user • Edge (Web)

Gherkin

```
Given I am staff on /admin
When I send an "Announce to everyone" broadcast and confirm
Then the request is acknowledged as queued
And every user of every tenant receives it once the outbox delivers
```

Walkthrough

1. As staff on `/admin`, the **Announce to everyone** card sits above the tenant grid (it is not tenant-scoped). Fill title + message -> **Send to everyone** -> the confirm spells out the blast radius (EVERY user of EVERY tenant).
2. **Expected:** "Broadcast queued for delivery." — the fan-out is **asynchronous** (outbox): give the dispatcher a few seconds; delivery is not instant by design.
3. Sign in as users of **two different tenants**. **Expected:** both bells show the announcement.
4. There is **no in-tenant audit row** for a broadcast (the audit trail is per-tenant and this spans all tenants); the durable outbox message is the record.

QA-ADMIN-06 — Comp a tenant to Pro and revert • Edge (Web)

Gherkin

```
Given I am staff on a tenant's detail in /admin
Then the Subscription section states, above the button and before any dialog, what comping (or
reverting) will do
When I use "Upgrade to Pro (comp)" (and later "Revert to Free")
Then the tenant's entitlements match the plan immediately, with no payment involved
And a provider-managed (Stripe-backed) subscription refuses the override
```

Walkthrough

1. As staff, open a **Free** tenant's detail. The header shows a **plan chip** (`free`) next to the status chip; the **Subscription** section shows a "This will" panel stating what comping does, with **Upgrade to Pro (comp)** beneath it (on Pro, the panel says what reverting does instead — SKIN-11).
2. Comp it -> confirm. **Expected:** "Subscription updated."; badge flips to `pro` / `active`; the button is replaced by **Revert to Free**. The comp **never lapses** (no period end) and is audited in-tenant (`admin.subscription.comped`).
3. As that tenant's owner, check `/billing`. **Expected:** plan **Pro**, seat limit 10 — same plan + entitlements as a completed checkout, but **no Manage subscription button** (a comp has no provider customer, so the portal is absent). This simulates payment completion for entitlement purposes; QA-BILL/QA-HH-14 behaviors follow the plan.
4. **Revert to Free** -> confirm. **Expected:** badge back to `free`; entitlements fall back (absence => Free, fail-closed); audited (`admin.subscription.reverted`). Reverting again is a no-op.
5. **Provider-managed guard:** for a tenant with a **real Stripe subscription** (QA-BILL-02), the section shows "Managed by the billing provider — change the plan there." and **no** comp/revert buttons; the API refuses with 409 (Stripe stays the source of truth — ADR-006).

QA-ADMIN-07 — Reset a locked-out user's MFA • Edge (Web)

Gherkin

```
Given a user has MFA enabled but lost both their authenticator and recovery codes
When staff clicks "Reset MFA" on that user's row in the tenant detail and confirms
Then the user's MFA secret and recovery codes are wiped and they can sign in with primary auth alone
And the reset is audited in the user's tenant and the user is notified in-app and by email
```

Walkthrough

1. As a member user, enable MFA in Settings (QA-MFA-01), then pretend the authenticator and codes are lost — do **not** disable it. Sign out. Confirm sign-in now demands the code you "lost" (QA-MFA-02).
2. As staff on `/admin`, open the tenant's detail. Each member row now shows a red **Reset MFA** button next to **Sign in as**. Click it for the locked-out user. **Expected:** the confirm spells out the blast radius (authenticator + recovery codes stop working immediately, the user is notified) and reminds you to verify identity **out-of-band** first. Confirm.
3. **Expected:** "Two-factor authentication was reset for …" above the member table.
4. As the affected user, sign in again. **Expected:** primary auth alone signs you in — **no MFA step-up** (the second factor is gone; primary credentials are untouched). Settings shows MFA off; re-enrolling from scratch works (fresh QR + fresh recovery codes).
5. **Visibility:** the user's bell shows "Two-factor authentication was reset" and the email copy arrives in Mailpit; the tenant's audit trail (owner data export, QA-HH-13) contains an `admin.mfa.reset` event naming the staff actor.
6. **No silent no-op noise:** clicking **Reset MFA** for a member who never enrolled still reports success (idempotent) but writes **no** audit event and sends **no** notification.

10c. Web — Billing page • Core

> With no Stripe keys configured (dev default) the **FakeBillingProvider** is active: checkout/portal return `https://billing.test/...` URLs (a dead domain — expected), and the webhook accepts the signature `valid`. With real Stripe test keys, use Stripe's hosted test checkout instead.

QA-BILL-01 — Billing page shows plan + seats; owner-only • Edge (Web) Automated in CI

Gherkin

```
Given I am the household owner on /billing
Then I see my current plan, its status, and seat usage vs the plan limit
And a member opening /billing sees only the "ask your owner" notice
```

Walkthrough

1. As **owner**, open **Billing** in the header. **Expected:** current plan shown as its localized label (e.g. **Free** — the raw `free` token stays wire-only), status badge, and seats (e.g. `1 of 3 used`); an **Upgrade to Pro** button on the free plan; **Manage subscription** only when a provider customer exists (a comped tenant has a subscription row but no portal button).
2. As a **member**, open `/billing`. **Expected:** no plan/usage — just the owner-only notice.

QA-BILL-02 — Upgrade via checkout + provider webhook lands on Pro • Core (Web) Automated in CI

Gherkin

```
Given the owner on the free plan clicks Upgrade to Pro
When the checkout redirect fires and the provider webhook lands (subscription active)
Then the provider returns me to /billing/success — the Billing page with a "Payment received" banner
— and the page refetches on its own until it shows plan pro, status active, the pro seat limit, and
the portal button
And cancelling at the provider returns me to /billing/cancel — the same page with a "nothing changed"
banner and the plan untouched
```

Walkthrough

1. Click **Upgrade to Pro**. **Expected:** redirect to the provider checkout (fake: `billing.test/checkout/{tenantId}/pro` — the page won't load, which is fine).

2. Simulate payment completion by POSTing the webhook (fake provider): `POST {api}/api/billing/webhook` with header `Stripe-Signature: valid` and a PascalCase JSON body (`EventId`, `TenantId`, `PlanKey: "pro"`, `Status: "active"`, `StripeCustomerId`, `OccurredAt`). **Expected:** 200.
3. Open `/billing/success` (where a real provider returns the browser). **Expected:** the **Payment received** banner, then — within a few seconds, no reload — plan **Pro** / status **Active** (localized labels; raw tokens on the wire), seats `x of 10`, **Manage subscription** now visible, and the owner's bell (+ outbox email) carries a **Subscription active** notice naming the plan and its renewal date. `/billing/cancel` shows the **Checkout cancelled — nothing changed** banner over the unchanged plan.
4. Cancel from the portal (or delete the customer in Stripe) -> the webhook lands. **Expected:** plan **Free**, badge **Canceled**, the line reads **Your paid subscription ended on <date>** (never "renews"), and **Manage subscription** is gone — **Upgrade to Pro** is the way back (a fresh checkout).

10d. Web — Budget settings (app slice BUDGET-1) • Core

> The first **app** section (ADR-V001 port slice P1). Household-wide settings: any member may edit; changes apply to months created afterwards (ADR-V005).

QA-BUD-01 — A new household sees the budget defaults • Core (Web)

Gherkin

```
Given I am signed in to a household that has never saved budget settings
When I open /settings
Then the Budget card shows Thursday and "Last Thursday of the previous month"
And a hint says a weekly-paid household should start the week on its payday (income itself lives on
the Budget page — #203)
```

Walkthrough: sign in with a fresh account (QA-ONB-01), open **Settings**. **Expected:** a **Budget** card between Preferences and Notifications: *Week starts on* = Thursday with the payday hint beneath it, *Month begins* = "Last Thursday of the previous month", no income fields and no income link (income is on the **Budget** page since #203). Nothing has been saved (`GET /api/budget-settings` returns `is_default: true` and no income fields).

QA-BUD-02 — Save the household's budget structure and see it persist • Core (Web)

Gherkin

```
Given I am on /settings
When I set Monday and "1st of the month" and click Save
Then the card confirms, and a reload (or another member's browser) shows the same values
```

Walkthrough

1. Change *Week starts on* to **Monday** — **Expected:** the anchor options re-label to "…Monday…".
2. Pick **1st of the month**; **Save budget settings**.
3. **Expected:** "Budget settings saved." Reload the page: the values persist. Sign in as another member of the same household (QA-INV-02): they see the same values (household-wide, not per user).
4. Save again with a different weekday. **Expected:** still one row for the household (`GET` shows the new weekday; `is_default: false`).

QA-BUD-03 — Invalid values are refused and nothing changes • Core (Web / API)

Gherkin

```
Given I am on /settings
When I PUT weekday 9 or anchor "x" via the API
Then the API answers 400 invalid_request, and a 400 shown in the card reads "Check the values…"
And a GET still returns the previously saved values
```

Walkthrough: the card only offers valid choices, so the refusal is checked through the API. Via Postman (**11 · Budget settings -> Update — invalid (400)**) -> **Expected:** 400 `{ "error": "invalid_request", "message": "week_start_weekday …" }`; a following **Get budget settings** is unchanged. Without a token -> 401.

10e. Web — Catalog: categories & banks (app slice CATALOG-1/2) • Core

> Two soft-delete name catalogs (ADR-V008): unique per household case-insensitively, deactivate instead of delete, the inactive-clash **Reactivate** offer. Seeded once per household in the first reader's language (ADR-V009).

QA-CAT-01 — A new household's first visit seeds the defaults in its language • Core (Web)

Gherkin

```
Given a fresh household whose member's language is Spanish
When I open Settings -> Catalog -> Manage categories
Then I see the 7 example categories in Spanish (Alimentación … Otro), all Active
And Manage banks shows 9 banks with "Efectivo" first
```

Walkthrough: sign up fresh (QA-ONB-01), switch the language to **Español** on the login page or Settings, then open **Settings -> Catálogo -> Administrar categorías**. **Expected:** 7 rows, Spanish names, Activo badges. Switch the language back to English and reload. **Expected:** the names **stay Spanish** — seeds are localized once (no retranslation). **Administrar bancos**: 9 rows, "Efectivo" present, the bank proper nouns unchanged.

QA-CAT-02 — Create a category; a duplicate name is refused case-insensitively • Core (Web)

Gherkin

```
Given I am on /categories
When I click New category, type "Viajes" and Create
Then "Viajes" appears Active
When I try to create "VIAJES"
Then I see "A category named 'Viajes' already exists" and nothing is created
```

Walkthrough: New category -> `Viajes` -> **Create**. **Expected:** "Created." and the row appears. Repeat with `VIAJES`. **Expected:** the red message in the form; no new row; no **Reactivate** button (the clash is with an *active* entry).

QA-CAT-03 — Deactivate, then the inactive clash offers Reactivate • Core (Web)

Gherkin

```
Given "Viajes" exists and is active
When I Edit it, switch Active off and Save
Then it shows Inactive (still listed, greyed)
When I try to create "viajes"
Then I see the warning with a Reactivate button, and clicking it makes "Viajes" Active again
```

Walkthrough: Edit on Viajes -> **Expected:** the page scrolls so the whole edit card is in view (it renders above the list; with 50+ categories the row clicked is far below it) -> toggle **Active** off -> **Save** -> **Expected:** Inactive badge. **New category** -> `viajes` -> **Create** -> **Expected:** yellow warning "…already exists but is inactive — reactivate it?" with **Reactivate**. Click it. **Expected:** "Updated.", Viajes is Active **and still spelled "Viajes"** (the stored name is restored, not the typed "viajes"). Via Postman (**12 · Catalog -> Create category — duplicate (409)**): `error` is `category_exists_inactive` with `existing_id` and `existing_name`.

QA-CAT-04 — Banks behave the same and are household-wide • Core (Web / API)

Gherkin

```
Given I am on /banks
When I rename "Lafise" to "Lafise CR" and create "Coopenae"
Then another member of the household sees both changes
And a PUT to a bank id from a different household returns 404
```

Walkthrough: on **/banks**, **Edit** Lafise -> `Lafise CR` -> **Save**; **New bank** -> `Coopenae` -> **Create**. Sign in as another member (QA-INV-02) -> **/banks** -> **Expected:** both changes visible (catalogs are household data). Via Postman, PUT `/api/banks/{id}` with an id copied from a *different* household's list -> **Expected:** 404 (never 403 — no existence oracle).

QA-CAT-05 — Cards: a voucher names the card, the household renames it, manual entry may pick it • Core (Web / API)

Gherkin

```
Given the household has no cards and the review queue holds a BAC voucher printed as VISA
**********1234
When I confirm it
Then Settings -> Cards lists VISA-1234 (VISA ····1234, the voucher's bank) with an "auto-named"
badge, and the month row shows VISA-1234 in the Card column
And the review queue says a card still carries the name a voucher gave it, with a link to Manage
cards
When I rename it to "Allan's Visa" and confirm a second voucher on the same card
Then both rows read "Allan's Visa" — one card, the badge is gone, and the queue stops nudging
When I open New transaction
Then Card defaults to "No card"; picking "Allan's Visa" saves it on the row; the month page filters
by card
And POST /api/cards with the same brand + last four is 409 card_exists naming the existing card; a
card from another household on a transaction is 400
```

Walkthrough: Review -> **Expected:** before confirming anything, no nudge. Confirm the voucher -> **Settings -> Manage cards** -> **Expected:** one row **VISA-1234 · VISA ····1234 · Credit · BAC Credomatic · Active** with the **auto-named** badge; back on **Review**, the amber "1 card still carries the name a voucher gave it" line with **Manage cards**. **Edit** -> alias `Allan's Visa` -> **Save** -> **Expected:** the badge and the nudge are gone; the identity line stays **VISA ····1234** (not editable). Month page -> **Expected:** the row's **Card** column reads Allan's Visa; the **Card** filter narrows to it. **New transaction** -> **Expected: Card** = *No card*; pick Allan's Visa -> **Save** -> the row shows it. **Export CSV** -> the last columns are `card,notes`. Via Postman (**24 · Cards**) -> Create card with brand VISA and last4 1234 -> **Expected:** 409 `card_exists` with `existing_id`; **Create card — invalid** -> 400.

QA-CAT-06 — A renewed card is the same card: merge keeps the history • Core (Web / API)

Gherkin

```
Given "Allan's Visa" (VISA ····1234) with transactions on it
When the bank renews the card and a voucher printed VISA **********5678 is confirmed
Then VISA-5678 appears auto-named, carrying that transaction, and the queue nudges about it
When I choose "Same card as… Allan's Visa" and Merge
Then one card remains, listing ····1234 · ····5678, every transaction on it, and the newest number as
its own
And the next voucher on EITHER number lands on that card; POST /api/cards/{id}/merge into itself is
400
```

Walkthrough: confirm a voucher whose last four differ from the card you have -> **Settings -> Manage cards** -> **Expected:** a second, auto-named row. Press **Same card as…** on it -> pick the card you know -> **Merge** -> **Expected:** the notice "Merged — one card, all its numbers", a single row whose Card column reads **VISA ····1234 · ····5678**, and the alias you chose (not the automatic one). Month page -> **Expected:** the rows that were on the renewed card now read the surviving alias. Via Postman (**24 · Cards -> Merge a renewed card into another**) with `into` set to the same id -> **Expected:** 400 `invalid_request`.

QA-CAT-07 — Credit or debit lives on the card and decides the payment method • Core (Web / API)

Gherkin

```
Given a card marked Credit (the default for every card that existed before this) with transactions on
it
When I edit it to Debit and save without ticking the backfill
Then the card reads Debit and not one past transaction moved
When I edit it again ticking "Also correct past transactions on this card"
Then the notice names how many moved, and those rows read Bank account on the month page
When I open New transaction and pick that card
Then Bank and Payment method become the card's own — its bank, and Bank account for a debit card —
shown as text under a hint reading "From the card — change the card to change these", not as pickers
I could contradict
And picking "No card" opens Bank and Payment method back up; a card with no bank on record leaves
Bank open and points at Cards
And the "How it was paid" group reads Card, then Bank, then Payment method
And confirming a voucher on that card books the transaction against the bank account, still naming
the card
```

Walkthrough: Settings -> Manage cards -> **Expected:** a **Kind** column reading Credit or Debit. **Edit** a card -> **Kind** -> `Debit` -> **Save** -> **Expected:** "Updated", the row reads Debit, and the month page is unchanged. **Edit** -> tick **Also correct past transactions on this card** -> **Save** -> **Expected:** "Updated. N past transaction(s) now match this card"; those rows now read **Bank account**, and the dashboard's **By bank and payment method** moves that money from the card group to the account group. **New transaction** -> the "How it was paid" group lists **Card** first -> pick the debit card -> **Expected: Bank** reads the card's bank and **Payment method** reads **Bank account**, both as text, with "From the card — change the card to change these" under the card; pick **No card** -> **Expected:** both are pickers again. Pick a card with no bank set -> **Expected:** Bank stays a picker and the hint links to **Cards**. Confirm a voucher on it -> **Expected:** the booked row is **Bank account**. Via Postman (**24 · Cards -> Update card**) with `kind: "prepaid"` -> **Expected:** 400 naming `kind`.

10f. Web — Exchange rate (app slice FX-1) • Core

> The day's USD->CRC rate and its honest fallback chain (ADR-V006): live -> stale "as of …" -> the household's last transaction -> unavailable. The app never invents a rate. Default provider: the Banco Central reference **buy/sell pair** via the Finance Ministry mirror — no key, works in a fresh checkout (ADR-V019). A $ purchase converts at the sell side, a ■ purchase at the buy side; income the other way round. `ExchangeRate__Provider=exchangerate-api` + `ExchangeRate__ApiKey` select the old one-rate world feed instead.

QA-FX-01 — The dashboard shows today's BCCR buy/sell pair, and each currency freezes its own side • Core (Web / API)

Gherkin

```
Given the API runs with the default provider (no ExchangeRate__ keys in .env) and has internet access
When I open the app (the root is the dashboard)
Then I see "Today's rate buy ■<compra> · sell ■<venta> per $1" with a green "live" badge under the
month selector (or on the empty state before the first month)
And GET /api/exchange-rate returns 200 { rate: <venta>, buy: <compra>, sell: <venta>, source: "live",
as_of }
When I reload within the hour
Then the same as_of comes back (cached — no second provider call)
When I open New transaction with currency CRC
Then the rate field is pre-filled with <compra>; switching the currency to USD pre-fills <venta>; a
rate I typed stays
When I save a $20 purchase
Then the month page shows it as ■(20 × venta) with exchange_rate_used = <venta>
```

Walkthrough: open the app (**Dashboard** is the root) -> **Expected:** the rate line under the month selector — or on the empty state before the first month — reading **buy ■… · sell ■… per $1** with the green **live** badge; both values plausible (≈ 440–560 colones per dollar in 2026, sell a few colones above buy) and matching https://api.hacienda.go.cr/indicadores/tc (`dolar.compra` / `dolar.venta`). Via Postman (**13 · Exchange rate -> Get exchange rate**) -> **Expected:** 200 with `rate` = `sell`, `buy` > 0, `source` = `live`, `as_of` ≈ now. Send it again -> **Expected:** identical `as_of` (served from the one-hour cache). Without a token -> 401. **New transaction** -> **Expected:**

the rate field pre-filled with the **buy** figure while the currency is CRC; pick USD -> the **sell** figure; type your own rate, switch currency again -> your rate stays. Save a $20 purchase -> **Expected:** the month page shows ■(20 × sell) beside it (a ■ purchase would show $(amount ÷ buy)). A voucher confirmed from the review queue freezes the same side for its currency — of the pair taken when the voucher **arrived**, not when it is confirmed (EMAIL-8): sync a voucher, confirm it the next day, and its rate is the one Postman showed on the day of the sync. A voucher synced while the provider was down books at the confirm day's rate.

QA-FX-02 — No provider -> the honest "unavailable" state, never a fabricated rate • Core (Web / API)

Gherkin

```
Given ExchangeRate__Provider=exchangerate-api with no ExchangeRate__ApiKey (the keyless world feed)
and the household has no transactions
When I open the app (the dashboard)
Then I see the red "Exchange rate unavailable — try again later" badge and no number
And GET /api/exchange-rate returns 503 { error: "exchange_rate_unavailable", message: "…" }
```

Walkthrough: set `ExchangeRate__Provider=exchangerate-api` in `.env` (leave `ExchangeRate__ApiKey` unset), restart the API, open the **Dashboard** with a household that has no transactions -> **Expected:** the red badge, no rate figure. Via Postman (**13 · Exchange rate -> Get exchange rate**) -> **Expected:** 503 with the shared error shape and `error` = `exchange_rate_unavailable`. With transactions the chain answers the last frozen rate instead (yellow "from your last transaction" badge, `buy` = `sell`). Remove the override and restart -> QA-FX-01 passes again. (The stale-cache tier and the BCCR client's own failure modes are covered by `Api.Tests`.)

10g. Web — Envelopes (app slice ENV-1) • Core

> Savings buckets with an annual target (■ and/or $) and a reminder cadence (ADR-V007), managed like the other catalogs (ADR-V008): unique per household, deactivate instead of delete, the inactive-clash **Reactivate** offer. Never seeded — a fresh household starts empty.

QA-ENV-01 — Create an envelope with targets and a reminder; duplicates are refused • Core (Web / API)

Gherkin

```
Given I am on /envelopes (Settings -> Catalog -> Manage envelopes) in a fresh household
Then I see the empty-state message
When I click New envelope, type "Marchamo", ■718000, "Only on 5-week months" and Create
Then "Marchamo" appears with ■718,000.00, $0.00, "Only on 5-week months" and an Active badge
When I try to create "MARCHAMO"
Then I see "An envelope named 'Marchamo' already exists" and nothing is created
When I type a negative target
Then the form refuses it before calling the API
```

Walkthrough: Settings -> Catalog -> Manage envelopes -> **Expected:** "No envelopes yet…". **New envelope** -> name `Marchamo`, **Annual target (■)** `718000`, **Reminder** "Only on 5-week months" -> **Create** -> **Expected:** "Created." and the row with both targets and the reminder. Repeat with `MARCHAMO` -> **Expected:** the red message in the form, no new row, no **Reactivate**. Type `-5` in a target -> **Create** -> **Expected:** "Targets cannot be negative." and no request. Via Postman (**14 · Envelopes -> Create envelope**) -> 201; re-send -> 409 `envelope_exists`; **Create envelope — invalid (400)** -> `invalid_request` naming `reminder_cadence`.

QA-ENV-02 — Edit, deactivate, then the inactive clash restores it • Core (Web / API)

Gherkin

```
Given "Marchamo" exists and is active
When I Edit it, change the target to ■750000, switch Active off and Save
Then it shows Inactive with the new target
When I try to create "marchamo" with ■800000
Then I see the warning with a Reactivate button, and clicking it makes "Marchamo" Active with
■800,000.00
And a PUT to an envelope id from another household returns 404
```

Walkthrough: Edit on Marchamo -> target `750000` -> **Active** off -> **Save** -> **Expected:** "Updated.", Inactive badge, ■750,000.00. **New envelope** -> `marchamo`, `800000` -> **Create** -> **Expected:** yellow "…already exists but is inactive — reactivate it?" with **Reactivate**. Click it -> **Expected:** "Updated.", **Marchamo** (stored spelling) Active with ■800,000.00. Via Postman (**14 · Envelopes -> Update envelope**) with an id copied from a *different* household's list -> **Expected:** 404 (never 403 — no existence oracle).

10g2. Web — Income lines (app slice INCOME-1) • Core

> Each income is a line (ADR-V023): whose it is (a member, or the household), its currency, **fixed** or **variable** (an estimate), how often it is paid (**weekly**, **twice a month** on two days, **monthly**) and the amount per payment. Catalog rules as the envelopes (ADR-V008). Every month created afterwards starts with one income row per active line: weekly × the month's weeks, twice a month × the pay days inside the month's window, monthly × 1. Never seeded. With the default settings (Thursday / last Thursday of the previous month) **September 2026** runs **Aug 27 – Sep 23** (4 weeks) and holds the **Aug 31** and **Sep 15** pay days.

QA-INC-01 — Add, order, deactivate and reactivate income lines; the catalog rules hold Automated in CI • Core (Web / API)

Gherkin

```
Given I am on Budget in a fresh household
Then its Income card says there is no income yet
When I click Edit income
Then I see the empty-state message
When I add "My salary", mine, Weekly, $500 and Create
And I add "Son salary", the household, Twice a month (15th and Last day), ■300,000
Then both rows show their amount, whose they are, Fixed or Variable, and how they are paid
When I move "Son salary" up
Then the order is saved and survives a reload
When I edit "My salary" and switch Active off
Then it shows Inactive and has no up/down buttons
When I add "my SALARY", Weekly, $550
Then I am offered Reactivate, and clicking it restores "My salary" (stored spelling) as active,
weekly, with $550 — the typed details win
And an amount of 0, or the same pay day twice, is refused before any request
When I go back to the budget
Then its Income card, above the fixed and variable lines, lists the active lines in their own
currencies with "A typical month"
And Settings has no income link any more
```

Walkthrough: Budget -> **Expected:** an **Income** card above the fixed and variable lines saying "No income yet…" -> **Edit income** -> **Expected:** "No income yet…". **New income** -> name `My salary`, **Whose income** = yourself, **Paid** = Weekly, `500`, **USD** -> the hint under the form says a month counts one payment per week and points to the week start -> **Create** -> **Expected:** "Created." and the row (`$500.00`, your name · Fixed · Weekly). **New income** -> `Son salary`, **Whose income** = "The household", **Paid** = Twice a month -> **Expected:** two pay-day selects appear with **15** and **Last day** -> `300000`, **CRC** -> **Create**. Click ↑ on Son salary -> **Expected:** it moves to the top; reload -> still first. **Edit** My salary -> **Active** off -> **Save** -> **Expected:** Inactive, no ↑/↓ on it. **New income** -> `my SALARY`, **Paid** = Weekly, `550` -> **Create** -> **Expected:** the yellow "…already exists but is inactive" warning with **Reactivate** -> click -> **Expected:** "Updated.", **My salary** active at $550.00. Type `0` -> **Create** -> **Expected:** "Enter an amount greater than zero." and no request; Twice a month with both days **Last day** -> "Pick two different pay days.". Via Postman (**25 · Income**): **Create income line** -> 201, re-send -> 409 `income_exists`; **Create income line — invalid (400)** -> `invalid_request` naming `pay_days`; a `member_user_id` from another household -> 400; **Update income line** with an id from another household -> 404; **Reorder income lines** with a list that isn't exactly the active lines -> 400.

QA-INC-02 — A new month starts with the lines' plan; one month is corrected without touching the lines Automated in CI • Core (Web / API)

Gherkin

```
Given the lines of QA-INC-01: "Son salary" ■300,000 twice a month and "My salary" $550 weekly
When I save the first transaction dated 2026-09-10
Then September 2026 (4 weeks) lists "Son salary" ■600,000 (two pay days) and "My salary" $2,200
(four weeks), in the lines' order
When I set "My salary" to 2000, remove nothing, add "Sold the bike" ■150,000 and click Save income
Then "Income updated.", My salary shows "Planned $2,200.00" beneath it, the one-off says "Only this
month"
And the dashboard's income counts ■600,000 + $2,000 + ■150,000 at the day's rate, with inflows named
separately
And the income page still shows My salary at $550 weekly
When I remove a row and Save
Then it is gone from the month only
```

Walkthrough: New transaction -> `10000` CRC, date `2026-09-10`, any payee, category and bank -> **Save** -> **Expected:** the September 2026 page with an **Income this month** block: two rows in the income page's order, each an editable name, amount and currency, `600000` CRC and `2200` USD, no "Planned" line (nothing corrected yet) and a **Manage income** link. Change `2200` to `2000` -> **Expected:** "Planned $2,200.00" appears under it. **Add income for this month** -> name `Sold the bike`, `150000`, **CRC** -> **Expected:** "Only this month" under it; after saving, **Reports -> Chart -> Income by member** counts it under **your** name (a one-off is the income of whoever adds it). Leave a name blank -> **Save income** -> "Every income needs a name." and no request; fill it -> **Save income** -> **Expected:** "Income updated."; reload -> the three rows as saved. **Dashboard** -> the Income step's total is the three rows at today's rate. **Budget -> Edit income** -> **Edit** Son salary -> set **Whose income** to yourself -> **Save** -> back on September -> **Expected:** Son salary's row unchanged in name and amount, and **Reports -> Chart -> Income by member** now counts it under your name (the member follows the line; the amounts never do). **Budget -> Edit income** -> **Expected:** My salary still $550.00 weekly. Remove **Sold the bike** (×) -> **Save income** -> gone after reload. With Tuesday weeks (**Settings -> Budget**, *Week starts on* Tuesday) a transaction in a month not yet created gets five weeks and five weekly payments (Sep 2026 would be Aug 25 – Sep 28 — use a later empty month on a household that already has September). Via Postman (**15 · Months -> Get month**) -> `income_rows` with `planned_amount`; **Update month income — invalid (400)** -> `invalid_request`; the month id of another household -> 404.

QA-INC-03 — The income migration keeps every month's income (rehearsal and after deploy) • Smoke (API / DB)

Gherkin

```
Given a database copy taken before INCOME-1 (a Neon branch of staging, or the local database with old
data)
When the API starts and applies the AddIncomeLines migration
Then ops/check-income-parity.sql returns no rows
And each household's old defaults appear as income lines ("Primary income", "Secondary income"), the
irregular ones flagged "Check this"
And every existing month shows the same income on its page and on the dashboard as before the
migration
And the old income columns still hold their values
```

Walkthrough: before merging, create a Neon branch of staging (DEPLOYMENT §9) and take the household snapshot. Point a local API at the branch -> it migrates on start. Run:

```
psql "$BRANCH_URL" -f ops/check-income-parity.sql
```

Expected: `(0 rows)`. Open **Budget -> Edit income** -> **Expected:** "Primary income" / "Secondary income" with the pay period the old figures implied; a pair that fit no period shows a **Check this** badge (hover: why), which clears on the first save. Open three past months and their dashboards -> **Expected:** the same income totals as production before the deploy. Repeat the parity query on staging right after the deploy, **before anyone edits a month's income** -> `(0 rows)`; any row -> roll the app back (the old columns are intact) and investigate.

QA-INC-04 — The month report says whose the income is • Core (Web / API)

Gherkin

```
Given September 2026 has income rows for me, a household row, a row of a member who left, and an
inflow
When I download the September PDF from Reports
Then it has an "Income by member" table (Whose · Income · Share) listing my name, "The household",
"Former members" and "Other income (inflows)", with a Total row equal to the month's income, all on
one page
And there is no "Income by member" chart, in the PDF or on the Reports page
When I report a date range, or the rate is unavailable
Then the PDF has no income by member table
```

Walkthrough: with the month of QA-INC-02 (add a household line and an inflow first, if needed), **Reports** -> the month -> **Chart** -> **Expected:** no income by member card. **PDF -> Download** -> **Expected:** no income by member chart, and before "By category" the **Income by member** table whose shares add to 100% and whose total equals the income tile's basis; in Spanish (Settings -> language) the labels read *Ingreso por miembro*, *El hogar*, *Exmiembros*. A date range -> **Expected:** no table. Via Postman (**20 · Reports -> Category analysis (month)**) -> `income_by_member` with `kind` per slice, summing to `income`; the range request -> `income_by_member: null`.

10h. Web — Months & transactions (app slice LEDGER-1/2) • Core

The transaction form is presented per SKIN-7 (2026-09-12): amount FIRST and at display size, with the currency toggle inside the same input group and the live conversion under it; then two named groups, **What it was** and **How it was paid**; then a **Before you save** rail stating which pay-cycle month the date lands in and both sides of the money. The class picker is five CHIPS in a radio group, not a dropdown — all five, because each one opens a different path (unplanned or discretionary -> expected refund, envelope -> bucket picker, inflow -> income). Save stays ENABLED and surfaces validation on submit; it never goes quietly dead. Unchanged: which month a date falls into is the pay-cycle logic's business, and the rate freezes on save, never on edit.

Months and the month page are presented per SKIN-8 (2026-09-12). Months is a card grid (three columns at desktop, two on tablet, one on phone): each card is ONE link carrying the month name, a **Current** / **Closed** / **Upcoming** chip (current = the window that holds today, not simply the newest), the window and week count, an 8px spent-versus-planned bar, "Spent ■…" and the result in green (left) or red (over). The figures come from each month's summary after the grid is already on screen; a month whose rate cannot resolve still shows as a card, with "Figures unavailable". A closed month's bar is solid and its result is what was actually left. The **month page** opens with "← All months" and the Dashboard link, the title, and one chip per week ("W1 · Jun 25"; hover for the full window); **income is a short list of rows** (INCOME-1: one editable name + amount + currency per income, **Add income for this month** and **Save income**); the ledger is one table — Date, Payee, Category, Paid with, Class, Amount — with class CHIPS, a stacked **Amount** cell (the "Show in" currency on top, the other muted beneath; one side only when a single currency is chosen) and **Paid with** = the bank with the card's alias beneath it. Below tablet width Category and Paid with hide and the payee gains a muted sub-line ("Groceries · Cash · Casa VISA") with the class chip beneath it, the date narrows to "Jul 6", and the filters fold behind a **Filters** button next to the payee search; the table never scrolls sideways. Refund rows use a status PILL (amber Pending, green Received — under the payee on a phone) and a stacked amount.

The core loop (ADR-V005/V006/V007): a transaction's date decides its pay-cycle month; months appear with their first transaction (weeks materialized, income snapshotted) and leave with their last; the exchange rate is frozen at creation. Fixture with the default settings (Thursday / last Thursday of the previous month): **June 2026** = 4 weeks (28 May – 24 Jun), **July 2026** = 5 weeks (25 Jun – 29 Jul).

QA-LED-01 — The first transaction creates its month with weeks and an income snapshot • Core (Web / API)

Gherkin

```
Given a fresh household with no months, and income lines "Salary" $750 weekly and "Rent" ■312,500 monthly
When I open New transaction
Then the AMOUNT is the first field, at display size, with the currency toggle inside its own input group and the conversion under it ("= $… at ■… per $1 · frozen when you save")
And the rest reads as two named groups — What it was (payee, category, class chips, notes) and How it was paid (bank, card, method, rate)
And a Before you save rail states which month AND week the date lands in ("Goes to July 2026 · week 3 — a new month will be created"), lists ■, $ and the rate used, and — for budgeted spending whose category backs a line in an existing month — states that line's spend so far, its plan, and the total after this purchase
When I type "AutoMercado", 50000 CRC, date 2026-07-10, bank Cash, class Budgeted
And I click "+ New" beside Category, type "Viajes" and Create
Then "Viajes" is selected without leaving the form (it also appears under Settings -> Categories); typing "viajes" again just selects it
Then the date says "Goes to July 2026 — a new month will be created" and the rate is pre-filled
When I Save
Then I land on July 2026: five week chips (W1 · Jun 25 … W5 · Jul 23), income rows Salary 3750 USD and Rent 312500 CRC, one row whose Amount cell stacks ■50,000.00 over $<50000 ÷ rate>, its class a "Budgeted" chip
And the transactions table sorts by Date, Payee, Category, Paid with or Class when I click the header (click again to flip; ▲/▼ marks the active one)
And the filters above it narrow the rows by payee search, category, bank, card, class and date range, with "Showing n of m" and a Clear button; on a phone the search stays and the rest fold behind a Filters button
```

Walkthrough: Budget -> Edit income -> add `Salary` $750 weekly and `Rent` ■312,500 monthly. **Dashboard -> New transaction** (or nav **Months -> New transaction**): fill the fields; beside **Category** click **+ New**, type `Viajes`, **Create** -> **Expected:** the inline form closes and **Viajes** is selected (Enter also creates, Esc cancels; a blank name -> "A name is required."; a name matching an inactive category offers **Reactivate "…"**). Pick the date `2026-07-10` -> **Expected:** the rail reads "Goes to July 2026 · week 3 — a new month will be created" (week 3: Jun 25 – Jul 1, Jul 2 – 8, Jul 9 – 15); with the date back in an existing month and a budgeted category that has a line, a second line reads "Groceries: ■8,000.00 spent of ■60,000.00 planned — after this, ■58,000.00" (a dollar purchase against a colón line is converted at today's rate first); the **Exchange rate** field pre-filled (or, without a key, the red hint asking for one — type `500`). **Save** -> **Expected:** the **July 2026** page with five week chips (hover one -> its full window), the income rows Salary `3750` USD (5 weeks × $750) and Rent `312500` CRC, and the row: a **Budgeted** chip and the amount stacked (■ on top, $ muted beneath — or one side only if **Show in** is set to a single currency on the dashboard). With a few rows in place: click **Payee** -> **Expected:** A->Z with ▲; click again -> Z->A ▼; **Date** flips newest/oldest; **Paid with** orders by bank. Type `auto` in **Search payee** -> **Expected:** only AutoMercado, "Showing 1 of n"; pick a **Category**, **Bank** or **Class** that matches nothing -> "No transactions match these filters."; **Clear filters** -> all rows back (the filters and sort are on-screen only — no request, and the CSV export still covers the whole month). Narrow the window below tablet width -> **Expected:** the Category, Paid with and Class columns are gone, each payee carries a muted sub-line with the first two ("Groceries · Cash") and its class chip beneath, the date reads "Jul 10", Edit sits over Delete, and the selects sit behind a **Filters** button (a dot on it means a filter is active); nothing scrolls sideways. Via Postman (**15 · Months -> List months**) -> 1 month with `week_count` 5; **Resolve a date** with `2026-05-30` -> `is_new: true`, `month_number` 6 (June's window starts 28 May).

QA-LED-02 — Edit keeps the frozen rate; a date fix moves the transaction • Core (Web / API)

Gherkin

```
Given the July 2026 transaction above (rate frozen at creation)
When I Edit it, change the amount to 100000 and Save
Then the $ amount doubles and the rate field was disabled (frozen) throughout
When I Edit again and change the date to 2026-06-05
Then I land on June 2026 (new, 4 weeks) and July 2026 no longer appears in Months
```

Walkthrough: on the month page -> **Edit** -> **Expected:** the amount field's conversion line now reads "frozen when this was saved" rather than "frozen when you save", and the rate input disabled with the "Frozen when the transaction was created" hint. Amount `100000` -> **Save** -> **Expected:** the row's amount doubles on both lines of the stack (same rate). **Edit** -> date `2026-06-05` -> **Expected:** "Goes to June 2026 — a new month will be created" -> **Save** -> **Expected:** the **June 2026** page (4 weeks); nav **Months** -> **Expected:** only June — July left with its last transaction. Via Postman (**16 · Transactions -> Update transaction**) -> `exchange_rate_used` unchanged in the response.

QA-LED-03 — Deleting the last transaction removes the month • Core (Web / API)

Gherkin

```
Given June 2026 holds exactly one transaction
When I click Delete, then Confirm delete
Then I am taken back to Months and June 2026 is gone
And GET /api/months/{id} returns 404
```

Walkthrough: on the month page -> **Delete** -> **Expected:** the button turns into **Confirm delete** (nothing is sent yet) -> click it -> **Expected:** "Transaction deleted." then the **Months** list without June and the empty-state text. Via Postman (**15 · Months -> Get month**) with the old id -> **Expected:** 404 `not_found`.

QA-LED-04 — Month income is editable; invalid input and foreign ids are refused • Core (Web / API)

Gherkin

```
Given a month exists
When I change its first income row to 1600000 CRC and Save
Then "Income updated." and the values persist on reload
When I PUT a negative amount or EUR via Postman
Then 400 invalid_request
When I PUT /api/months/{id}/income with an id from another household
Then 404
```

Walkthrough: on the month page's income block -> the first row's amount `1600000`, its currency select **CRC** -> **Save income** -> **Expected:** "Income updated."; reload -> values kept. Via Postman (**15 · Months -> Update month income — invalid (400)**) -> `invalid_request`. With an id copied from a *different* household's list -> **Expected:** 404 (never 403 — no existence oracle). Also (**16 · Transactions -> Create transaction — invalid (400)**) -> `invalid_request` naming the field.

QA-LED-05 — An unplanned or discretionary purchase can expect a refund; the refund follows the transaction • Core (Web / API)

Gherkin

```
Given I am on New transaction
When I pick class Unplanned
Then a "Refund expected" switch appears; switching it on shows the amount expected back (a ■ | %
toggle beside its label) beside a "Refund notes" box that spans the row like the transaction's own
Notes
When I enter "Hospital", 50000 CRC, switch the refund to % and type 30, "CASE-7 · lent to Diego", and
Save
Then the month page lists an expected refund: Hospital · 30% · ■15,000.00 · $<30> · Pending, with the
note behind its icon
When I Edit the transaction to 80000 and Save
Then the refund still reads ■15,000.00 (an amount: a bigger purchase doesn't grow it) at 19 %
When I Edit it, switch the refund to % and type 30, and Save
Then the refund reads ■24,000.00
When I Edit it again, switch Refund expected off and Save
Then the refund is gone
When I pick class Discretionary
Then the "Refund expected" switch is there too; for Budgeted it is not
```

Walkthrough: New transaction -> **Class** "Unplanned" -> **Expected:** the **Refund expected** switch appears. Pick **Discretionary** -> **Expected:** it is still there (ADR-V025); pick **Budgeted**, **Income** or **Savings** -> **Expected:** it is gone. Back to **Unplanned**. Switch it on -> **Expected:** the **Amount expected back** field with a **■ | %** toggle beside its label, and **Refund notes** beside it — a one-row box at the percentage's height (drag it taller) spanning the rest of the row, with a 0/250 counter like the transaction's own Notes and a placeholder reading "Optional — case number, who owes it, when you expect it back"; no separate Case No.; with `50000`, the toggle on **%** and `30` the hint reads "Expected back: ■15,000.00"; back on ■ the field holds `15000` and the hint reads "30 % of ■50,000.00". Type `CASE-7 · lent to Diego`, fill the rest and **Save** -> **Expected:** the month page's **Refunds** table shows Hospital · 30% · ■15,000.00 stacked over $30 · an amber **Pending** pill and a note icon whose hover text is "CASE-7 · lent to Diego", with a **Mark received** button (its accessible name says "Mark Hospital received"). **Edit the transaction** -> **Expected:** the refund notes prefilled; clear them and **Save** -> **Expected:** the note icon is gone. **Edit** -> amount `80000` -> **Save** -> **Expected:** the

refund row still reads ■15,000.00, now at 19 %. **Edit** -> the refund opens on `15000` -> toggle **%**, type `30` -> **Save** -> **Expected:** ■24,000.00. **Edit** -> switch off -> **Save** -> **Expected:** "No refunds expected this month." Via Postman (**16 · Transactions -> Create transaction**) with `refund_expected: true, refund_amount: 60000` on a 50000 purchase -> **Expected:** 400 `invalid_request` naming `refund_amount`; with `transaction_type: "budgeted", refund_expected: true, refund_amount: 15000` -> **Expected:** 400 `invalid_request` naming `refund_expected`, and nothing is created.

QA-LED-06 — Marking a refund received books an inflow; reverting removes it • Core (Web / API)

Gherkin

```
Given an expected refund of ■15,000.00 (Pending) on a purchase in this month
And the Received on date next to Mark received defaults to today and refuses a date before the
purchase
When I keep a date inside this month and click Mark received
Then the pill reads "Received <date>" and the transactions table gains an Income (inflow) row of
■15,000.00 on that date, marked "Derived from a refund — read-only"
And the Income card shows "Other income this month" ■15,000.00 with a "show the 1 transaction(s)"
link that filters the table to inflows, and the dashboard's Income gains an "Other income (inflows)"
sub-row of the same amount
And that row has no Edit/Delete buttons
When I click Back to pending
Then the inflow row disappears and the pill is Pending again
When I pick a date in the NEXT month and click Mark received
Then the pill reads "Received <date>" with a "booked in another month — view" link, this month's
table has NO inflow row, and the linked month (created if needed) holds it
When I click Back to pending -> the inflow is gone, and that month with it if it was otherwise empty
And the Expected refunds header reads "Received ■15,000.00 · Pending ■0.00 · of ■15,000.00" while it
is received
When the refund is Received and I Edit its purchase
Then the refund switch and amount are disabled with "Already received — mark it back to pending on
the month page to change it."
And deleting the purchase is refused with 409 refund_status_conflict, and nothing changes
```

Walkthrough: on the month page, the pending row shows **Received on** (today) next to **Mark received**; the date input's minimum is the purchase date. **Mark received** -> **Expected:** "Refund updated.", the pill **Received <today>**, the button now **Back to pending**, and a new **Income (inflow)** row dated today with the refund's amounts whose actions column says "Derived from a refund — read-only". Via Postman (**16 · Transactions -> Delete transaction**) with that inflow's id -> **Expected:** 400 `derived_transaction`. **Back to pending** -> **Expected:** the inflow row is gone, the pill **Pending**. Via Postman (**17 · Refunds -> Update refund status**) send `received` twice -> **Expected:** 200 both times, one inflow in **List month transactions**. With an id copied from a *different* household -> **Expected:** 404. (The concurrent-flip 409 is proven by `Api.Tests`.) **Cross-month (ADR-V017): Back to pending**, pick a **Received on** date in the *next* month -> **Mark received** -> **Expected:** the pill "Received <date>" plus **booked in another month — view**; this month's transactions table has no inflow; the link opens the next month (auto-created if it did not exist) with the inflow row dated as picked. Postman **Update refund status** with `received_date` before the purchase -> **Expected:** 400 `invalid_request`. **Back to pending** -> **Expected:** the inflow is gone and the next month too if it held nothing else. **Totals (#206):** with the refund received, the **Expected refunds** header reads **Received** ■15,000.00 · **Pending** ■0.00 · **of** ■15,000.00; back to pending, the two swap. **Locked once received (ADR-V026): Mark received** again, then **Edit** its purchase -> **Expected:** the **Refund expected** switch and the amount are greyed out with "Already received — mark it back to pending on the month page to change it."; change the purchase's notes and **Save** -> **Expected:** saved, the inflow unchanged. Postman **Delete transaction** on the purchase -> **Expected:** 409 `refund_status_conflict`, the purchase, refund and inflow all still there. **Back to pending** -> **Edit** -> the refund is editable again.

QA-LED-07 — A transaction can carry a short note; the month page shows it as an icon • Edge (Web / API)

Gherkin

```
Given a month with transactions
When I open New transaction, fill the fields and type "Tuti's birthday dinner" in Notes
Then the counter reads 22/250 and Save stores the note trimmed
When I open the month page
Then the row shows a small note icon after the payee; hovering reads the note; clicking it opens Edit
with the note filled
When I clear the note on Edit and Save
Then the icon is gone
And POST /api/transactions with 251 characters of notes is 400 invalid_request naming notes
And confirming a voucher with notes books the note on the transaction; Export CSV ends with a notes
column
```

Walkthrough: New transaction -> **Expected:** a **Notes** box under Payee with `0/250`; type a note -> the counter follows -> **Save** -> month page -> **Expected:** a note icon next to the payee (hover shows the text); rows without a note have none. Click the icon -> **Expected:** the Edit page with **Notes** filled. Clear it -> **Save** -> **Expected:** no icon. **Review** -> a draft's card has a **Notes** box -> confirm with a note -> **Expected:** the booked row carries the icon. **Export CSV** -> **Expected:** the header ends …,`card`,`notes`. Via Postman (**16 · Transactions -> Create transaction**) with a 251-character `notes` -> **Expected:** 400 `invalid_request`, message mentions `notes`.

QA-EMAIL-07 — Clearing the review queue re-reads those emails and spares everything else • Core (Web / API)

Gherkin

```
Given drafts wait in the review queue, at least one voucher was confirmed and one discarded
When I open Settings -> Email and press "Clear the review queue"
Then a warning names the number of drafts and says confirmed transactions and discarded drafts are
untouched
When I confirm
Then the queue is empty, the header badge drops to zero, and no transaction, month or refund changed
When I press Sync now on the inbox
Then the cleared emails are staged again with today's parser; the confirmed and discarded ones do not
come back
And POST /api/pending-vouchers/clear without confirm is 409 confirmation_required
```

Walkthrough: Settings -> Email -> bottom of the page -> **Expected:** "N draft(s) waiting to be reviewed" and a **Clear the review queue** button, disabled when N is 0. Press it -> **Expected:** an amber warning naming N and stating what survives. **Yes, clear the queue** -> **Expected:** the notice reads "Queue cleared: N draft(s) removed, M inbox(es) will read them again", the **Review** badge is gone, and **Months** shows every transaction unchanged. **Sync now** -> **Expected:** the same N drafts return (a voucher whose date failed under the old parser now shows its date); nothing you confirmed reappears. Via Postman (**22 · Review queue -> Clear the review queue**) with `confirm: false` -> **Expected:** 409 `confirmation_required`.

QA-LED-08 — A refund carries its notes, and edits do not wipe them • Core (Web / API)

Gherkin

```
Given an unplanned essential expecting a 50% refund
When I open the month page and Edit the refund
Then I can set Refund notes (case number and all — there is no separate Case No. field or column
since 2026-09-14), and blank clears them (the transaction form asks for the same notes at entry —
QA-LED-05)
When I change the refund's amount in the transaction form
Then the refund's ■/$ change and the notes survive
When I untick "refund expected" on the transaction
Then the refund row is gone, and with it the notes
And PUT /api/refunds/{id}/details with 251-character notes is 400; an unknown id is 404
```

Walkthrough: create an **Unplanned** transaction with **refund expected** `50` -> month page -> **Expected refunds** -> **Expected:** a row with no note icon and no Case No. column. **Edit** -> **Refund notes** `CASE-2026-4471, lent to Diego` -> **Save** -> **Expected:** a note icon beside the payee whose hover text is the note (on a phone the % column hides and the payee's sub-line reads "50%"). **Edit the transaction** -> double the refund's amount -> **Save** -> month page -> **Expected:** the refund's amounts doubled, the note untouched. **Edit the refund** -> clear it -> **Save** -> **Expected:** no icon. **Edit the transaction** -> untick refund expected -> **Save** -> **Expected:** the refund row is gone. Via Postman (**17 · Refunds -> Set refund notes**) with 251-character `notes` -> **Expected:** 400 naming `notes`.

QA-LED-09 — Every refund across months: filter, group, and mark several received at once • Core (Web / API)

Gherkin

```
Given refunds in two months — one received, two pending
When I open Refunds (from a month's "See all refunds", or the dashboard's link under the forecast)
Then the pending ones are listed oldest purchase first, each with its month and "pending N days"
And the header reads Received · Pending · of expected for what is listed
When I pick All, type part of a payee, or set a From / To date
Then the list and the totals follow; Group by Payee / Status / Month shows one group each with its
received and pending
When I tick two pending refunds, set the received date and click "Mark them received"
Then each books its own inflow on that day, the list reloads, and a refund that could not be marked
is named
When I come back later
Then the page opens on the status and grouping I left it on
```

Walkthrough: with refunds in June (one **received**) and July (one **pending**) and a second pending one in June, open a month -> **Expected refunds** -> **See all refunds** -> **Expected:** the **Refunds** page on **Pending**: the two pending ones, June's first, each with its month (a link to that month) and "pending N days"; the header shows **Received** ■0.00 · **Pending** <their sum> · **of** <the same>. **All** -> **Expected:** the received one too, the totals now include it. Type part of a payee in **Payee** (any case) -> **Expected:** only matching rows. **From** the first of July -> **Expected:** only July's. Clear the filters, **Group by -> Payee** -> **Expected:** one header per payee (case ignored) with its received and pending; **Month** -> one per month, in order; **Status** -> Pending then Received. Tick both pending refunds -> **Expected:** a bar "2 selected" with a **Received on** date and **Mark them received**; set a date -> click -> **Expected:** "2 refund(s) marked received.", both now Received; each month page shows its inflow on that date. Repeat with a received date *before* one purchase -> **Expected:** "1 marked received; these stayed pending: <payee>." Reload the page -> **Expected:** it opens on the status and grouping you left. Postman **17 · Refunds -> List all refunds** with `status=maybe` -> **Expected:** 400 `invalid_request`; from a second household -> **Expected:** none of the first household's refunds. The dashboard shows **See all refunds** under the forecast only when refunds are expected.

10i. Web — Budget lines: fixed & variable (app slice EXPENSES-1) • Core

The budget baseline (ADR-V007/V008): two ordered lists of single-currency lines, each tied to a category that backs at most one active line across both lists; optional bank; reorder by drag or the handle's move menu. Never seeded — a fresh household starts empty.

Presented per SKIN-9 (2026-09-12). The page opens on a **commitment header**: "Planned every month ■…" (every active line, both lists, added at today's rate in the "Show in" currency — the header says "at today's rate"), "N% of a typical income" with the income figure at the right (a typical income = the four-week defaults under Settings -> Budget; when those are still zero there is no share, and without a rate each currency is summed on its own side, "■400,000.00 + $13.00"), and a two-tone Fixed / Variable bar. Each list is a card of GRID ROWS, not a table: a drag handle (■), the name, the amount in the line's OWN currency (never converted), the category, an "account" / "card" chip for the method (a plan names no bank), and **Edit**; the list total sits in the card header. An inactive line is struck through in muted ink with a small INACTIVE label, has no handle, and keeps Edit (which is how it comes back). One **+ Add a line** button in the page head opens a **dialog** (Fixed / Variable switch, then the same fields as before); Edit opens the same dialog prefilled, without the switch. On tablet the chip column hides; on phone the category goes too and both reappear as a sub-line under the name.

QA-EXP-01 — Create fixed and variable lines; the single-currency and category rules hold • Core (Web / API)

Gherkin

```
Given I am on Budget (nav) in a fresh household
Then both lists show "No lines yet" and the header reads "Planned every month ■0.00"
When I click + Add a line, keep Fixed, enter "Mortgage", 300000 CRC, category Housing, Bank account,
and Create
And "+ New" beside Category creates a category in place (it is then offered for either list)
Then the dialog closes and the row reads Mortgage · ■300,000.00 · Housing · "account", with a drag
handle — no bank anywhere on a line (a plan is pay by card / by account; the transaction records the
real bank)
And the header's planned total is ■300,000.00 and, if income lines exist, its share of a typical
four-week month of them
When I add a line, switch to Variable, enter "Netflix", 13 USD, category Entertainment, Credit card
Then it appears under Variable as $13.00 · Entertainment · "card", and the header adds it at today's
rate
When I add a fixed "Rent" with category Housing
Then the dialog shows "that category already backs another budget line" and nothing is created
```

Walkthrough: nav **Budget** -> **Expected:** the header "Planned every month ■0.00" and "No lines yet — add the first one." in both cards. **+ Add a line** -> **Expected:** a dialog with a **Fixed | Variable** switch (Fixed selected) and the fields; the name has focus. Name `Mortgage`, **Monthly budget** `300000` **CRC**, **Category** Housing (or **+ New** -> type a name -> **Create** -> **Expected:** selected in place), **Payment method** Bank account (there is no bank field) -> **Create** -> **Expected:** "Created.", the dialog gone, the row with its ■ handle, and the header now ■300,000.00 (with "N% of a typical income" and the income figure if Settings -> Budget has four-week defaults; "at today's rate" under the bar). **Edit** on the row -> **Expected:** the same dialog prefilled, no Fixed/Variable switch, an **Active** toggle; **Cancel** or Escape closes it. **+ Add a line** -> switch **Variable** -> `Netflix`, `13` **USD**, Entertainment, Credit card -> **Create** -> **Expected:** the row under Variable shows $13.00 (its own currency) and the chip "card"; the header total grew by 13 × today's rate and the bar gained a lighter Variable segment. **+ Add a line** -> `Rent`, `50000` CRC, category **Housing** -> **Create** -> **Expected:** the red message inside the dialog about the category already backing another line. Narrow the window below tablet width -> **Expected:** the category and chip leave their columns and sit under the name as "Housing · account"; the header stacks its number above the bar. Via Postman (**18 · Expenses -> Create fixed expense — invalid (400)**) -> `invalid_request` ("exactly one of budget_crc or budget_usd…").

QA-EXP-02 — Reorder by drag or the handle's move menu; inactive lines stay out of the order • Core (Web / API)

Gherkin

```
Given fixed lines Mortgage (1st), Water (2nd) and Gym (3rd)
When I drag Mortgage's handle and drop it on Water
Then Water is first and Mortgage second, immediately, and a reload keeps that order
When I click Gym's handle
Then a menu offers Move up, Move down (disabled: last line) and "Move to position" with 3 positions
When I choose Move up
Then Gym is second and the menu closes
When I choose "Move to position" 1 on Mortgage
Then Mortgage is first again
When I Edit Water, switch Active off, Save
Then Water is struck through with INACTIVE and no handle, and the other handles' menus offer only 2
positions
When the reorder save fails (API down)
Then the rows return to their previous order and "Couldn't save the order" shows
```

Walkthrough: add `Water` (`15000` CRC) and `Gym` (`25000` CRC), other categories. Drag ■ on Mortgage onto the Water row -> **Expected:** the rows swap at once (optimistic), no flash; **F5** -> order kept. Click ■ on Gym -> **Expected:** a small menu: **Move up**, **Move down** (disabled — it is last), **Move to position** with positions 1–3; Escape or a click outside closes it. **Move up** -> **Expected:** Gym second, menu gone. ■ on Mortgage -> **Move to position** `1` -> **Expected:** Mortgage first. The menu is the keyboard path (Tab to the handle, Enter, arrow to an item) and the only path on a phone, where drag does not exist. **Edit** Water -> **Active** off -> **Save** -> **Expected:** Water struck through, INACTIVE, no handle, still an **Edit** link; the other lines' menus now offer positions 1–2. Stop the API, move a line -> **Expected:** it springs back and "Couldn't save the order" shows above the list. Via Postman (**18 · Expenses -> Reorder fixed expenses**) with only one of two active ids -> **Expected:** 400 `invalid_request` ("must exactly match the active fixed expense lines").

QA-EXP-03 — Duplicate names per list; the inactive clash restores the line; foreign ids are 404 • Core (Web / API)

Gherkin

```
Given fixed "Mortgage" is active and fixed "Water" is inactive
When I add fixed "MORTGAGE" -> "A fixed expense named 'Mortgage' already exists", nothing created
When I add variable "Mortgage" -> created (names are unique per list)
When I add fixed "water" with 20000 CRC -> the yellow warning with Reactivate; clicking it makes
"Water" Active at ■20,000.00
And a PUT to a line id from another household returns 404
```

Walkthrough: + Add a line (Fixed) `MORTGAGE` -> **Expected:** the red message in the dialog, no row. **+ Add a line** -> **Variable** -> `Mortgage` (any free category) -> **Expected:** created. **+ Add a line** (Fixed) `water`, `20000` -> **Create** -> **Expected:** the amber "…already exists but is inactive — reactivate it?" inside the dialog with **Reactivate** -> click -> **Expected:** "Updated.", the dialog gone, **Water** (stored spelling) back in the list at ■20,000.00 with its handle. Via Postman (**18 · Expenses -> Update fixed expense**) with an id copied from a *different* household -> **Expected:** 404 (never 403 — no existence oracle).

10j. Web — Dashboard (app slice DASH-1) • Core

> The month at a glance (ADR-V004/V006/V007): every figure a ■/$ pair. Actuals sum each transaction's frozen amounts; projections (income conversion, budget display, pending budgeted, remainder for debts) use the rate resolved through the chain. No rate -> projections are blocked, never guessed.
>
> **Presented per SKIN-5 (2026-09-11):** one verdict, the pace, four steps, the line lists, one breakdown panel. The ARITHMETIC is unchanged — the same figures in the same order as the eleven-row waterfall this replaced — so what moved is where each number is read, not what it is.

QA-DASH-01 — The dashboard reflects income, lines vs actuals, and the unbudgeted spend • Core (Web / API)

Gherkin

```
Given a household with fixed line Mortgage ■350,000 (Housing, BAC, Bank account) and no other lines
And June transactions: Mortgage ■300,000 bank account on Jun 5, and a ■10,000 Unplanned lunch on Jun
12 in category Dining
When I open Dashboard (nav)
Then the newest month loads with "4 weeks · 28/5/2026 – 24/6/2026" and the rate line
And Fixed lines shows Mortgage as a progress row — planned ■350,000.00 · $700.00 with a signed delta
of −■50,000.00 in green — and the heading reads "■50,000.00 under"
And Where it went opens on By week with the mortgage in week 2; its Unbudgeted tab lists Dining
■10,000.00
When I Edit Mortgage's budget down to ■250,000 and reload the dashboard
Then Mortgage's row is marked over (red bar and a +■50,000.00 delta) and Still planned drops to
■0.00
And each Where-it-went table ends with a Total row (the sum of the rows shown), and each line list's
heading carries its own over/under figure
And a line budgeted in dollars is judged in dollars: a $2.99 line paid at $2.99 is green even when
its colón projection sits a few colones under the frozen colón actual (the totals turn red only when
over on both sides)
When I set "Show in" (top right) to $
Then every pair on the page reads in dollars only — except each budget line's Budgeted cell, which
stays in the currency the line is set in
```

Walkthrough: Budget -> add fixed `Mortgage` `350000` CRC, Housing, BAC, Bank account. **New transaction** -> `Bank`, `300000` CRC, Housing, BAC, Bank account, `2026-06-05`, Budgeted -> **Save**. **New transaction** -> `Soda`, `10000` CRC, Dining, BAC, Credit card, `2026-06-12`, Unplanned -> **Save**. Nav **Dashboard** -> **Expected:** June 2026, the head reading "4 weeks · 28/5/2026 – 24/6/2026 · day N of 28" with the rate badge beside it; **Fixed lines** with Mortgage's delta in **green** and "■50,000.00 under" on the heading; **Where it went** on **By week**, 4 rows, week 2 = ■300,000.00 budgeted; its **Unbudgeted** tab listing Dining. **Budget** -> **Edit** Mortgage -> `250000` -> **Save** -> **Dashboard** -> **Expected:** Mortgage's delta now **red** at +■50,000.00; **Still planned** ■0.00. Via Postman (**19 · Dashboard -> Month summary**) -> 200 with `exchange_rate`, `rate_source`, `summary.fixed_expenses[0].actual.crc = 300000`.

QA-DASH-02 — Month selector, entry points, empty state, and the blocked projections when no rate resolves • Core (Web / API)

Gherkin

```
Given months June and July 2026 exist
When I open /dashboard -> July (newest) loads; I pick June in the selector -> the URL becomes
/dashboard/{june id} and June loads
When I click Month details -> /months/{id}; on the month page, Dashboard -> back to /dashboard/{id}
Given a brand-new household with no transactions
When I open Dashboard -> "Nothing to show yet" with New transaction
Given the provider key is unset and the household has no transaction yet (no rate resolves)
When I GET /api/months/{id}/summary for a month created by another path -> rate_unavailable true,
summary null
```

Walkthrough: add a July transaction (`2026-07-10`). **Dashboard** -> **Expected:** July 2026 first; the selector lists both months; pick **June 2026** -> **Expected:** the URL ends in June's id and the June figures show. **Month details** -> **Expected:** `/months/{id}` (June). **Dashboard** button there -> **Expected:** back on June's dashboard. Sign in as a fresh household (or wipe) -> **Dashboard** -> **Expected:** "Nothing to show yet" + **New transaction**. Rate-unavailable: with `ExchangeRate__ApiKey` empty, stop the API, restart it (empty cache), and in a household whose only transaction was just deleted there is nothing to resolve — via Postman (**13 · Exchange rate -> Current rate**) -> 503; the dashboard page for a remaining month shows the red "No exchange rate could be resolved…" block and no figures — no verdict, no pace bar, no four-step row — while the month title and buttons stay. Postman (**19 · Dashboard -> Month summary**) with an unknown id -> 404.

10k. Web — Reports: category analysis & CSV export (app slice REPORTS-1/2) • Core

Read-only reporting over the frozen transaction amounts (ADR-V004/V006). One period rule for both: a month (its anchor window, ending on the last week's end date) or a `from`–`to` range. The CSV is delivered through the platform's signed-link download (ADR-010), so it works on web and native alike.

Presented per SKIN-10 (2026-09-12). The page opens on its verdict: **four KPI tiles** — Total spend ("N% of income" when the month has an income), Budgeted and Discretionary ("N% of spend"), Unplanned ("■… refundable" from the month's expected refunds, or its share for a range) — and, for a month, the **Pace against the plan** chart full width with "N% of the month elapsed · M% of the plan spent" as text beside its title. Below them a **Table | Chart** switch governs only the detail. **Table** is ONE "By category" card behind a **Budgeted | Discretionary | Unplanned** switcher (rows already loaded, no request): Category, an inline **Spent vs budget** bar (only where there is a budget: the budgeted class of a month; red past the plan; hidden on a phone), the # count, Budget and Spent (red when over, judged in the line's own currency), with a Total row. **Chart** holds the eight charts as before — class bars, the class / income / budget donuts, month by month, by bank, by card, card vs account — restyled; the pace chart is no longer among them because it is always above. The period picker and Export CSV sit in the page head; month and date range stay mutually exclusive.

QA-DASH-03 — "Show in" follows the account, and a first choice on a device follows you • Core (Web / API)

Gherkin

```
Given I chose $ on the dashboard in this browser
When I open the app in another browser (or the phone) with the same account
Then the dashboard and Reports open in $ without touching the switch
When I set it to Both there
Then this browser shows Both on its next load
And GET /api/display-settings returns { display_currency: "both", is_default: false }
When I pick ■ on a month page, the Months list or the Budget page instead
Then that page switches at once, and the dashboard opens in ■ too
```

Walkthrough: on the **Dashboard**, set **Show in** to **$**. Via Postman (**23 · Display settings -> Get display settings**) -> **Expected:** 200 with `display_currency` = `USD`, `is_default` = `false`. Open the app in a private window (same

account, sign in) -> **Expected:** the dashboard opens in $ and **Reports** (table view) too. Set **Both** there; reload the first window -> **Expected:** Both. Postman **Update display settings — invalid (400)** -> **Expected:** 400 `invalid_request`; **Reset display settings to both** -> 200. (The impersonation refusal and the account-erasure wipe are covered by `Api.Tests`.) **The switch where you are (#207):** open a month -> **Show in** sits in its header -> pick ■ -> **Expected:** the ledger, the refunds, their totals and the **Other income** line switch at once (income rows keep their own currency). Open **Dashboard** -> **Expected:** ■ there too. Same on **Months** (each card's figures) and **Budget** (the commitment header converts at today's rate; every line keeps its own currency).

QA-DASH-04 — One verdict, the pace, and the four-step month • Core (Web)

Gherkin

```
Given the month above (income configured, ■310,000 spent against a ■350,000 plan)
When I open Dashboard
Then the page opens on ONE verdict: a state in words with a coloured dot, the caption "Forecast left
at month end", the forecast at display size, and one sentence explaining it
And the state is derived, never stored: forecast above zero and spend at or under the elapsed share
reads On track; forecast above zero but spend ahead of it reads Watch; a forecast at or below zero
reads Over
And beside it the pace bar — thicker than the month-card bars, this is the screen's verdict — draws
Budgeted, Discretionary, Unplanned, a hatched Still planned and the green Forecast, with a capped
Today tick standing taller than the bar at the elapsed share, over a summary reading "N% committed ·
N% of the month gone"
And every legend entry carries its AMOUNT beside its whole-percent share, in the currency "Show in"
is set to
And below them four steps read Income -> − Spent so far -> − Still planned -> = Forecast at month
end, the operator belonging to the row rather than the label
And Other income (inflows) is named on the Income step when an inflow exists; expected refunds are
named WITH THEIR AMOUNT on the Forecast step ("Expected refunds: ■… — not counted until they land as
income"), because they are NOT counted in it
When the plan does not fit the income
Then the verdict reads Over in red, the Forecast step is red, and the warning line appears beneath
the steps
When I set "Show in" to $
Then the forecast, the steps and the pace legend all read in dollars; in "Both" the dollars sit UNDER
the colones rather than after a middot, and the legend keeps its amounts inline
```

Walkthrough: Dashboard -> **Expected:** the verdict card first (**ON TRACK** with a green dot for a month spending under its elapsed share), then **THIS MONTH** with the bar and "N% committed · N% of the month gone", then the four steps on one row. Read the bar's legend -> **Expected:** each class named with its **money** and a whole-percent share — not a percentage alone. Add a budget line big enough to exceed the income -> reload -> **Expected:** the verdict flips to **Over** in red, the **Forecast at month end** step red, and the warning line under the steps. Enter an **Income (inflow)** transaction -> **Expected: Other income** named under the Income step and the income total grown by it. Switch **Show in** to ■, then **$**, then **Both** -> **Expected:** every figure follows, and in **Both** no money cell is doubled on one line.

QA-DASH-05 — Where it went: one panel, four cuts, and the envelope strip • Core (Web)

Gherkin

```
Given the month above, with at least one transaction naming a card and one category with no budget
line
When I open Dashboard
Then ONE "Where it went" panel replaces the separate week, bank and card cards, with a segmented
switch reading By week | By bank | By card | Unbudgeted
And the switch is a real radio group: it is reachable by keyboard and announces its position
And By week opens first, with Budgeted, Discretionary and Unplanned columns per week (#211) and a
Total column adding the three (on a phone, under the week's dates); each cut ends in a Total row, and
switching between them refetches nothing
And By bank opens on a two-row "Planned vs spent, by payment method" summary — Card and Bank account,
budgeted against actual, red when over — above a table of actual spend per bank and method with its
Total; there is no budgeted column per bank, because a budget line names no bank
And Unbudgeted lists the categories with spend and no budget line — the old "Other spending" card —
grouped by class with a subtotal per group: Discretionary, then Unplanned, then "Marked budgeted, no
line" only when a purchase classed Budgeted sits in a category no line covers; a category whose money
came in two classes appears once per group with that group's share
And By card lists each card's alias with its kind and transaction count beneath, its spend, and its
share of the month — "No card" last
Given an envelope is due this month by its cadence
Then a thin envelope strip sits between the four steps and the line lists, one row per due bucket
When no envelope is due
Then that strip is absent entirely, and the page is one section shorter
```

Walkthrough: Dashboard -> scroll to **Where it went** -> **Expected:** one panel, the switch on **By week**, its columns **Budgeted**, **Discretionary** and **Unplanned** — the unplanned lunch's ■10,000.00 in its week's Unplanned cell and in the Unplanned total; the **Total** column adds a week's three cells, and its bottom cell is the month's whole spend. Tab to the switch and use the arrow keys -> **Expected:** it moves between the four options like a radio group. Click through **By bank**, **By card**, **Unbudgeted** -> **Expected:** each renders its own table with a **Total**, nothing scrolls sideways, and no money pair breaks across two lines (check in **Both**, the widest). **By bank:** first a two-row summary, **Credit card** and **Bank account**, each planned against spent (spent turns red when over); under it the banks — BAC · Bank account · ■300,000.00 for the mortgage, the lunch's bank · Credit card · ■10,000.00 — and a **Total** of the actuals only. **By card:** the card's alias with "Credit · N transaction(s)" under it and a share adding to 100%. **Unbudgeted:** the categories with no budget line, grouped under **Discretionary** / **Unplanned** / **Marked budgeted, no line** headings, each heading carrying its subtotal — the unplanned lunch sits under **Unplanned**; a category with both a discretionary and a budgeted purchase appears under both, with each share, and the Total at the bottom still equals the sum of the headings. Envelopes: with a bucket due this month -> **Expected:** the strip above the line lists naming it, with contributed and remaining. Deactivate it (or pick a month where its cadence does not apply) -> reload -> **Expected:** no strip at all.

QA-REP-01 — Category analysis by month shows budgets; a date range doesn't • Core (Web / API)

Gherkin

```
Given June 2026 has Groceries budgeted ■60,000 (a fixed line) and transactions: Groceries budgeted
■8,000 total, Dining Discretionary ■2,000, an Income (inflow) ■9,000
When I open Reports (nav)
Then the newest month loads with "one budget month — budgets shown next to actuals"
And four tiles read Total spend ■10,000.00 with "N% of income", Budgeted ■8,000.00 "80% of spend",
Discretionary ■2,000.00 "20% of spend", Unplanned ■0.00
And the Pace against the plan chart sits full width under them, with "N% of the month elapsed · M% of
the plan spent" beside its title
And By category opens on Budgeted: Groceries — a Spent vs budget bar a fifth full — # 2 — Budgeted
(month) ■60,000.00 — Actual ■8,000.00 in green, with a Total row (the # column counts the
transactions behind each row and its total adds them up)
When I switch the class to Discretionary
Then Dining ■2,000.00 shows under a "Spent" column with no bar and no budget beside it (so no
"Actual"), without a request; Unplanned shows "Nothing in this class for the period."; the inflow
appears nowhere
When I switch Period to "Date range", set 2026-01-01 – 2026-06-30 and Load
Then the note says "custom range — monthly budgets don't apply" and the Budgeted (month) column is
gone
When I set From 2026-06-30 and To 2026-06-01 and Load
Then "From must not be after To" and nothing loads
And a line budgeted in dollars is judged in dollars: $18.99 spent against $18.99 is green, $25 is red
(never red just because its colón side is above ■0)
When I set "Show in" to $
Then every actual reads in dollars only, each budget line still shows in the currency it is set in,
and the Budgeted total is one figure at today's rate (colón lines at buy, dollar lines at sell)
And "Both" brings the ■ · $ pairs back; the choice is remembered on this device and shared with the
dashboard
```

Walkthrough: Budget -> fixed `Supermarket 60000` CRC on Groceries. **New transaction** ×3 -> Groceries Budgeted `5000` (`2026-06-05`) and `3000` (`2026-06-12`), Dining Discretionary `2000` (`2026-06-10`), plus an **Income (inflow)** `9000`. Nav **Reports** -> **Expected:** the month selector (top right) on the newest month; the four tiles; the pace chart with its summary line; **By category** on **Budgeted** with the bar, the budget column and the green actual. Switch the class to **Discretionary** -> **Expected:** Dining, no bar, no budget column; **Unplanned** -> "Nothing in this class…"; the inflow absent everywhere. **Period** -> **Date range** -> From `2026-01-01`, To `2026-06-30` -> **Load** -> **Expected:** the multi-month note, the tiles still adding the period up (Total spend without a share), no pace chart, no budget column and no bars, same totals. Reverse the dates -> **Load** -> **Expected:** the red order message. Via Postman (**20 · Reports -> Category analysis (month)**) -> 200 with `single_month: true`, `budgeted[0].budgeted_crc = 60000`, an `income {crc, usd}` pair, `budget_total.crc = 60000`; (**date range**) -> `income: null`, `budget_total: null`, `spend_by_day: null`; (**Category analysis — no period (400)**) -> `period_required`.

QA-REP-02 — Export CSV downloads the shown period; the file has the fixed columns and 4-decimal rate • Core (Web / API)

Gherkin

```
Given Reports shows June 2026 (three spending rows + one inflow)
When I click Export CSV
Then "CSV ready — 4 rows. Your download has started." and transactions-<today>.csv lands in Downloads
And the file's first line is
date,payee,category,class,amount_crc,amount_usd,exchange_rate_used,payment_method,bank,source,card
And rows are newest first, amounts read like 5000.00 and 10.00, exchange_rate_used like 500.0000, no
currency symbols
When I open a month page and click Export CSV
Then the same file downloads for that month
When I POST the export with month_id of another household
Then 404
```

Walkthrough: Reports -> **Export CSV** -> **Expected:** the green notice with the row count and the browser download (on Android: the OS share sheet; on Windows: a Save As dialog, #204). Open the file -> **Expected:** the header line exactly as above; one line per transaction incl. the inflow (the export is the whole period, not just spending); `exchange_rate_used` with four decimals; payees containing commas/quotes are quoted. **Months** -> June -> **Export CSV** -> **Expected:** the same download and the notice under the header. Via Postman (**20 · Reports -> Export transactions (CSV link)**) -> 200 with `download_url` (relative `/api/files/{token}` on local storage), `file_name`, `row_count`; open the URL **without** a token -> the CSV downloads (`Content-Disposition: attachment`); wait 15

minutes -> 404 (link expired). Postman with a foreign `month_id` -> 404.

QA-REP-03 — Chart view: the class bars and the three donuts • Core (Web)

Gherkin

```
Given the June data above, in month mode
When I switch the View to Chart (the Table | Chart switch under the pace chart)
Then the tiles and the pace chart stay where they are, the By category card is replaced by the
charts, and each class shows the same rows as horizontal bars (largest first) with the budget as a
muted track and the actual on top — red past it — plus a "Spend by class" donut with shares
And an "Income vs spend" donut: the same class slices plus a muted Remaining slice, the month's
income in the hole (income = configured incomes at today's rate + inflows, as on the dashboard);
overspent -> no Remaining and a red "Over income by ■…"
And an "Income vs budget" donut: Budget lines (every active line, a $ line converted at today's rate)
and Uncommitted, the income in the hole; a plan above the income -> no Uncommitted and a red "Budget
exceeds income by ■…"
When I switch the chart currency to $
Then every chart redraws in the other currency, and the choice is remembered on this device
When I switch Period to Date range
Then the income and budget donuts are gone (both are per month) while the class bars stay
```

Walkthrough: Reports -> **View -> Chart** -> **Expected:** tiles and pace unchanged above; below, "Income vs spend" beside "Spend by class", Remaining = the month's income – ■10,000 spent, the income in the hole (the inflow counts as income here, never as spend); "Income vs budget" with Budget lines ■60,000 and Uncommitted = income – ■60,000. Flip the ■/$ switch -> **Expected:** every figure redraws; reload the page -> the choice stuck. **Date range** -> **Expected:** both income cards gone, the class bars unchanged.

QA-REP-04 — Pace against the plan, month by month, and where the money left from • Core (Web)

Gherkin

```
Given the June data above, in month mode, with at least one transaction naming a card
When I look at the Pace against the plan card (always visible under the tiles, in Table or Chart
view)
Then a line steps through the days that had spend, against a dashed plan line to the budget total,
with a dashed Today marker, and "N% of the month elapsed · M% of the plan spent" as text beside the
title
And on a phone the chart keeps its width, loses height and the Today marker — the summary line still
says the elapsed share
When I switch the View to Chart
Then "Month by month" shows one bar per month, oldest first, spend on an income track, red for a
month that spent more than its income
And "Spend by bank" and "Spend by card" sit side by side as two donuts — same shape, same question —
with "No card" last in the card one
And "Card vs account" sits below them across the full width: its donut on the left, and on the right
"Budgeted vs spent, by payment method" with one bar pair per method and a caption naming both figures
When I switch Period to Date range
Then pace and month-by-month are gone, the two donuts stay, and the budget-by-method bars go (budgets
are per month)
```

Walkthrough: Reports (month mode) -> **Expected:** the **Pace against the plan** card under the tiles with three points (Jun 5, 10, 12), the plan line to ■60,000 and Today at the right edge — "100% … · 17% of the plan spent" beside the title; narrow the window below tablet width -> the chart is shorter and the Today marker gone. **View -> Chart** -> **Expected: Month by month** with one bar (June) on its income track. Scroll on -> **Expected: Spend by bank** and **Spend by card** on one row, both donuts; below them **Card vs account** full width with the bars using the space, captioned "budgeted ■… · spent ■…" per method. Switch to **Date range** -> **Expected:** pace and trend gone, the two donuts still there, the method bars gone. Via Postman (**20 · Reports -> Category analysis (month)**) -> `by_bank`, `by_method` and `by_card` arrays (the card one keyed `"none"` for the no-card bucket) and `spend_by_day` with three dates.

QA-REP-05 — Download the report as a PDF: same figures, same charts, the transactions appended Automated in CI • Core (Web / API)

Gherkin

```
Given the June data above, in month mode, with "Show in" on both sides and the chart currency on ■
When I press PDF beside Export CSV
Then a dialog offers "Include the transactions" (ticked) and says the amounts, charts and language it
will use
When I press Download
Then a file "report-<first day>_<last day>.pdf" downloads (Android: the share sheet opens; Windows: a
Save As dialog) and the page shows "PDF ready"
And the PDF opens with the household, "June 2026", the period, the generated time and the buy/sell
rate used
And it has the four tiles with the same figures as the screen, the pace chart, the donuts, month by
month, the method bars and the three category tables with the same budgets and red/green
And its last pages are landscape and list every row the CSV export lists for June, in the same order,
with readable class, method and source labels
When I untick "Include the transactions" and download again
Then the PDF has no transaction pages
When I set "Show in" to $ and download
Then every amount in the tiles, tables and appendix is in dollars and the charts are drawn in dollars
When I switch the app to Spanish and download
Then the PDF is in Spanish ("Informe de gastos", "■5.000,00")
When I switch Period to Date range and download
Then there is no pace, no income or budget card and no month by month, and the tables show spend only
```

Walkthrough: Reports (month mode) -> press **PDF** -> **Expected:** the dialog with the transactions box ticked and three lines: amounts "■ and $", charts "■", language "English". Press **Download** -> **Expected:** a file `report-2026-05-28_2026-06-24.pdf` (on Android the share sheet, on Windows a Save As dialog) and "PDF ready" on the page. Open it -> **Expected:** the ¿Y el vuelto? lockup and the household on every page; page 1 with "Spending report", "June 2026", the period and "Exchange rate: buy … · sell … per $1"; the four tiles matching the screen (a pair prints ■ on one line and $ under it); the pace card; then the donuts two to a row, then **Month by month** and **Budgeted vs spent, by payment method**; then **By category** with the Budgeted table (budget column, red over / green under), Discretionary and Unplanned; then landscape **Transactions** pages with every CSV column. Compare its rows with **Export CSV** for the same month -> **Expected:** the same rows in the same order. Untick the box -> no Transactions pages. Set **Show in** to **$** -> dollars only everywhere. Switch the app to **Español** -> the PDF is in Spanish. **Date range** -> no pace, income, budget or month-by-month pieces. A payee with an emoji still renders (the emoji prints as a box). Stop the exchange-rate provider (or test when none is cached) -> the PDF says the rate is unavailable and leaves out income, budget and the plan line. Via Postman (**20 · Reports -> Report as PDF (link)**) -> 200 with `download_url` / `file_name` / `period` / `expires_in_seconds` 900; `display: "EUR"` -> 400 `invalid_request`; both `month_id` and `from`/`to` -> 400 `period_ambiguous`; another household's month -> 404; opening `download_url` without a token downloads the PDF.

QA-REP-06 — Email me this report: the same PDF, attached, to my own inbox, in my saved language Automated in CI • Core (Web / API)

Gherkin

```
Given I am signed in with Spanish saved in Settings -> Preferences, on Reports for June
When I press PDF and then "Enviármelo"
Then the dialog closes and the page says "Enviado a <my address>, con el PDF adjunto."
And my inbox (Mailpit locally) receives one email in Spanish, "Tu informe de gastos: Junio 2026",
naming the period, the household and the total spend
And it carries report-<first day>_<last day>.pdf — the same file Download gives, in Spanish
When I switch my saved language to English and press "Email me" again
Then the email and its PDF are in English
When I press "Email me" an eleventh time in the same day
Then the dialog stays open and says today's maximum was reached, and no email is sent
```

Walkthrough: Settings -> Preferences -> Español. **Reports** (June) -> **PDF** -> **Enviármelo** -> **Expected:** the dialog closes and the page says "Enviado a …, con el PDF adjunto." Open Mailpit (`http://localhost:8026`) or the inbox -> **Expected:** one email "Tu informe de gastos: Junio 2026", the brand header, a sentence with the period, the household and the total spend, and the PDF attached; open it -> **Expected:** the same report as **Descargar** gives. Switch to English and send again -> **Expected:** English subject, body and PDF. Keep pressing **Email me** -> **Expected:** from the eleventh send of the day the dialog shows the daily-limit message and nothing more arrives. Via Postman (**20 · Reports -> Email the report to me (PDF attached)**) -> 202 `{ sent_to, file_name, period }`; a month of another household -> 404 and no email; `display: "EUR"` -> 400 `invalid_request` and no email; **Report as PDF**

(link) without `language` follows the saved language, with `"language": "en"` it is English.

QA-REP-07 — Choose the transaction columns the PDF prints Automated in CI • Edge (Web / API)

Gherkin

```
Given I am on Reports for June with transactions
When I press PDF
Then under "Include the transactions" nine columns are listed, all ticked, with "Date and payee
always print"
When I untick Exchange rate, Source, Card and Class and press Download
Then the appendix prints Date, Payee, Category, the amounts, Payment method, Bank and Notes, in that
order
When I open the dialog again
Then every column is ticked again
When I untick "Include the transactions"
Then the column list disappears and the PDF has no appendix
```

Walkthrough: Reports (June) -> **PDF** -> **Expected:** the **Columns** list under the transactions checkbox, nine boxes ticked. Untick **Exchange rate**, **Source**, **Card**, **Class** -> **Download** -> open the file -> **Expected:** the landscape "Transactions" page with only the listed columns, in order, still readable. **PDF** again -> **Expected:** all nine ticked. **Email me** with a lean choice -> the attachment matches. Untick **Include the transactions** -> **Expected:** the list hides. Via Postman (**20 · Reports -> Report as PDF (link)**) with `"appendix_columns": ["notes", "amount"]` -> 200, the appendix prints Date, Payee, the amounts, Notes; `["tip"]` -> 400 `invalid_request` naming it.

10l. Web — Email inboxes: connect, filters & readers (app slice EMAIL-2/3) • Core

> Your inbox, not the household's (ADR-V002): read-only consent on the account you're signed in with, tokens protected by the platform key ring (ADR-V016), one inbox per provider. Live consent needs the platform's Microsoft/Google OAuth apps configured (`Authentication:*`) with the API callback `https://<api>/api/email/connections/callback` registered as a redirect URI.

QA-EMAIL-01 — The Email settings page without credentials: honest errors, no dead ends • Core (Web / API)

Gherkin

```
Given Authentication:Google:ClientId is empty on the API
When I open Settings -> Manage inboxes
Then I see "No inbox connected yet." and the two Connect buttons
When I click Connect Gmail
Then "Gmail mail consent isn't configured on this server yet." and I stay on the page
When I POST /api/email/connections with tokens (Postman)
Then 400 use_consent_flow
```

Walkthrough: Settings -> **Manage inboxes** (`/email`) -> **Expected:** the empty message, **Connect Outlook** / **Connect Gmail**. Click **Connect Gmail** with no Google credentials -> **Expected:** the red "isn't configured" message. Via Postman (**21 · Email inboxes -> Create connection (refused, 400)**) -> `use_consent_flow`; (**Authorize (unknown provider, 400)**) -> `invalid_provider`; (**Suggested filters**) -> the BAC/BN senders and subjects with the two bank presets.

QA-EMAIL-02 — Live consent round-trip (IdP boundary) and the pre-seeded connection • Core (Web)

Gherkin

```
Given the API has Authentication:Microsoft (or Google) credentials and the callback URL is a
registered redirect URI
When I click Connect Outlook and approve read-only access on my signed-in account
Then I land on /email?connected=microsoft with "Outlook connected…"
And the inbox shows Outlook — my address · Active · Last checked: <now> · every 15 min
And Edit shows sender notificacion@notificacionesbaccr.com, bncontacto@bncr.fi.cr and the three
subject prefixes pre-filled, Unread only on
And the Connect Outlook button is greyed out (one inbox per provider); re-running the consent URL by
hand -> /email?email_error=already_connected
```

Walkthrough: Connect Outlook -> the Microsoft consent page (scopes: read your mail, offline access, your email) -> **Accept** -> **Expected:** back on `/email` with the green notice and the row. **Edit** -> **Expected:** the pre-filled senders/subjects, **Unread only** on, interval `15`, **Import mail from** today. **Expected:** the **Connect Outlook** button is now **disabled** (Connect Gmail stays live); the row's **Reconnect** is the only way back through consent. Paste the consent URL from before into the address bar and approve again -> **Expected:** "That provider is already connected." (the API guard behind the greyed button). Cancel the consent page instead -> **Expected:** `/email?email_error=consent_failed` and "Couldn't connect the inbox."

QA-EMAIL-03 — Edit with real folders, backfill rule, disconnect, and nothing leaks across users • Core (Web / API)

Gherkin

```
Given a connected Outlook inbox
And the row reads Folders: Inbox (default)
When I Edit -> Load folders
Then my real folders appear as checkboxes, subfolders as Inbox/Vouchers, and the Load folders link
hides
When I tick Inbox/Vouchers and click Apply
Then the list closes and the chips read Inbox, Inbox/Vouchers (Cancel instead would drop the tick)
When I set interval 60, turn on "Fetch all unread (ignore date)", Save
Then "Saved.", the row reads every 60 min and Folders: Inbox, Inbox/Vouchers; a reload keeps both
When I set Import mail from to 7 days ago and Save -> GET the connection: last_polled_at moved back 7
days
When I set it to 3 days ago and Save -> last_polled_at is still 7 days ago
When I set interval 4 -> "Polling interval must be between 5 and 1440 minutes."; clear both filters
-> "Provide at least one sender or subject filter."
When another user GETs/PUTs/DELETEs my connection id -> 404
When I Disconnect -> confirm -> the inbox is gone; the API list is empty
```

Walkthrough: the collapsed row reads **Folders: Inbox (default)**. **Edit** -> **Load folders** -> **Expected:** the checkbox list (Graph: nested names with `/`) with **Apply** / **Cancel** under it, the chips above it unchanged. Tick a subfolder -> **Cancel** -> **Expected:** list closed, chips unchanged. **Load folders** -> tick it -> **Apply** -> **Expected:** list closed, chips `Inbox`, `Inbox/Vouchers`. Interval `60`, **Fetch all unread** on -> **Save** -> **Expected:** "Saved.", "every 60 min", the row's **Folders:** line names both; **F5** keeps them. Via Postman (**21 · Email inboxes -> Get connection**) after each import-from save -> **Expected:** `last_polled_at` follows a lower date and ignores a higher one; **the day you picked reads back as the same day** after Save/F5 and is the first day whose mail arrives (Postman shows it as that day's midnight in your zone, e.g. …`T00:00:00-06:00`). Interval `4` -> **Save** -> **Expected:** the interval message; blank both filter boxes -> **Save** -> **Expected:** the filters message. Second account (**Update connection** with the first user's id) -> 404. **Disconnect** -> **Yes, disconnect** -> **Expected:** "Inbox disconnected…", empty list.

10m. Web — Email ingestion: staging & dedup (app slice EMAIL-4) • Core

> Voucher emails become inert review drafts in the owner's current household (ADR-V010) — nothing in the budget until confirmed (EMAIL-6). Needs a live-connected inbox (QA-EMAIL-02) with at least one real BAC/BN voucher email that matches the filters.

QA-EMAIL-04 — Sync now stages drafts once, dedups re-fetches, and a dead inbox says so • Core (Web / API)

Gherkin

```
Given a connected inbox with two unread BAC voucher emails received after "Import mail from"
When I click Sync now
Then "Sync done — 2 staged for review, 0 already seen, K not a voucher." and Last checked updates to
now
When I click Sync now again
Then "0 staged for review, 2 already seen" — the same emails never stage twice
When the inbox needs reconnecting (token revoked at the provider)
Then Sync now shows "Reconnect this inbox to sync it." and the row turns Needs reconnect
When I click "Sync inboxes" on the Review queue instead
Then every inbox is synced in one go: "Synced N inbox(es) — S new to review, D already seen, U not a
voucher.", the queue refreshes, and a dead inbox is reported in the same notice without stopping the
others
```

Walkthrough: Settings -> Manage inboxes -> **Sync now** -> **Expected:** the green summary with the counts; the emails stay **unread** in the mailbox. **Sync now** again -> **Expected:** the same count now under "already seen". Via Postman (**21 · Email inboxes -> Sync now**) -> 200 `{ staged, duplicates, unrecognized }`; (**Get connection**) -> `last_polled_at` moved to the sync time. Revoke the app's access in the provider's account settings -> **Sync now** -> **Expected:** the reconnect message, badge **Needs reconnect**, Postman -> 409 `needs_reconsent`. The drafts become visible in EMAIL-6's Review queue; until then confirm via SQL that `PendingVouchers` holds the rows with `status = pending`. **Review -> Sync inboxes** -> **Expected:** one notice with the summed counts across all inboxes (green; red with "N inbox(es) need reconnecting" when one is dead — the rest still synced), the queue and the header badge refreshed. Postman (**21 · Email inboxes -> Sync all inboxes**) -> 200 `{ synced_inboxes, needs_reconsent, staged, duplicates, unrecognized }`; with no inboxes -> all zeros.

10n. Web — Email ingestion: suggestions & review queue (app slice EMAIL-5/6) • Core

> **The queue is presented per SKIN-6 (2026-09-12):** each staged email is a two-pane row — the draft, and beside it a plain-language statement of what confirming will do, with the actions under it. Confirm blocks VISIBLY while a required field is empty, naming which, instead of failing on submit. Amber on this screen means one thing only: the bank email arrived incomplete. Nothing books until confirmed, discard is still a soft delete of the DRAFT and never the source email, and remembering a merchant is still opt-in per draft.

> The staged drafts (QA-EMAIL-04) become transactions only here. Merchant rules prefill the queue; the user always confirms. Can be run without a live inbox by staging a draft row directly (see the note in QA-EMAIL-06) — the confirm path is identical.

QA-EMAIL-05 — Merchant rules suggest, never apply, and are unique per household • Core (Web / API)

Gherkin

```
Given Settings -> Manage suggestions
When I add "AUTOMERCADO" -> Groceries and "Taco Bell" -> Dining / Extraordinary
Then both list with their category; adding "automercado" again says "A rule for this merchant already
exists."
When a voucher from "TACO BELL PLAZA REAL C" is staged
Then the Review queue shows it with Dining / Extraordinary prefilled and a "Suggested" badge — but it
is NOT a transaction until I confirm
```

Walkthrough: Settings -> Manage suggestions -> add the two rules -> **Expected:** the table shows pattern, category, class. Add `automercado` (lower-case) -> **Expected:** the red notice, no new row. Edit "Taco Bell" -> class Budgeted -> save -> the row follows; delete it (two-step) -> gone. Via Postman (**22 · Review queue & merchant suggestions -> Create merchant rule** twice) -> 201 then 409 `mapping_exists`; **List merchant rules** -> `category_name` filled. Stage a matching voucher (Sync now with a real email, or the SQL row from QA-EMAIL-06 with `merchant = 'TACO BELL PLAZA REAL C'`) -> **Review** -> **Expected:** the category select already shows the mapped category, the "Suggested" badge is on, and **Months** shows no new transaction yet.

QA-CAT-08 — A half-hidden card number is asked about once and remembered • Core (Web / API)

Gherkin

```
Given a card "Black" (VISA ····7558) and a BN payment receipt in the queue printing XXXXXXXXXXX8755X
When I open Review
Then the voucher shows XXXXXXXXXXX8755X (not ····8755) and a "Which card was it?" picker listing my
cards and "No card"
And Confirm without answering says to choose the card first, and nothing is booked
When I pick Black and Confirm
Then the payment is on Black in the month, and Settings -> Manage cards has no CARD-8755
When the next BN payment with the same number arrives
Then its picker comes preselected with Black, saying it was my answer last time
When I pick "No card" instead and Confirm
Then that payment carries no card
```

Walkthrough: stage a BN payment receipt (a real one, or the `bn-payment` fixture through the dev mailbox) whose card reads `XXXXXXXXXXX8755X`, with a card **Black** already in **Manage cards**. **Review** -> **Expected:** the card reads `XXXXXXXXXXX8755X` and a **Which card was it?** select sits under the class, with "The bank hides part of this number…" under it. **Confirm** -> **Expected:** "Choose which card this was (or No card)." and the voucher still there. Pick **Black** -> **Confirm** -> **Expected:** "Confirmed", the month row shows **Black**, and **Manage cards** has no new auto-named card. Stage a second receipt with the same number -> **Expected: Black** preselected and the hint "Your answer last time…". Pick **No card** -> **Confirm** -> **Expected:** that row has no card. Postman **Confirm pending voucher** with a `card_id` from another household -> **Expected:** 400 `invalid_request`, the draft still pending. A BAC voucher (`**********1234`) shows no picker and books on its card as before.

QA-EMAIL-06 — Review queue: confirm books the transaction once, discard never reverts a confirm • Core (Web / API)

Gherkin

```
Given a pending draft in the Review queue (header badge shows 1, dashboard banner says 1 waiting)
Then each draft is a TWO-PANE row: the draft on the left, and on the right a "Confirming will" panel
stating in words what the click books — the amount, the category, the class, and which PAY-CYCLE
month AND week the date lands in (not always the calendar one); for budgeted spending whose category
backs a line in that month, the sentence goes on with the line's spend so far, its plan and the total
after this booking
And the class is three chips, not a dropdown — Budgeted, Discretionary, Unplanned — reachable by
keyboard as a radio group
When I pick a category (or create one right there with "+ New" — every card on the queue then lists
it) and class, tick "Remember this merchant" and Confirm
And when the class is Unplanned, a "Refund expected" switch appears with a percentage, an "Expected
back: …" preview and a "Refund notes" box beside the percentage, spanning the row like Notes;
confirming with it books the transaction AND its pending refund in that month, carrying the notes
Then "Confirmed and remembered", the draft leaves the queue, the badge disappears, and the month
lists a transaction with source email and the voucher's amount, bank, date and card (the queue card
shows "VISA ····1234"; the card is created as VISA-1234 on first sight — QA-CAT-05)
And Settings -> Manage suggestions now has a rule for that merchant
When I confirm the same draft again through the API
Then 409 not_pending, and no second transaction exists
When I discard another pending draft
Then it leaves the queue; discarding it again -> 409; the same email never re-stages on the next Sync
now
Given a draft the parser could not fully read
Then an amber notice names the missing fields IN THE USER'S WORDS (Payee, Amount, Date — not the
parser's field names), each blank input carries a red border and points at that notice
And the consequence panel reads "Nothing yet — … still missing" and Confirm is DISABLED — blocked
visibly, never failing on submit
When I fill those blanks in
Then the panel switches to the booking sentence and Confirm enables, without leaving the row
```

Walkthrough: need a pending draft — either QA-EMAIL-04 with a real email, or stage one directly (dev only): `INSERT INTO "PendingVouchers" (…)` with your household's `TenantId`, a `BankId` from `"Banks"`, `Status = 'pending'`, `Merchant`, `Amount`, `Currency = 'CRC'`, `Date`, `Fingerprint`, `ProviderMessageId`, `ParsedBank = 'Bac'`, `MissingFields = '{}'`. Open **Dashboard** -> **Expected:** the amber banner "1 voucher(s) … waiting for

review -> Review now" (even with no months yet) and the header **Review** link with a **1** badge. **Review** -> **Expected:** each draft is a **two-pane row** — merchant, ■ amount, date, type, bank and card on the left; a **CONFIRMING WILL** panel on the right. Read that panel -> **Expected:** a sentence naming the amount, the category, the class, the month and the week, e.g. "Book ■7,200.00 into Carne as Budgeted, in September 2026 · week 3." followed, when Carne backs a budget line in that month, by "Carne: ■… spent of ■… planned — after this, ■…" (the line clause appears only for a voucher in the line's own currency — the queue holds no rate to convert with). Category is prefilled only when a rule matches, and then carries a **from your rule** chip. The class is **three chips** — tab to them and use the arrow keys -> **Expected:** they move like a radio group, and picking **Unplanned** reveals the refund switch. Parsed fields stay read-only; a draft the parser could not read shows the **amber** notice naming **Payee / Amount / Date**, red borders on exactly those inputs, **"Nothing yet — … still missing"** in the panel and **Confirm disabled**; filling them in flips the panel to the booking sentence and enables Confirm without the row moving. Pick a category — or **+ New** beside the picker, type a name, **Create** -> **Expected:** selected on this card and offered on every other card — tick **Remember this merchant**, **Confirm** -> **Expected:** the green notice, the card gone, the badge gone; **Months -> that month** lists the transaction (source `email`); **Settings -> Manage suggestions** has the new rule. On another draft pick class **Unplanned** -> **Expected:** a **Refund expected** switch; turn it on, toggle **%**, type `30` -> **Expected:** "Expected back: <30 % of the amount>" (the amount is what is sent); **Confirm** -> **Expected:** the month's **Expected refunds** table has the pending refund (Postman **Confirm pending voucher** with a `refund_amount` above the voucher's amount -> 400 `invalid_request`, draft still pending). Postman (**Confirm pending voucher** with the same `{{pendingVoucherId}}`) -> **Expected:** 409 `not_pending`; **Months -> transactions** still shows one row for it. Stage a second draft -> **Review -> Discard** -> **Expected:** "Draft discarded.", queue empty; Postman **Discard pending voucher** -> 409 `not_pending`; **Sync now** (or re-staging the same fingerprint) -> not re-staged (the tombstone). Also: with the rate provider blocked (unset the API key and no prior transaction), **Confirm** -> **Expected:** "No exchange rate is available right now", the draft stays in the queue, nothing in Months.

11. Emails (Mailpit) — branding & content • Core

> **Delivery is asynchronous** (the outbox dispatcher) — emails land in Mailpit a few seconds after the triggering action, and the send request succeeds regardless (see §1.1). Wait briefly before opening Mailpit; a missing email is a delayed/retrying/dead-lettered outbox message, not a request failure.

QA-MAIL-01 — OTP email is branded & correct • Core

Gherkin

```
Given I request an OTP code
When I open the email in Mailpit
Then it shows the brand logo, brand colours, the 6-digit code, and the tagline
```

Walkthrough: trigger an OTP; open it in Mailpit. **Expected:** the logo image renders (CID-embedded, not a broken image), brand-green styling, a clearly displayed code, footer wordmark + tagline.

QA-MAIL-02 — Magic-link email • Core

Walkthrough: trigger a magic link; open in Mailpit. **Expected:** branded layout; a working sign-in button/link; sensible subject.

QA-MAIL-03 — Invitation email • Core

Walkthrough: send an invite; open in Mailpit. **Expected:** branded layout; the recipient's address; a `/join?token=…` link that works (QA-INV-02).

QA-MAIL-04 — Logo renders in a real client • Edge

Walkthrough (optional, deliverability): forward/inspect one email in a real Gmail/Outlook client. **Expected:** the CID logo still renders. *(Note: from a non-verified domain, real delivery may land in spam — a domain/DKIM concern, not an app bug.)*

12. Desktop — MAUI / Windows • Core

> The desktop client reuses the same UI; only the **auth transport** (loopback browser flow, body token, OS secure storage) differs. Magic link is intentionally **absent** on native.

QA-DSK-01 — OTP sign-in • Smoke (Desktop) — CI covers boot-to-login only

Gherkin

```
Given the desktop app is on the login screen
When I request an OTP and enter the code from Mailpit
Then I am signed in within the app (no browser)
```

Walkthrough

1. Launch the desktop app -> login screen. **Expected:** Google/Microsoft buttons + email field with **Email me a code**; **no magic-link button** (native hides it).
2. Enter an email -> request code -> get it from Mailpit -> enter it.
3. **Expected:** signed in, app shell shown, household + name in header.

QA-DSK-02 — Google OAuth via loopback • Core (Desktop)

Gherkin

```
Given the desktop login screen
When I click Continue with Google and complete consent in the system browser
Then the browser shows a "you can close this" page and the app completes sign-in
When instead I close the browser tab without signing in
Then the app's login screen, which was saying "Finish signing in in your browser, or Cancel", comes
back on Cancel — no five-minute wait, no restart, no error
```

Walkthrough

1. Click **Continue with Google**. **Expected:** your **system browser** opens to Google consent, and the app's login screen reads "Finish signing in in your browser, or **Cancel**" above the held provider buttons.
2. Approve. **Expected:** the browser tab shows a "you can close this tab" page; **focus returns to the app**, now signed in. (Repeat for **Microsoft**.)
3. Sign out. **Continue with Google** again, then **close the browser tab**. **Expected:** the app is still waiting; click **Cancel** -> the provider buttons are live again immediately, with no error line.

QA-DSK-03 — "Remember me" across app restart • Core (Desktop)

Gherkin

```
Given I am signed in to the desktop app
When I fully close and reopen it
Then I am still signed in
```

Walkthrough: close the app completely; relaunch. **Expected:** lands signed in (refresh token held in Windows secure storage / DPAPI, silently exchanged on startup).

QA-DSK-04 — Household & Settings load (authorized API calls) • Core (Desktop)

Gherkin

```
Given I am signed in to the desktop app
When I open Household and Settings
Then both load their data without an auth error
```

Walkthrough: open **Household** (members load) and **Settings** (linked providers load). **Expected:** both populate — no spinner-forever, no "couldn't load" error. *(This is the Bearer-token-handler path that previously failed on native; it must work.)*

QA-DSK-05 — Link a provider from Settings • Edge (Desktop)

Walkthrough: Settings -> **Link** Microsoft -> system browser loopback flow -> returns to app. **Expected:** Microsoft shows **Connected**; the app shell was never navigated away.

QA-DSK-06 — Sign out • Edge (Desktop)

Walkthrough: Sign out. **Expected:** back to the login screen; reopening the app does **not** auto-sign-in (secure storage cleared).

QA-DSK-07 — Core household flows work on desktop • Edge (Desktop)

Walkthrough: spot-check rename, invite (token revealed), and leave on desktop. **Expected:** same behavior as web (§7–8) — the UI is shared.

> **NATIVE Wave 2 (ADR-018, the platform's NATIVE_PARITY):** the cases below verify the parity fixes per-feature on desktop — join-by-code (G5), culture persistence (G6), export share (G1), and the billing return-trip (G2) — plus the feature areas the old plan never exercised natively.

QA-DSK-08 — Join a household by pasted invite code • Core (Desktop)

Gherkin

```
Given a member account signed in on desktop and an invite code from the owner
When I open Household -> "Have an invite?" and paste the code
Then I join the owner's household exactly as the emailed link would
```

Walkthrough

1. As the **owner** (web is fine): Household -> invite the member's email -> copy the revealed token.
2. On **desktop** as the member: **Household** -> **Have an invite?** -> paste the code -> **Join**. **Expected:** success state -> **Go to household** -> roster lists both members.
3. Negative: paste a garbage code. **Expected:** inline error, the form stays for a retry.

QA-DSK-09 — Language choice survives an app restart • Core (Desktop)

Gherkin

```
Given the desktop app on the login screen (signed out)
When I switch the language to Español and fully restart the app
Then it launches in Spanish
```

Walkthrough

1. Signed out, on the login screen: switch the language selector to **Español**. **Expected:** the UI re-renders in Spanish (no restart needed).
2. Fully close the app; relaunch. **Expected:** still Spanish — the choice is read from OS Preferences before first render (NATIVE-5). Switch back to English; same persistence.
3. Note: after sign-in, a **server-saved** locale wins (the account preference follows you across devices) — that's by design.

QA-DSK-10 — Data export downloads via the OS • Core (Desktop)

Gherkin

```
Given I am the owner, signed in on desktop
When I request the data export and click Download
Then the file is offered through the platform share/save UI, not a dead WebView navigation
And on Windows that is a Save As dialog starting in Downloads, not the share flyout (#204); Cancel
saves nothing
```

Walkthrough

1. **Household** -> **Data** -> **Export my data** -> wait for the ready alert -> **Download**.
2. **Expected:** a **Save As** dialog opens in **Downloads** with the server's name (…`-<id>.json`) and the JSON file type (#204 — no longer the share flyout); the app page is not navigated away. Save it and open — valid JSON, no secrets (spot-check: no token hashes).
3. **Reports -> Export CSV** and **Reports -> PDF -> Download** -> **Expected:** the same Save As dialog, the type CSV / PDF; pick another folder -> the file lands there. Run one again and **Cancel** -> **Expected:** nothing is saved and no error shows.

QA-DSK-11 — Billing: checkout leaves, summary refreshes on return • Core (Desktop)

Gherkin

```
Given I am the owner on the desktop Billing page (Stripe test mode configured)
When I click Upgrade, complete checkout in the system browser, and return to the app
Then the plan summary refreshes by itself — no re-navigation needed
```

Walkthrough

1. **Billing** -> **Upgrade**. **Expected:** the **system browser** opens the hosted checkout; the app stays on Billing (it does not navigate away).
2. Complete checkout with a test card. **Expected:** the browser lands on the **web** app's billing page (by design — emailed/redirect links are web; the platform's NATIVE_PARITY G2).
3. Click back into the desktop app. **Expected:** the summary **refetches on focus** — the plan flips to **pro** without touching navigation. (Without Stripe keys the fake provider's checkout URL is a stub — then verify only: browser opened, app stayed, and refocusing refetches.)

QA-DSK-12 — MFA: enroll and native step-up • Core (Desktop)

Gherkin

```
Given I am signed in on desktop without MFA
When I enable the authenticator in Settings, sign out, and sign in again
Then the app itself prompts for the 6-digit code before completing sign-in
```

Walkthrough

1. **Settings** -> **Two-factor** -> **Enable**. **Expected:** the QR renders inside the app (the vendored QR script ships in the native host too); manual key shown; confirm with a code; **recovery codes** displayed once.
2. Sign out -> OTP sign-in. **Expected:** after the OTP, the app shows the **in-app MFA prompt** (native step-up, MFA-4) — enter the authenticator code -> signed in. A recovery code also works (single-use).

QA-DSK-13 — Notification bell & preferences • Edge (Desktop)

Walkthrough: header **bell** -> **Expected:** opens with the empty state (or your items), badge matches unread count. **Settings** -> notification preferences -> toggle one off -> reload the page -> **Expected:** the switch state persisted. (For a real item end-to-end, a staff announcement — see QA-ADMIN-04 — lands in the native bell too; spot-check when staff is configured.)

QA-DSK-14 — Admin console on desktop (staff only) • Edge (Desktop)

Walkthrough: with your email in `Admin:StaffEmails`, sign in on desktop. **Expected: Admin** appears in the nav; the console lists tenants; opening a detail works. Impersonate a user -> **Expected:** banner appears; **Stop** restores your staff session in-app (native refresh path).

QA-DSK-15 — Theme: dark mode survives an app restart • Edge (Desktop)

Walkthrough: pick **Dark** in the header switcher -> **Expected:** the WebView restyles dark immediately. Quit the app fully and relaunch -> **Expected:** it boots dark with no light flash (the theme bootstrap reads the WebView's own localStorage pre-paint — verifies WebView storage persists across restarts on this platform). Pick **Auto** -> **Expected:** follows the OS light/dark setting live.

13. Android — MAUI • Core

> Prereq every run: **`adb reverse tcp:5338 tcp:5338`** + API on the https profile. See the platform's MOBILE_TESTING.

QA-AND-01 — OTP sign-in • Smoke (Android) Automated in CI

Gherkin

```
Given the Android app is on the login screen with adb reverse set
When I request an OTP and enter the code from Mailpit
Then I am signed in
```

Walkthrough

1. Confirm `adb reverse --list` shows `tcp:5338`. Launch the app.
2. Login screen: email field + **Email me a 6-digit code**; Google/Microsoft buttons; **no magic link**.
3. Enter an email -> request code -> read it in Mailpit (host) -> enter it.
4. **Expected:** signed in, app shell shown.

QA-AND-02 — Google OAuth via custom scheme • Core (Android)

Gherkin

```
Given the Android login screen
When I tap Continue with Google and complete consent
Then the in-app browser returns to the app via the perezosoft:// scheme, signed in
```

Walkthrough

1. Tap **Continue with Google**. **Expected:** a browser tab opens to Google consent.
2. Approve. **Expected:** the tab returns control to the app (`perezosoft://auth` intent), now signed in. (Repeat **Microsoft** if its `:5338` redirect is registered.)

QA-AND-03 — "Remember me" across app restart • Core (Android)

Walkthrough: swipe-close the app; reopen. **Expected:** still signed in (refresh token in the Android Keystore). *(If `adb reverse` was lost on a device reboot, re-run it first — a startup failure after reboot is an environment issue, not an app bug.)*

QA-AND-04 — Household & Settings load • Core (Android)

Walkthrough: open **Household** and **Settings**. **Expected:** both load their data (the native Bearer path works), same as desktop QA-DSK-04.

QA-AND-05 — Navigation drawer / header is reachable • Edge (Android)

Gherkin

```
Given I am signed in on Android
When I open the navigation (hamburger)
Then the menu is tappable and not hidden under the status bar
```

Walkthrough: tap the hamburger; inside the sheet, open the **user menu** (tenant chip / your name) and use **Household/Settings/Sign out**. **Expected:** the header sits below the status bar (safe-area padding), the menu flows inside the sheet rather than floating over it, and every item is tappable.

QA-AND-06 — Core flows on Android • Edge (Android)

Walkthrough: spot-check language switch, invite (token revealed), and leave. **Expected:** parity with web.

> **NATIVE Wave 2 (ADR-018, the platform's NATIVE_PARITY):** the cases below verify the parity fixes on Android — including the two that only exist on this platform (hardware back, share sheet).

QA-AND-07 — Hardware back navigates in-app history • Smoke (Android)

Gherkin

```
Given I am signed in on Android and have navigated Dashboard (the root) -> Household -> Settings
When I press the hardware/gesture back button repeatedly
Then it walks back through the app's pages and only leaves the app at the root
```

Walkthrough

1. Navigate **Dashboard (root) -> Household -> Settings** (three distinct pages).
2. Press **back**. **Expected:** Settings -> Household. Again: -> the Dashboard.
3. Press **back at Home (root)**. **Expected:** the app backgrounds/exits — the default, but only at the root. *(Before NATIVE-4, any back press exited the app.)*
4. Note: a full WebView reload (e.g. the language switch) restarts the in-page history — back exiting right after one is acceptable.

QA-AND-08 — Join a household by pasted invite code • Core (Android)

Walkthrough: as QA-DSK-08, on Android: owner invites (web) -> member on Android: **Household** -> **Have an invite?** -> paste -> **Join** -> roster shows both. Garbage code -> inline error, retryable. *(This was parity gap G5 — a native member previously had no way to join at all.)*

QA-AND-09 — Language choice survives an app restart • Core (Android)

Walkthrough: as QA-DSK-09: signed out, switch to **Español** (re-renders) -> **swipe-close** the app -> relaunch. **Expected:** still Spanish (OS Preferences bootstrap, NATIVE-5). Signed-in accounts reconcile to their server-saved locale — by design. **Signed in (2026-09-16):** Settings -> Preferences -> Language -> **Español**. **Expected:** the app reloads once, in Spanish, and **stays** Spanish — before the fix it read the old language from the sign-in token, saved it back and reloaded again.

QA-AND-10 — Data export via the share sheet • Core (Android)

Walkthrough: owner -> **Household** -> **Data** -> **Export my data** -> **Download**. **Expected:** the **Android share sheet** opens with the JSON bundle (server-named); share to Files/Drive and open — valid JSON. The app page is not navigated away. *(Before NATIVE-3 this click did nothing — the WebView silently dropped it.)*

QA-AND-11 — Billing: checkout leaves, summary refreshes on return • Core (Android)

Walkthrough: as QA-DSK-11: **Billing** -> **Upgrade** -> **Expected:** the system browser/Custom Tab opens; complete checkout (test mode); switch back to the app (app switcher or back). **Expected:** the summary **refetches on resume** — plan shows **pro** without re-navigation (NATIVE-4; Android's return path is the Activity resume).

QA-AND-12 — MFA: enroll and native step-up • Core (Android)

Walkthrough: as QA-DSK-12 on Android — QR renders in-app (scan it with a second device or use the manual key), recovery codes shown once; after sign-out, OTP sign-in prompts the **in-app** MFA step-up (MFA-4).

QA-AND-13 — Edge-to-edge / status bar on Android 15 • Edge (Android)

Gherkin

```
Given a device or emulator on Android 15 (API 35, edge-to-edge enforced)
When I use the app in portrait and landscape
Then no control is hidden under the status bar or gesture areas
```

Walkthrough: check the header/hamburger (extends QA-AND-05), the bell dropdown, and a page with bottom-of-screen buttons (Settings danger zone) in both orientations. **Expected:** nothing sits under the status bar or the gesture-nav pill; everything tappable. *(Flagged [verify] by the parity audit — if this fails, it becomes a small safe-area fix slice.)* **Also, in both themes (2026-09-16):**

- The **status bar** is the header's indigo with light icons in Light and Dark alike — never the old sage green; on the sign-in screen (and while the app boots) it is the page's ground instead: near-white with dark icons in Light, the dark indigo ground with light icons in Dark.
- **No empty band** between the status bar and the header.

QA-AND-14 — Theme: dark mode survives an app restart • Edge (Android)

Walkthrough: as QA-DSK-15 on Android — pick **Dark** (hamburger -> header controls), force-stop the app (or swipe it away) and relaunch. **Expected:** boots dark, no light flash (Android WebView localStorage persists). **Auto** follows the system dark theme toggle live. **Then (2026-09-16):** signed in, pick **Light** in Settings -> Preferences and immediately switch the language (which reloads the app). **Expected:** still Light after the reload — and the status bar follows each change (QA-AND-13).

QA-AND-15 — OAuth sign-in survives process death (NATIVE-12) • Core (Android)

Gherkin

```
Given I tapped Continue with Google and the consent tab is open
When Android kills the app process before I finish consent
Then approving still signs me in — the redirect relaunches the app and completes on startup
```

Walkthrough

1 Tap **Continue with Google**. **Expected:** the browser tab opens to Google consent.

2. With the tab in the foreground, kill the app process: `adb shell am kill com.perezosoft.platform` (works because the app is backgrounded behind the browser; *Don't keep activities* + memory pressure reproduces it the organic way).
3. Approve consent in the still-open tab. **Expected:** the `perezosoft://auth` redirect cold-starts the app, which **stays open** and lands signed in on Home (the stashed code is exchanged during startup — no "flash open and close").
4. (MFA account) same steps. **Expected:** the app opens on the Login MFA code prompt; entering the TOTP completes sign-in.
5. (Staleness) repeat 1–2, wait > 5 min before approving. **Expected:** the app opens on Login with "Your sign-in took too long to complete. Please try again." — no crash, retry works.

13b. iOS + macCatalyst — first-run smoke • Core

> **These platforms compile in CI but had never been RUN before this pass.** Prereqs: a Mac with **Xcode 26.5** (the CI pin), the repo, and the API + Postgres + Mailpit running on that Mac (the iOS **simulator** shares the host network, so `https://localhost:7260` works; a **physical device** needs the API bound to a LAN address + the dev cert trusted). Launch: `dotnet build src/Maui -t:Run -f net10.0-ios` (simulator) / `-f net10.0-maccatalyst`. The **G7 fix is required** (PR #109) — before it, both platforms crashed at first resolve (no `IOAuthInitiator` registered). OAuth is wired via `ASWebAuthenticationSession` + the `perezosoft` scheme in Info.plist; first exercised **and passed** in the 2026-07-06 §13b run (PR #125 fixed the two gaps it found) — QA-IOS-04 re-verifies it each pass.

QA-IOS-01 — App boots to the login screen • Smoke (iOS)

Walkthrough: launch on the simulator. **Expected:** the app opens (no startup crash — this *was* parity gap G7), the login screen renders: email + **Email me a 6-digit code**, provider buttons, **no magic-link button**, nothing under the notch/safe areas.

QA-IOS-02 — OTP sign-in • Smoke (iOS)

Walkthrough: request a code -> read it from Mailpit (on the Mac) -> enter it. **Expected:** signed in, app shell + household load (the native Bearer/body-token path works on iOS).

QA-IOS-03 — Core flows spot-check • Core (iOS)

Walkthrough: spot-check on the simulator: **Household** roster + invite (token revealed) + **join-by-code**, **Settings** (providers list, MFA card renders its QR), **language switch** -> re-render + relaunch persistence, **bell** empty state, **export** -> iOS share sheet. **Expected:** parity with Android (§13) — same shared RCL.

QA-IOS-04 — OAuth via ASWebAuthenticationSession • Core (iOS)

Walkthrough: Continue with Google. **Expected:** the system auth session sheet opens to Google consent; approving returns to the app via the `perezosoft://auth` scheme, signed in. Also verify session-across-restart (Keychain-backed secure storage).

QA-MAC-01 — App launches at a usable window • Smoke (macCatalyst)

Walkthrough: launch the macCatalyst build. **Expected:** no startup crash (G7); the window opens at a sensible default size and is resizable; login renders. *(The audit's [verify] desktop-window-sizing cell for macOS.)*

QA-MAC-02 — OTP sign-in • Smoke (macCatalyst)

Walkthrough: as QA-IOS-02. **Expected:** signed in; Household + Settings load.

QA-MAC-03 — Core flows + OAuth spot-check • Core (macCatalyst)

Walkthrough: as QA-IOS-03 (share = macOS share menu) + one OAuth round-trip (QA-IOS-04 flow) + restart persistence. **Expected:** parity.

13c. Native release checklist

Per release that ships a native client, run the platform's • Smoke cases plus **one** • Core feature spot-check, and record results in §16:

Platform	Always (• Smoke)	Plus one of (• Core)
Windows desktop	DSK-01, DSK-03, DSK-06	DSK-08..12
Android	AND-01, AND-03, AND-07	AND-08..15
iOS	IOS-01, IOS-02	IOS-03, IOS-04
macCatalyst	MAC-01, MAC-02	MAC-03

Full per-feature native regression (every case in §12–13b) is for releases that changed native glue (`src/Maui/**`, the RCL seams: `IClulturePersistence` / `IFileDownloadLauncher` / `AppResumeNotifier`) or bumped the .NET/MAUI toolchain.

> **Two things to know before handing a tester an Android build (v4 T51).** (1) Android upgrades an app in place only when the new build carries the **same signing key** as the installed one: a store-signed build will not install over a debug-signed sideload, nor the reverse — the tester uninstalls the old one first (DEPLOYMENT §9). (2) Nothing the app stores is backed up off the device (`allowBackup="false"` + data-extraction rules), so after an uninstall or on a new phone the tester signs in again and re-picks language and theme; the account and its data are on the server.
>
> **(!) The native legs run ON REQUEST, never per push (ADR-031).** A pull request runs the web gates only. The MAUI builds and the Windows / Android / Apple smokes run from GitHub -> Actions -> `CI` -> *Run workflow* -> `devices` (android / windows / apple / all) — macOS bills at 10× and Windows at 2× on a private repo.
>
> **What that means for a release:** a green pull request says nothing about the native apps. Before shipping a native client, run the device legs for that platform (or all) on the commit you ship, or run the iOS/macOS cases in §13b on a Mac.

14. Cross-cutting security • Core

QA-SEC-01 — Tenant isolation • Smoke

Gherkin

```
Given two households owned by two different users
When user A is signed in
Then A can only ever see A's household, members, and invitations — never B's
```

Walkthrough

1. Create household A (owner A) and a separate household B (owner B, different account/incognito).
2. As A, open **Household**. **Expected:** only A's members/invites. Confirm B's data never appears. *(Deeper API-level probing — e.g. requesting another tenant's resource id — belongs in automated `Api.Tests`; this manual case verifies the UI never cross-contaminates.)*

QA-SEC-02 — Protected pages require auth • Core

Walkthrough: signed out, directly visit `/household`, `/settings`. **Expected:** each redirects to `/login`.

QA-SEC-03 — Session is gone after sign-out • Core Automated in CI

Gherkin

```
Given I sign out
When I press the browser Back button or reload a protected page
Then I am not able to access it — I am sent to /login
```

Walkthrough: sign out, press **Back** to a protected page / reload it. **Expected:** bounced to `/login`; no stale authenticated view.

*Automated by `SessionJourneyTests.SignOut_ThenBack_LandsOnLogin_NotTheCachedHousehold`, which runs with the browser's back/forward cache on and fails if the page was not actually restored from it. The trade-off, by decision: a page restored from that cache is reloaded (`bfcache-guard.js`), so Back after sign-out costs a signed-in

user one extra page load on any Back that hits the cache, in exchange for never showing the previous user's screen on a shared computer.*

QA-SEC-04 — Native open-redirect guard • Edge (Desktop/Android)

Context/Expected: the native OAuth flow only honors loopback `http` callbacks or the configured `perezosoft://` scheme; arbitrary redirect targets are rejected. This is unit-tested (`NativeRedirectPolicyTests`); no manual action needed unless probing the API directly — record as **covered by automated tests**.

QA-SEC-05 — Server-side hardening (automated) • Edge

Context/Expected: several invariants are enforced at the API/data layer and verified by `tests/Api.Tests`, not by manual UI steps — record as **covered by automated tests** unless probing the API directly:

- **Tenant write-stamping** — a new tenant-scoped row is stamped with the caller's tenant and a foreign-tenant write is rejected (`TenantStampingInterceptorTests`), so reads *and* writes are tenant-isolated.
- **Refresh-token reuse detection** — replaying an already-rotated refresh token revokes all the user's sessions (`RefreshTokenServiceTests`, `RefreshReplayTests`) — unless it arrives within 60 s of its rotation while its successor is still live (two tabs refreshing at once, a lost response): that race gets a fresh session and revokes nothing (ADR-002 addendum, 2026-09-18) — once per token: a third presentation is reuse (2026-09-28). Logout revokes the family of any known token, expired or just rotated out included (`RefreshReplayTests.Logout_With*`). Manually observable only by capturing and replaying a refresh cookie/token; out of scope for routine QA.
- **Unverified-email takeover guard** fails closed (`ClaimsExtractorTests` / `UserServiceTests`).
- **Legacy refresh-cookie self-heal** — a stale `Path=/` refresh cookie left by an older build can shadow the live `Path=/api/auth` cookie and wedge sign-in into a `/refresh` 401 -> "Authentication Failed" loop (seen in Firefox, due to cookie send-order). Setting the refresh cookie now also emits an expiry for the orphan, so the next successful sign-in / refresh sweeps it automatically — no manual cookie-clearing, and upgraded deployments self-heal (`CookieServiceTests`). *Manual repro needs a planted `Path=/` cookie; record as covered by automated tests. If a tester hits a stuck `/refresh` 401 loop in Firefox after a deploy, a single re-sign-in clears it.*

14a. Adversarial & tenant-isolation (QA-ADV-*) • Core

> This suite probes the failure classes a **v3 audit** surfaced: cross-tenant reads/writes at the **API** layer (not just the UI), impersonation attribution and confinement, billing idempotency, session/token lifecycle, preference bleed on shared devices, and deploy/native hardening. Most cases are **curl/Postman** driven with **two tenants A and B** — mint an **owner JWT for each** (sign in as each owner and copy its access token from `POST /api/auth/refresh` or the Swagger **Authorize** button, exactly as §14b describes) so you hold **two JWTs carrying different `tenant_id` claims**. A few cases need the **two browser contexts** of §1.2 (a normal window + an incognito/second profile); those are flagged in the title. Base URL `https://localhost:7260` (use `-k` for the dev cert) locally, or the staging host for Environment B. Grab each tenant's ids up front: `GET /api/household` as A and as B gives you A's/B's household id + member user-ids; note one **B** member user-id, one **B** notification/webhook/api-key id (create them if needed) for the cross-tenant probes.
>
> **(!) EXPECT-FAIL discipline.** Roughly half of these assert behaviour the v3 audit says is **broken at authoring time (2026-07); ALL are fixed as of the v3 remediation (PRs #147–#191)**. Each formerly-broken case carries a ■ v3-landed note naming the finding. When it fails, record **Blocked (known defect)** against the id in §16 — **never Pass**. A QA plan that green-ticks a broken isolation path is worse than no case at all. The remaining cases should **Pass on current code**; a failure there is a real regression.

QA-ADV-01 — Tenant A cannot read/export/erase Tenant B via the API • Smoke (curl)

Gherkin

```
Given I hold owner JWTs for two separate tenants A and B
When I use A's JWT to target B-scoped resource ids directly
Then every B id is refused (404/403), A's export contains only A, and no B row mutates
```

Walkthrough

1. With **A's JWT**, call `GET /api/household` -> **200** showing **only A** (never B's name/members).
2. `POST /api/household/export` with A's JWT -> the JSON bundle enumerates **only A's** tenant, members and invitations — grep it for B's household name/emails: **absent**.
3. Target B directly with A's JWT: `DELETE /api/household/members/{B-userId}`, `POST /api/notifications/{B-notificationId}/read`, `DELETE /api/notifications/{B-notificationId}`.
4. **Expected:** each B-scoped call returns **404** (or 403) — the global tenant filter + RLS backstop hide B entirely; ids from another tenant simply don't exist for A.
5. Re-verify as **B** (`GET /api/household`, bell): B's member list and notifications are **unchanged**. This promotes QA-SEC-01 from a UI-only check to a direct API probe (audit **RLS-2/4**).

QA-ADV-02 — Cross-tenant isolation on the newer tables (PUBAPI/HOOKS on) • Core (curl)

Precondition: set `PublicApi__Enabled=true` + `Webhooks__Enabled=true`, restart (§14b). In **each** tenant mint an API key (QA-API-02) and register a webhook + generate one delivery (QA-API-05/06). **Gherkin**

```
Given tenants A and B each own an API key, a webhook subscription and a delivery row
When A's JWT targets B's api-key / webhook / delivery ids
Then each is 404 and nothing cross-tenant is read, replayed or revoked
```

Walkthrough

1. With **A's JWT**: `GET /api/webhooks/{B-subscriptionId}/deliveries`, `POST /api/webhooks/deliveries/{B-deliveryId}/replay`, `DELETE /api/apikeys/{B-keyId}`.
2. **Expected: 404** for each — the delivery log/read side filters by `TenantId` and management routes are tenant-scoped, so B's rows are invisible and untouchable to A.
3. Confirm as B: B's key still authenticates, its subscription/deliveries are intact, nothing replayed (audit **LB-TEN-2 / RLS-8**).

QA-ADV-03 — Export includes EVERY tenant-scoped table, secret-free • Core (curl)

■ v3 REMEDIATION LANDED (2026-07, PRs #147–#191) — this case now expects PASS; re-run and record normally. Gherkin

```
Given PUBAPI + HOOKS are enabled and my tenant has an API key, a webhook and metered usage
When I export the household
Then the bundle covers api-keys (metadata only), webhook subscriptions (no secret) and usage counters
— or explicitly notes their exclusion
```

Walkthrough

1. Enable both flags; as owner mint an API key, register a webhook, and drive **one** metered `IQuotaService.TryConsumeAsync` consume (any endpoint an app has wired, or seed a `UsageCounter`).
2. `POST /api/household/export`; open the JSON.
3. **Expected (post-remediation):** it contains an **api-keys** section (name/prefix/scopes, **no hash**), a **webhook-subscriptions** section (url/event-types, **no signing secret**), and the **usage counters** — or an explicit documented exclusion note for each.
4. **Was (pre-v3 audit LB-TEN-1):** this step used to FAIL and was recorded Blocked. The finding is fixed (v3 remediation, PRs #147–#191) — the assertions above now hold; expect **Pass**. Also assert **no secret leaks** (hashes / `whsec_…`) regardless — the export stays secret-free.

QA-ADV-04 — Dissolve / erasure actually deletes api keys, webhook secrets, usage counters, delivery logs • Core (curl + DB)

■ v3 REMEDIATION LANDED (2026-07, PRs #147–#191) — this case now expects PASS; re-run and record normally. Gherkin

```
Given a tenant with an API key, a webhook subscription (+ deliveries) and usage counters
When the sole owner dissolves the household (or deletes the account)
Then all those rows are physically gone — no orphaned keys, secrets, counters or delivery logs remain
```

Walkthrough

1. Set up a throwaway tenant with the same artefacts as QA-ADV-03.
2. As sole owner, dissolve (QA-HH-07) / delete account (QA-SET-07).
3. Query the DB (or the staff console) for that tenant's `ApiKey`, `WebhookSubscription`, `WebhookDelivery`, `UsageCounter` rows.
4. **Expected (post-remediation): 0 rows** for the dissolved tenant — every contributor cleaned up.
5. **Was (pre-v3 audit LB-TEN-1):** this step used to FAIL and was recorded Blocked. The finding is fixed (v3 remediation, PRs #147–#191) — the assertions above now hold; expect **Pass**.

QA-ADV-05 — Writes during impersonation are attributed to the acting staff • Core (curl)

■ v3 REMEDIATION LANDED (2026-07, PRs #147–#191) — this case now expects PASS; re-run and record normally. Gherkin

```
Given a staff user is impersonating the household owner (token carries impersonated_by)
When they perform audited tenant writes (export the household, change a member's role)
Then each mutation's audit row records impersonated_by=<staff>, not just the target
```

> **Pick writes that are actually audited.** The audited-action catalog is small — `tenant.exported`, `member.role_changed`, `account.erased`, and the staff-only `admin.*` actions. Household rename (`PUT /api/household`) and mark-notification-read (`POST /api/notifications/{id}/read`) emit **no** `AuditEvent`, so they produce nothing to inspect; the two owner-gated writes below do. The stamp itself is ambient (`AuditLog` reads `ICurrentImpersonation`), so it lands on **every** audited event regardless of call site — the point is to exercise one that exists.

Walkthrough

1. As staff, `POST /api/admin/impersonate/{ownerUserId}` -> short-lived token with `impersonated_by`. Pick the household **owner** so the writes below are permitted; the tenant must also have **at least one other member** for the role change.
2. With that token, perform two **audited** tenant writes: `POST /api/household/export` (-> `tenant.exported`) and `PUT /api/household/members/{memberUserId}/role` (flip admin<->member -> `member.role_changed`).
3. Inspect the tenant's audit trail (staff-console audit view, or query the `AuditEvent` rows in the DB).
4. **Expected (post-remediation):** the `tenant.exported` **and** `member.role_changed` rows each carry **`impersonated_by=<staff-id>`** (with `actor_user_id=<owner>`), so an operator can tell staff-driven changes from the user's own — the stamp is applied to every event, not per call site.
5. **Was (pre-v3 audit LB-ADM-1):** this step used to FAIL and was recorded Blocked. The finding is fixed (v3 remediation, PRs #147–#191) — the assertions above now hold; expect **Pass**.

QA-ADV-06 — An impersonation session cannot reach staff-only actions • Core (curl)

■ v3 REMEDIATION LANDED (2026-07, PRs #147–#191) — this case now expects PASS; re-run and record normally. Gherkin

```
Given I hold an impersonation token (impersonated_by present, target is a normal member)
When I call staff-only admin endpoints with it
Then every one is refused at the staff gate — impersonation must not be a ladder back to staff power
```

Walkthrough

1. Impersonate a **plain member** (`POST /api/admin/impersonate/{memberUserId}`, as in QA-ADV-05 step 1 but targeting a non-owner) -> token with `impersonated_by`.
2. With it, attempt: `POST /api/admin/impersonate/{x}`, `PUT /api/admin/tenants/{id}/subscription`, `DELETE /api/admin/users/{x}/mfa`, `POST /api/admin/announce-all`.
3. **Expected (post-remediation): 403** on each — the staff gate treats a token bearing `impersonated_by` as **non-staff**, closing privilege re-escalation.
4. **Was (pre-v3 audit ADM-2):** this step used to FAIL and was recorded Blocked. The finding is fixed (v3 remediation, PRs #147–#191) — the assertions above now hold; expect **Pass**.

QA-ADV-07 — Impersonation cannot exceed the target's role • Core (curl)

Gherkin

```
Given I am impersonating a plain member (not owner)
When I attempt owner-only actions as that member
Then I get exactly the 403 the member themselves would get
```

Walkthrough

1. Impersonate a **plain member** of a tenant that has an owner + other members.
2. Attempt owner-only writes: `POST /api/household/transfer-ownership`, `PUT /api/household/members/{id}/role`, and (as staff-would-be) a comp — via the member token.
3. **Expected: 403** on each — impersonation inherits the **target's** role ceiling; a member seat confers no owner power (audit **TB-ADM-3**). Should **Pass** on current code.

QA-ADV-08 — Impersonation never rewrites target prefs; shared-device pref poisoning • Core (curl + Web — two contexts)

■ v3 REMEDIATION LANDED (2026-07, PRs #147–#191) — this case now expects PASS; re-run and record normally. Gherkin

```
Given I impersonate a user and change theme/language in their session
Then the target's server-stored preference is unchanged after I Stop impersonating
And on a shared browser, a fresh sign-in never inherits the previous user's saved preference
```

Walkthrough

1. **Leg A (should Pass):** impersonate a user, change theme/language in-session, **Stop impersonating**. Re-read the target's server pref (`GET /api/auth/me` / their Settings -> Preferences). **Expected: unchanged** — preference sync is suppressed while `impersonated_by` is set (PREFS-1/ADR-022).
2. **Leg B (EXPECT-FAIL):** in **context 1**, sign in as user A whose saved locale is **Español**; sign out. In the **same** browser, sign in as user B who has **never chosen** a language/theme.
3. **Expected (post-remediation):** B renders in B's own default (server never-set => B does not adopt A's leftover device value while a *different* account signs in).
4. **Was (pre-v3 audit LB-UI-4/5):** this step used to FAIL and was recorded Blocked. The finding is fixed (v3 remediation, PRs #147–#191) — the assertions above now hold; expect **Pass**.

QA-ADV-09 — A staff MFA-reset notification cannot be silenced by target prefs • Core (curl)

■ v3 REMEDIATION LANDED (2026-07, PRs #147–#191) — this case now expects PASS; re-run and record normally. Gherkin

```
Given a user has turned BOTH notification channels (in-app + email) off
When staff reset that user's MFA
Then the security.mfa_reset in-app row AND the email are still delivered (security events ignore
prefs)
```

Walkthrough

1. As the target, `PUT /api/notifications/preferences` with **in-app=false, email=false**.
2. As staff, `DELETE /api/admin/users/{targetUserId}/mfa`.
3. **Expected (post-remediation):** the target still gets the **`security.mfa_reset` **bell row** and** the email — a security-critical notice is not suppressible by user prefs.
4. **Was (pre-v3 audit ADM-1):** this step used to FAIL and was recorded Blocked. The finding is fixed (v3 remediation, PRs #147–#191) — the assertions above now hold; expect **Pass**.

QA-ADV-10 — MFA step-up locks out after repeated wrong codes • Core (curl)

■ v3 REMEDIATION LANDED (2026-07, PRs #147–#191) — this case now expects PASS; re-run and record normally. Gherkin

```
Given an MFA-enabled account at the sign-in step-up
When I submit wrong 6-digit codes past the attempt cap, including across freshly-requested challenges
Then a per-user cumulative MFA lockout engages — not merely the per-IP 429
```

Walkthrough

1. Trigger step-up (sign in as an MFA-on user); `POST /api/auth/mfa/verify` with wrong codes.

2. Keep going **past** the OTP-style attempt cap, and request **new** challenges to reset any per-IP window, pacing under the 429 verify throttle.
3. **Expected (post-remediation):** after N cumulative failures the **account's** step-up is locked (distinct from QA-AUTH-11's per-IP 429), mirroring the OTP cumulative lockout (QA-AUTH-04).
4. **Was (pre-v3 audit ADM-3):** this step used to FAIL and was recorded Blocked. The finding is fixed (v3 remediation, PRs #147–#191) — the assertions above now hold; expect **Pass**.

QA-ADV-11 — A recovery code is single-use • Core (Web)

Gherkin

```
Given I used one MFA recovery code to complete step-up
When I sign out and submit the SAME recovery code again
Then it is rejected — recovery codes are consumed on first use
```

Walkthrough

1. On an MFA-on account, at step-up enter a **recovery code** (not the TOTP) -> signed in.
2. Sign out; start a fresh sign-in to the same account; at step-up submit the **same** recovery code.
3. **Expected:** rejected ("that code is incorrect or has expired"); the code was hashed + burned on first use (audit **TB-AUTH-6**). A different, unused code still works. Should **Pass**.

QA-ADV-12 — Webhook replay + out-of-order + same-second idempotency • Core (curl)

Precondition: billing wired to the fake provider; HOOKS not required (this exercises the billing webhook inbox).
Gherkin

```
Given the billing webhook endpoint
When I POST the same EventId twice, then two distinct same-second events (created then active)
Then the duplicate is a no-op (inbox dedup) and the later state (active) still applies — not dropped
as stale
```

Walkthrough

1. POST a provider webhook to `/api/billing/webhook`; **repeat the exact same `EventId`**.
2. **Expected:** the second POST is a **no-op** — the inbox dedups on event id; the subscription state is applied exactly once.
3. POST two **distinct** events with the **same whole-second** `OccurredAt`: first `created`, then `active`.
4. **Expected:** the flip to **`active` is applied (the strictly-older recency guard drops stale events; same-second ties apply in arrival order (exact redeliveries are inbox-deduped), not by a second-granular timestamp that would wrongly drop it as stale) (audit** LB-BILL-1**). Should** Pass**.

QA-ADV-13 — A first-ever webhook in a bad state does not false-notify • Core (curl)

■ v3 REMEDIATION LANDED (2026-07, PRs #147–#191) — this case now expects PASS; re-run and record normally. Gherkin

```
Given a tenant that has NEVER had a live subscription
When its first-ever billing webhook arrives as past_due (or canceled)
Then NO dunning notification is sent to the owner (there was nothing to lapse)
```

Walkthrough

1. Pick a tenant with no subscription history. POST a **first** webhook with `Status=past_due` (or `canceled`) to `/api/billing/webhook`.
2. **Expected (post-remediation):** the owner receives **no** billing/dunning notification — a dunning notice requires a transition **out of** an active/paid state.
3. **Was (pre-v3 audit LB-BILL-4):** this step used to FAIL and was recorded Blocked. The finding is fixed (v3 remediation, PRs #147–#191) — the assertions above now hold; expect **Pass**.

QA-ADV-14 — Comp / revert a churned (canceled) tenant • Core (curl)

■ v3 REMEDIATION LANDED (2026-07, PRs #147–#191) — this case now expects PASS; re-run and record normally. Gherkin

```
Given a tenant whose Stripe subscription is canceled (its subscription id still persisted)
When staff try to comp it to Pro (or revert)
Then the comp should succeed — a churned tenant is not permanently un-comp-able
```

Walkthrough

1. Take a tenant whose provider sub is **canceled** but whose `Subscription` row still holds the Stripe id. As staff, `PUT /api/admin/tenants/{id}/subscription` (comp to Pro).
2. **Expected (post-remediation):** comp **succeeds** — a canceled/churned sub is treated as not-provider-managed for comp purposes.
3. **Was (pre-v3 audit ADM-5):** this step used to FAIL and was recorded Blocked. The finding is fixed (v3 remediation, PRs #147–#191) — the assertions above now hold; expect **Pass**. (The guard now keys on *liveness*: 409 only for a live provider sub — see QA-ADMIN-06, where 409 on a live Stripe sub is correct.)

QA-ADV-15 — Concurrent acceptance of the last seat • Core (Web — two contexts)

Gherkin

```
Given a tenant at seat cap minus one with two pending invitations
When both invitees accept near-simultaneously
Then exactly one joins, the other gets 402 seat_limit_reached, and seats never exceed the cap
```

Walkthrough

1. Bring a Free tenant to **one seat below its cap** with **two** pending invitations outstanding (the cap is the M in the Billing page's "N of M seats"). A pending invitation reserves a seat, so a Free tenant cannot be put in that state directly: comp it to Pro from the staff console, add members until it has **cap** − **1**, send the two invitations, then revert it to Free — the downgrade setup QA-INV-10 uses.
2. In **two browser contexts**, sign in as each invitee and open both `/join` links; click **accept** as close to simultaneously as you can (or double-submit).
3. **Expected: one** join succeeds (the last seat), the other returns **402 `seat_limit_reached` with the "household is full" state; the member count settles at** exactly the cap **— the atomic seat check has no race (audit** TB-BILL-19 / BILLING-9**). Should** Pass**.

QA-ADV-16 — Magic-link / OTP double-redemption issues exactly one session • Core (Web — two contexts)

Gherkin

```
Given a single magic link or a single OTP code
When I redeem it from two clients at once (open the link in two tabs / submit the OTP twice)
Then exactly one sign-in succeeds and the second attempt is rejected
```

Walkthrough

1. Request a magic link; open the **same** link in two tabs nearly simultaneously (or double-click). Alternatively, request one OTP and `POST /api/auth/otp/verify` the same code from two clients at once.
2. **Expected: one** session is issued; the second redemption is rejected (token consumed single-use, no double-spend under concurrency) (audit **LB-AUTH-3**). Should **Pass**.

QA-ADV-17 — Replaying a rotated refresh token revokes all sessions • Core (curl)

Gherkin

```
Given I captured a refresh token, then refreshed once (rotating it)
When I replay the OLD (now-rotated) refresh token more than 60 seconds after that rotation
Then it is rejected AND all of the user's sessions are revoked
But a replay WITHIN 60 seconds, while the new token is still live, is a race and gets a fresh session
```

Walkthrough

1. Sign in; capture the refresh cookie/token. `POST /api/auth/refresh` once -> a **new** token (the old one is now rotated out).
2. **Grace window (ADR-002 addendum, 2026-09-18):** replay the **old** token within 60 s -> **200** with a fresh token, and nothing is revoked (the new token from step 1 still refreshes). This is the two-tab / lost-response race, deliberately not treated as theft (`RefreshToken:ReuseGraceSeconds`, default 60). **The grace is one-shot (ADR-002 addendum,**

2026-09-28): replay the same old token a **third** time, still within the 60 s -> **401**, and every session is revoked (both the step-1 token and the step-2 token now fail). Sign in again before step 3. Should **Pass**.

3. Wait **more than 60 s** after step 1, then replay the **old** token to `POST /api/auth/refresh`.
4. **Expected: 401** — reuse detected — **and** the whole token family is revoked: a legitimate silent refresh from another live session now **fails** too (forces re-auth). Promotes QA-SEC-05's automated `RefreshTokenServiceTests` note to a manual probe. Should **Pass**.
5. **Logout stays final:** sign in again, refresh once (rotating A -> B), `POST /api/auth/logout` with B, then replay A **within** 60 s -> **401**, no new session (`RefreshReplayTests`). Should **Pass**.

QA-ADV-18 — Spanish account on an English device accepts an invite • Smoke (Web — two contexts) Automated in CI

■ v3 REMEDIATION LANDED (2026-07, PRs #147–#191) — this case now expects PASS; re-run and record normally. Gherkin

```
Given a user whose saved locale is Español, on an English-default browser
When they open a valid /join?token=… (signed in, or signing in through it)
Then the locale-mismatch reload preserves the /join deep-link and the invite is accepted
```

Walkthrough

1. User's server locale = **Español**; use a **fresh English-default** browser profile.
2. Open a valid `/join?token=…` while signed in (or sign in through the join flow).
3. **Expected (post-remediation):** the one-time locale-mismatch reload (WASM satellite assemblies, PREFS-1) **preserves** the `/join?token=…` URL and the invite is **accepted**.
4. **Was (pre-v3 audit UX-1, LB-UI-1/2):** this step used to FAIL and was recorded Blocked. The finding is fixed (v3 remediation, PRs #147–#191) — the assertions above now hold; expect **Pass**.

QA-ADV-19 — Theme/locale doesn't revert after a soft (OTP/MFA) sign-in • Core (Web)

Gherkin

```
Given on the login page I pick Dark + Español, for a user whose server prefs differ
When I complete an OTP soft-navigation sign-in
Then there is no flip-back-then-correct flicker; the switcher reflects the applied value all session
```

Walkthrough

1. On `/login`, set **Dark + Español**. Complete an **OTP** sign-in (soft nav, no full reload) for a user whose stored prefs are e.g. Light/English.
2. **Expected:** the reconcile settles the applied theme/locale **once**, cleanly — no visible revert-then-reapply flash — and the header switcher shows the settled value for the rest of the session (PREFS-1 reconcile on **every** sign-in path, audit **UX-3/4**). Should **Pass**.

QA-ADV-20 — "Clear read" never deletes unread notifications • Core (Web)

Gherkin

```
Given my bell holds a mix of read and unread notifications
When I use "Clear read"
Then only the read ones are removed; every unread notification survives
```

Walkthrough

1. Seed a mix (mark some read, leave some unread). In the bell, click **Clear read**.
2. **Expected:** the client sends `DELETE /api/notifications?read=true` — **read-only** clear; unread rows remain. Confirm the bulk clear **requires an explicit scope**: `?read=true` clears read only, `?read=false` is the distinct **Clear all**, and an omitted scope returns **400 `scope_required` — so a dropped param can never silently wipe unread (audit** LB-UI-10**). Should** Pass**.

QA-ADV-21 — Security headers on the single-origin host (staging / Environment B) • Core (curl)

■ v3 REMEDIATION LANDED (2026-07, PRs #147–#191) — this case now expects PASS; re-run and record normally. Gherkin

```
Given the deployed single-origin host serving API + WASM
When I inspect the response headers for the SPA shell and framework assets
Then HSTS, nosniff, a CSP/frame-ancestors and Referrer-Policy are present, with correct
cache-control
```

Walkthrough

1. `curl -I https://<app>-staging.onrender.com/` and `curl -I https://<app>-staging.onrender.com/_framework/blazor.webassembly.js`.
2. **Expected (post-remediation):** `Strict-Transport-Security`, `X-Content-Type-Options: nosniff`, a `Content-Security-Policy` (or `frame-ancestors`), and `Referrer-Policy`; **index.html** served `no-cache`, `_framework/*` fingerprinted assets `immutable`.
3. **Was (pre-v3 audit DEP-2/3):** this step used to FAIL and was recorded Blocked. The finding is fixed (v3 remediation, PRs #147–#191) — the assertions above now hold; expect **Pass**.

QA-ADV-22 — Forged X-Forwarded-For cannot bypass the per-IP rate limit • Core (curl)

Gherkin

```
Given the deploy is reachable other than via its trusted proxy (test the assumption)
When I send OTP requests with a rotating X-Forwarded-For header
Then the per-IP limit + OTP/MFA lockout is NOT bypassed
```

Walkthrough

1. Hammer `POST /api/auth/otp/send` past the 5/min budget, rotating a spoofed `X-Forwarded-For` each request.
2. **Expected:** the throttle still trips **429** — the app only honours forwarded headers from the **configured trusted proxy** (DEPLOY-1's config-gated forwarded-headers), so a client-supplied XFF is ignored for rate-limit partitioning.
3. If the deploy is reachable **only** through its single trusted ingress, spoofing is moot — **document that sole-ingress assumption** in the run notes (audit **DEP-1 / ADM-10**). Should **Pass** (or be recorded N-A with the documented assumption).

QA-ADV-23 — A Release native build points at a real HTTPS base URL, not cleartext localhost • Core (Desktop/Android)

■ v3 REMEDIATION LANDED (2026-07, PRs #147–#191) — this case now expects PASS; re-run and record normally. Gherkin

```
Given a Release (non-dev) native build with no dev overrides
When I inspect its configured API base URL and network security config
Then it targets the configured HTTPS API (build fails if none) — no http://localhost cleartext ships
```

Walkthrough

1. Build a **Release** AAB/MSIX without dev overrides. Inspect the effective base URL + Android network security config.
2. **Expected (post-remediation):** base URL is the configured **HTTPS** API; a missing base URL **fails the build**; no `http://localhost:5338` and no cleartext-permitting network config is shipped.
3. **Was (pre-v3 audit NAT-3):** this step used to FAIL and was recorded Blocked. The finding is fixed (v3 remediation, PRs #147–#191) — the assertions above now hold; expect **Pass**.

QA-ADV-24 — Windows loopback OAuth binds state (login-CSRF guard) • Edge (Desktop)

Gherkin

```
Given the desktop loopback OAuth callback listener with a pending state
When a callback arrives whose state does not match the pending listener
Then it is rejected — no session is minted from an unsolicited/forged callback
```

Walkthrough

1. Start a desktop OAuth sign-in (loopback listener opens). Simulate a callback to the loopback URL with a **mismatched/blank `state`**.

2. **Expected:** rejected — the client only completes the exchange when `state` matches the value it generated for the pending listener (login-CSRF / session-fixation guard), consistent with the native redirect policy (audit **NAT-10**). Should **Pass** (unit-backed; manual probe optional).

14b. API surfaces — PUBAPI + HOOKS (config-gated; curl / Postman) • Core

> These two surfaces are **off by default** and have **no web UI** by design — they're for machines, so they're QA'd with an HTTP client. Any client works; the steps use `curl`. **Postman:** the repo ships a **complete, chained collection for the entire API** (all surfaces, not just these two) in `docs/postman/`, and CI mirrors it into the **Postman workspace** (`postman-sync` — open the workspace and pick an environment: local dev or staging/Render; importing the files by hand also works). It signs in via OTP (auto-fetching the code from Mailpit on local) and stores/rotates tokens per request. Alternatively, import `GET /api/public/openapi.json` (once PUBAPI is on) for just the public routes.
>
> **Preconditions (do once):** in the repo-root `.env` set `PublicApi__Enabled=true` and `Webhooks__Enabled=true`, then restart the API. Management of keys/webhooks is **owner-only**, so sign in as an owner and grab a JWT access token from `POST /api/auth/refresh` (the Swagger "Authorize" button shows one) to call the `/api/apikeys` and `/api/webhooks` management routes below. Base URL in these steps is `https://localhost:7260` (use `-k` for the dev cert).

QA-API-01 — Config gate: surfaces are 404 when disabled • Edge (curl)

Gherkin

```
Given PublicApi:Enabled and Webhooks:Enabled are false (the default)
When I call any /api/public, /api/apikeys or /api/webhooks route
Then it does not exist (404) — the routes aren't mapped and the API-key scheme isn't added
```

Walkthrough

1. With both flags **unset/false**, restart the API and call `curl -k https://localhost:7260/api/public/openapi.json` and `.../api/apikeys` (with a JWT).
2. **Expected: 404** for both. Now set the two flags true, restart, and re-check — they become live (401/200). Leave them **on** for the rest of this section.

QA-API-02 — Mint an API key (shown once) • Core (curl)

Gherkin

```
Given I am the owner with PUBAPI enabled
When I create an API key
Then I receive the raw pk_… key exactly once, and listing later shows only its prefix/metadata
```

Walkthrough

1. `curl -k -X POST https://localhost:7260/api/apikeys -H "Authorization: Bearer <JWT>" -H "Content-Type: application/json" -d '{"name":"qa","scopes":["read"]}'`
2. **Expected: 201** with a `key` field like `pk_…` — **copy it now** (never shown again). `GET /api/apikeys` lists it with `prefix`/`scopes` but **no** `key`.
3. **Non-owner:** repeat as a member/admin -> **403**.

QA-API-03 — Call the public API with the key; scopes + tenant-scoping • Core (curl / Postman)

Gherkin

```
Given a read-only API key for my tenant
When I call the public API with it
Then whoami returns my tenant, and a write-scoped route is refused (403 insufficient_scope)
```

Walkthrough

1. `curl -k https://localhost:7260/api/public/whoami -H "X-Api-Key: pk_…"` -> **200**, body shows my `tenant_id`, the key name, and `["read"]`.
2. `curl -k -X POST https://localhost:7260/api/public/echo -H "X-Api-Key: pk_…" -d '{"message":"hi"}'` with the **read-only** key -> **403 `insufficient_scope`**. (A key created with `"write"` succeeds.)
3. **No/blank/garbage key** -> **401**. **Revoked key** (`DELETE /api/apikeys/{id}`) -> **401** afterwards.
4. **Postman:** import `/api/public/openapi.json`, set an `X-Api-Key` header on the collection, run `whoami`.

QA-API-04 — Per-key rate limit • Core (curl)

Walkthrough

1. Fire `whoami` with one key ~65 times in a minute (`for i in $(seq 1 65); do curl -k -s -o /dev/null -w "%{http_code}\n" https://localhost:7260/api/public/whoami -H "X-Api-Key: pk_…"; done`).
2. **Expected:** the first 60 are **200**, then **429**. A **second** key still returns **200** (budgets are per key, not shared).

QA-API-05 — Register a webhook + send test + verify signature • Core (curl)

Precondition: a receiver URL that echoes requests — e.g. create one at **https://webhook.site** and copy it. **Gherkin**

```
Given HOOKS is enabled and I own the tenant
When I register my receiver and send a test event
Then my endpoint receives a signed POST I can verify with the secret
```

Walkthrough

1. `POST /api/webhooks` (JWT) with `{"url":"<webhook.site URL>","event_types":["ping"]}` -> **201** with a `secret` (`whsec_…`) **shown once** — copy it.
2. `POST /api/webhooks/{id}/test` (JWT) -> **200** `{ "delivered": true, "status_code": 200 }`.
3. On webhook.site, confirm the request has headers **`X-Webhook-Id`, `X-Webhook-Event: ping`, and `X-Webhook-Signature: sha256=…`. Verify: HMAC-SHA256 of the** raw body** with your `whsec_…` secret equals the signature (any HMAC tool, or the app's `WebhookSignature.Compute`).
4. **Non-owner** management -> **403**. **Bad URL / no event types** on create -> **400**.

QA-API-06 — Delivery log + replay • Core (curl)

Gherkin

```
Given I've sent test deliveries to my subscription
When I view its delivery log and replay one
Then I see per-attempt rows, and replay re-POSTs the same event to my endpoint
```

Precondition: send one or more **test** events first (QA-API-05 step 2) — the sync send-test records a delivery row per attempt (success and failure), so the log is populated in-template even though the sample app fires no published events. (Published events via `IWebhookPublisher` also log, through the outbox.) **Walkthrough**

1. `GET /api/webhooks/{id}/deliveries` (JWT) -> a list of attempts, newest first, each with `success`, `status_code`, `error`, `event_id`. Each send-test from QA-API-05 shows up here.
2. `POST /api/webhooks/deliveries/{deliveryId}/replay` (JWT) -> **202**; webhook.site receives the **same** event again (same `X-Webhook-Id`, so a real receiver can dedup). Replay goes through the outbox, so its own attempt is logged too.
3. **Failure path:** point the subscription at a URL that returns 500, send a test -> the response is `{ "delivered": false, "status_code": 500 }` and the log gains a `success:false` row. (The sync send-test does **not** retry; the outbox retry/backoff + dead-lettering applies to *published*/replayed deliveries — watch the API logs on a replay.) Replay of an unknown/other-tenant delivery id -> **404**.

14c. Pre-launch gates — billing off + signup green list (GATES) • Core

> Both gates are **deployment configuration**, read at startup (ADR-027) — every change below needs an **API restart**, and neither can be flipped from inside the app. They exist so a deployment can run **private and free** before it is published: nothing offers to sell a tester anything, and a stranger who finds the URL cannot create an account. Hiding the deployment itself is explicitly out of scope.

QA-GATE-01 — Billing off: the surface does not exist • Smoke (Web + curl) Automated in CI

Automated by `GateJourneyTests.BillingOff_TheSurfaceDoesNotExist_NoLink_NoPage_ApiAnswers404` in the gates-off E2E lane (`Billing__Enabled` unset, `Signup__AllowedDomains__0` = one listed domain; `dotnet platform e2e -Gates` locally). The manual walkthrough stays for a real deployment.

Precondition: `Billing__Enabled` unset in the repo-root `.env` (the shipped default); restart. **Gherkin**

```
Given Billing:Enabled is unset
When I look at the header and call the billing routes
Then there is no billing link, /billing does not render, and the API answers 404
```

Walkthrough

1. Sign in as an owner. **Expected:** the header shows Household / Settings but **no Billing** button.
2. Type `/billing` in the address bar. **Expected:** you land on the home page — the page refuses to render.
3. `curl -k https://localhost:7160/api/billing` -> **404** (not 401 — the route is gone, not protected).
4. `curl -k -X POST https://localhost:7160/api/billing/webhook -d '{}'` -> **404**. The provider callback is gated too: signature authentication is not a reason to accept events for a deployment with no provider.
5. Check the API startup log for one line reading `Pre-launch gates: billing disabled...`.

QA-GATE-02 — Billing off: nothing offers an upgrade • Core (Web) Automated in CI

Automated by `GateJourneyTests.BillingOff_AFullHousehold_SaysFull_AndNeverOffersAnUpgrade` in the gates-off E2E lane (`Billing__Enabled` unset, `Signup__AllowedDomains__0` = one listed domain; `dotnet platform e2e -Gates` locally). The manual walkthrough stays for a real deployment.

Precondition: QA-GATE-01's state, plus a household at its seat cap (see QA-HH-14). **Gherkin**

```
Given billing is gated off and my household is full
When I invite one more member, and when an invitee opens a valid invitation
Then both are told the household is full, and neither is told to upgrade a plan
```

Walkthrough

1. As owner of a full household, invite another address. **Expected:** "Your household is full. Remove a member or revoke a pending invitation to free a seat." — **no** mention of upgrading.
2. Open a still-valid invitation to that household as the invitee. **Expected:** the full-household page says to ask the owner to free a seat, **not** to ask them to upgrade their plan.
3. Switch the UI to Spanish and repeat step 1 — the Spanish copy must be the no-upgrade wording too.

QA-GATE-03 — Billing on: the surface comes back whole • Core (Web)

Precondition: set `Billing__Enabled=true`; restart. **Gherkin**

```
Given Billing:Enabled is true
When I sign in as an owner
Then the billing link is back, /billing renders the plan summary, and the seat-limit copy offers an
upgrade
```

Walkthrough

1. The header shows **Billing**; `/billing` renders the plan + seat usage (§10c applies in full).
2. A seat-capped invite now reads "...Upgrade your plan to invite more members."
3. `curl -k https://localhost:7160/api/features` -> `{"billing":true}` (anonymous — this is what the client reads).

QA-GATE-04 — Green list: a stranger cannot create an account • Smoke (Web) Automated in CI

Automated by `GateJourneyTests.GreenList_AStrangerIsRefusedAtRedemption_WithTheRightWords` in the gates-off E2E lane (`Billing__Enabled` unset, `Signup__AllowedDomains__0` = one listed domain; `dotnet platform e2e -Gates` locally). The manual walkthrough stays for a real deployment.

Precondition: in `.env` set `Signup__AllowedEmails__0=` **your own address**; restart. Use a *second* address you control that is NOT listed and has **no account yet**. **Gherkin**

```
Given a green list that does not contain my address
When I complete a first-time sign-in with a valid code
Then I am told the app is in private testing and no account is created
```

Walkthrough

1. On `/login`, request a code for the unlisted address. **Expected:** the send succeeds — the gate runs at redemption, not at issue, deliberately (refusing at issue would reveal whether an address has an account).
2. Enter the **correct** code from Mailpit. **Expected:** "This app is in private testing and isn't accepting new accounts yet..." (HTTP **403**, `signup_not_allowed`) — NOT the "incorrect or expired" line.
3. Confirm in the DB (or by retrying) that **no** user row and **no** household were created.
4. Repeat with the same unlisted address via **Sign in with Google**. **Expected:** the same private-testing message on the login page — the provider button is not a side door.
5. Repeat via a **magic link**. **Expected:** the same message.

QA-GATE-05 — Green list: a listed person founds a household and can bring their family • Core (Web) Automated in CI

Automated by `GateJourneyTests.GreenList_AListedOwnerFoundsAHousehold_AndAnUnlistedInviteeMayJoinIt` in the gates-off E2E lane (`Billing__Enabled` unset, `Signup__AllowedDomains__0` = one listed domain; `dotnet platform e2e -Gates` locally). The manual walkthrough stays for a real deployment.

Precondition: QA-GATE-04's state (your address listed, one unlisted address available). **Gherkin**

```
Given my address is on the green list
When I sign in, and then invite the unlisted address into MY household
Then I get my own household, and my invitee may sign up even though they are not listed
```

Walkthrough

1. Sign in with your listed address. **Expected:** normal sign-in; you own a household.
2. Invite the unlisted address from **Household**. Open the invitation as that address and sign in for the first time. **Expected:** sign-in succeeds and they join **your** household — the invitation admits them because the household's **owner** (you) is green-listed.
3. Have that member press **Leave**. They are re-homed into their own empty household — expected, and harmless: now have them invite a **third** unlisted address. **Expected:** the third address is refused at sign-in, because the owner of that household is not green-listed. This is the one-hop boundary.

QA-GATE-06 — Green list never locks out an existing account • Smoke (Web)

Precondition: an account that already exists and is **not** on the green list (e.g. the one from QA-GATE-05 step 2, after removing it from the list if you added it). **Gherkin**

```
Given an account that already exists and is not on the green list
When it signs in
Then the sign-in succeeds
```

Walkthrough

1. Sign out, then sign in again with that existing, unlisted account. **Expected:** success — the gate is on account **creation** only. This is the case that makes editing the list safe once people have data.
2. Clear `Signup__AllowedEmails__0` entirely and restart. **Expected:** the startup log reads `signup open to anyone` and any new address can sign up again — this is what publishing looks like.

14d. v4 audit — adversarial, forge & regression (QA-ADV-25+, QA-DEP-*) • Core

The platform's v4 delta audit (2026-09-23; its reports live in the perezosoft-platform repo, the rule book it produced is `docs/audits/v4-2026-09/FOUNDATION_RULES_v3.md` here) found the classes below. When this section was written, eleven of its cases asserted behaviour the audit had proved broken and were pre-recorded **Blocked**. **All eleven are remediated** (v4 batches B3–B7, merged 2026-09-24 -> 2026-10-01): each case below names the finding and the task that fixed it, and **every case in this section is expected to Pass**. A failure here is a regression — record it **Fail** with the finding id in Notes. (The discipline for a future audit is unchanged: a case that asserts known-broken behaviour is marked **(!) PENDING remediation** and recorded Blocked, never Pass, until its task lands.)

QA-ADV-25 — Joining another household wipes your old one completely • Core (curl + DB)

■ **Remediated** — v4 LB-AUTH-5 / LB-BILL-19, task T21 (R123) landed; expected **Pass**. **Gherkin**

```
Given I am the only member of household A, with an API key and a webhook subscription (PUBAPI/HOOKS
on)
When I accept an invitation to household B
Then household A is gone AND its API key no longer authenticates AND no row of A survives
```

Walkthrough

1. Environment with `PublicApi__Enabled=true`, `Webhooks__Enabled=true`. Sign in as a fresh user (a tenant-of-one is founded). Create an API key (`POST /api/apikeys`, capture the raw key) and a webhook subscription.
2. From a second account, invite the first user to household B; accept it as the first user.
3. `GET /api/public/…` with the captured key. **Expected: 401**. **Today:** 200 — the key still authenticates against a tenant that no longer exists.
4. DB: `SELECT count(*) FROM "ApiKeys"/"WebhookSubscriptions"/"UsageCounters" WHERE "TenantId" = '<A>'`. **Expected:** 0 each. **Today:** rows survive (the accept path deletes the tenant row directly instead of running the dissolution contributors). With a Stripe-backed A, also expect a `billing.cancel` outbox row.

QA-ADV-26 — Dissolving a household leaves no queued email or attachment behind • Core (curl + DB)

■ **Remediated** — v4 JOBS-2 / ADV-P4-7, tasks T22–T23 (R90/R91) landed; expected **Pass**. **Gherkin**

```
Given household A has emails in the outbox (an invitation, a notification)
When A is dissolved (or its owner erases their account)
Then no outbox row for A keeps a recipient address, a body or attachment bytes
```

Walkthrough

1. As A's owner, send an invitation to `x@example.com`. Stop the outbox dispatcher (or read quickly) and note the `OutboxMessages` row for it.
2. Dissolve A (`POST /api/household/leave` as sole owner, or delete the account).
3. DB: `SELECT "Payload" FROM "OutboxMessages" WHERE "Payload" LIKE '%x@example.com%'`. **Expected:** no rows (pending rows wiped, sent rows scrubbed). **Today:** the row survives with `TenantId` null and the full payload — and sent rows are never purged.

QA-ADV-27 — Signing out while a background renewal is in flight really signs out • Core (curl)

■ **Remediated** — v4 LB-AUTH-4 / LB-UI-12, tasks T29/T31 (R124/R125) landed; expected **Pass**. **Gherkin**

```
Given I refreshed once, rotating token A into B
When I sign out presenting the rotated-out token A (the cookie a racing tab still holds)
Then B is revoked too, and no further refresh succeeds
```

Walkthrough

1. Sign in; capture refresh token A. `POST /api/auth/refresh` with A -> capture B.

2. Within 60 s, `POST /api/auth/logout` presenting **A**. Response is 200 either way.
3. `POST /api/auth/refresh` with **B**. **Expected: 401** (the family was revoked). **Today:** 200 — a logout carrying the just-rotated token revokes nothing. Repeat step 2 with an **expired** token and a second live session: the second session should be revoked as well.

QA-ADV-28 — A rotated token is forgiven once, not forever • Core (curl)

■ **Remediated** — v4 AUTH-1, task T28 (R81) landed; expected **Pass**. **Gherkin**

```
Given token A was rotated into B less than 60 seconds ago
When A is presented a second time inside the window
Then it is treated as theft: 401 and every session revoked
```

Walkthrough

1. Sign in -> A. Refresh with A -> B.
2. Refresh with A again (inside 60 s) -> **200** (the benign race, QA-ADV-17 step 2).
3. Refresh with A a **third** time (still inside 60 s). **Expected: 401** and B stops working. **Today:** 200 again — each replay mints another live chain.

QA-ADV-29 — An expired impersonation never turns into the staff account mid-page • Core (Web)

■ **Remediated** — v4 LB-UI-13, task T31 (R125) landed; expected **Pass**. **Gherkin**

```
Given staff is impersonating a member on the member's Household page
When the 15-minute impersonation token expires and staff clicks an action
Then the action is refused or staff is returned home — it never runs as the staff user in the staff's
household
```

Walkthrough

1. As staff (`Admin__StaffEmails__0`), impersonate a member from `/admin`. Stay on the member's `/household`.
2. Wait 15+ minutes (or shorten the impersonation lifetime in a test config).
3. Rename the household. **Expected:** a visible refusal or a return to your own identity with a message; the member's household is untouched and the staff household is untouched. **Today:** the bearer handler silently renews into the staff identity and the rename lands on the **staff's own** household.

QA-ADV-30 — A webhook endpoint that redirects is a failed delivery • Core (curl)

■ **Remediated** — v4 LB-JOBS-1 / JOBS-9 / ADV-P4-9, task T37 (R130) landed; expected **Pass**. **Gherkin**

```
Given a webhook subscription whose URL answers 302 to another host
When a delivery or a send-test runs
Then the redirect is not followed, and the delivery log records a failure with status 302
```

Walkthrough

1. Point a subscription at a public endpoint you control that returns `302 Location: https://<other>/ok` (e.g. a request-bin with a redirect rule); make `<other>` answer 200.
2. `POST /api/webhooks/{id}/test`. **Expected:** `delivered: false`, `status_code: 302`; `<other>` receives nothing. **Today:** `<other>` receives a body-less **GET** carrying the signature headers and the log says delivered (200). With a 307, today the signed body itself reaches `<other>`.

QA-ADV-31 — The delivery log never shows raw server exception text • Edge (curl)

■ **Remediated** — v4 JOBS-1, task T39 (R89) landed; expected **Pass**. **Walkthrough**

1. Subscribe a webhook to `https://does-not-exist.invalid/hook`; send a test.
2. `GET /api/webhooks/{id}/deliveries`. **Expected:** `error` is a short code (`dns`, `timeout`, `connection`, `http_<status>`, `url_refused`). **Today:** the raw exception message (resolver text, IPs, the SSRF verdict).

QA-ADV-32 — Billing off leaves no billing-shaped surface anywhere • Core (curl)

■ **Remediated** — v4 BILL-2/BILL-3, task T45 (R86) landed; expected **Pass**. **Walkthrough**

1. Environment with `Billing__Enabled` unset. As staff: `PUT /api/admin/tenants/{id}/subscription {"plan_key":"pro"}`. **Expected: 404** (the comp write goes with the billing surface) and the console's Comp/Revert buttons are hidden. **Today:** 200, the tenant becomes Pro while billing is "off".
2. Complements QA-GATE-01 (which checks `/api/billing*` only).

QA-ADV-33 — Expired invitations stop holding seats • Core (Web)

■ **Remediated** — v4 LB-AUTH-7 / LB-BILL-20, task T34 (R127) landed; expected **Pass**. **Walkthrough**

1. Free household at `cap − 1` members plus pending invitations that are **past their expiry** (seed `ExpiresAt` in the past in the DB, or wait out `LifespanDays`).
2. Invite a new address. **Expected:** allowed (an expired invitation reserves nothing). **Today:** 402 `seat_limit_reached` / "household full" — dead invitations keep their seats forever.

QA-ADV-34 — The native export download never sends your sign-in token to the file host • Edge (Android/Desktop)

■ **Remediated** — v4 NAT-12, task T49 (R102) landed; expected **Pass**. **Walkthrough**

1. Environment with `Files__Provider=S3` (MinIO in compose). On the native app, Household -> Export data.
2. Watch the MinIO/S3 access log (or a proxy). **Expected:** the presigned GET carries **no** `Authorization: Bearer` header and the download succeeds. **Today:** the bearer JWT is attached (and AWS S3 rejects a presigned GET that also carries an Authorization header).

QA-ADV-35 — Exported logs carry no email addresses • Edge (Ops)

■ **Remediated** — v4 OBS-1, task T41 (R93) landed; expected **Pass**. **Walkthrough**

1. Set `OpenTelemetry__Otlp__Endpoint` to a collector you can read (Grafana Cloud or a local otel-collector with a file exporter). Sign in with OTP twice.
2. Search the exported log records for `@`. **Expected:** none — records carry user ids only. **Today:** every token issue exports `{Email}` as an attribute.

QA-DEP-01 — Deploy staging from GitHub • Smoke (Operator)

Gherkin

```
Given develop on GitHub
When I run the CI workflow on develop with deploy = staging
Then every web gate runs, and only when all pass the Render hook fires and the version-gated smoke
passes
```

Walkthrough

1. GitHub -> Actions -> `CI` -> *Run workflow* on `develop`, `deploy` = staging, `devices` = none (ADR-031; DEPLOYMENT §6).
2. **Expected:** `build-test`, `secret-scan`, `qa-artifacts`, `license-scan`, `docker-build` and `e2e` run, then `deploy-staging` fires `RENDER_DEPLOY_HOOK_STAGING`, waits until `/api/version` reports the commit and runs the post-deploy smoke green. No device leg runs. A merge alone deploys nothing.

QA-DEP-02 — A deploy run on the wrong branch fails loudly • Core (Operator)

Walkthrough

1. *Run workflow* on `main` with `deploy` = staging. **Expected:** the web gates run, then `deploy-staging` fails at its first step: "staging deploys from develop". Nothing is deployed.
2. *Run workflow* on `develop` with `deploy` = prod. **Expected:** `deploy-prod` fails the same way ("prod deploys from main").

QA-DEP-03 — A red gate blocks the deploy • Edge (Operator)

Walkthrough

1. On a throwaway branch off `develop`, break a unit test; run the workflow on that branch with `deploy` = staging. **Expected:** `build-test` is red, `deploy-staging` is skipped, and the Render hook never fires.
2. Delete the throwaway branch.

QA-DEP-04 — The device legs run only when asked for • Core (Operator)

Walkthrough

1. Open a pull request that changes `src/Shared.Ui`. **Expected:** only the web gates run — no `native-*` job.
2. *Run workflow* on `develop` with `deploy` = none, `devices` = android. **Expected:** `native-build` (Android leg only), `native-release-android` and `native-smoke-android` run; no web gate, no Windows or Apple job.
3. Repeat with `devices` = all before a release (macOS bills 10×). **Expected:** every native job green.

QA-SET-09 — A theme saved just before a reload survives the reload • Core (Web + Android)

Walkthrough

1. Signed in, switch theme Light -> Dark in Settings; immediately reload (web) or background/foreground the Android app so the WebView reloads. **Expected:** Dark stays (platform PR #233 — the switcher remembers the saved value; `PreferenceSyncClaimTests`). Repeat with the language switcher.

QA-AND-16 — An API base configured with a trailing slash still signs in • Edge (Android)

Walkthrough

1. Build the Android app with `-p:ApiBaseUrl=https://<staging>/` (trailing slash). Sign in with OTP and with Google. **Expected:** both succeed; no request goes to `//api/…` (platform PR #230 — `TrimEnd('/')` in `MauiProgram` and both OAuth initiators).

15. Traceability matrix (feature -> cases -> API)

Feature area	Test cases	Key API endpoints
OAuth sign-in (Google/MS)	SMK-02, AUTH-02, DSK-02, AND-02	`GET /api/auth/login/{provider}`, `GET /api/auth/callback/{provider}`, native `login/callback/exchange`
Magic link (web)	AUTH-01, 05, 06, MAIL-02	`POST /api/auth/magic-link/send`, `GET /api/auth/magic-link/verify`
Email OTP	SMK-01/05/06, AUTH-03/04, DSK-01, AND-01, MAIL-01	`POST /api/auth/otp/send`, `POST /api/auth/otp/verify`
Rate limiting / abuse guard	AUTH-11	`POST /api/auth/otp/send`, `…/magic-link/send`, `…/otp/verify` (429)
Session / refresh / sign-out	SMK-03/04, DSK-03/06, AND-03, SEC-03, SEC-05 (legacy-cookie self-heal)	`POST /api/auth/refresh`, `POST /api/auth/logout`, `GET /api/auth/me`
Enumeration / error handling	AUTH-04/07/08/09	(send + verify endpoints; `/login` query states)
Onboarding (auto tenant)	ONB-01/02, SMK-01	(provisioned on first auth)
Household view/rename	HH-01/02	`GET /api/household`, `PUT /api/household`
Members (remove/leave/transfer/dissolve)	HH-03..08	`DELETE /api/household/members/{id}`, `POST /api/household/leave`, `POST /api/household/transfer-ownership`
Invitations	INV-01/06/07/08, MAIL-03	`POST /api/household/invitations`, `GET /api/household/invitations`, `POST …/{id}/regenerate`, `DELETE …/{id}`
Join / accept	INV-02/03/04/05, **INV-10** (seat re-check after downgrade — BILLING-9, E2E), **DSK-08 / AND-08** (paste invite code — NATIVE-4b; web variant E2E)	`POST /api/household/invitations/accept` (402 `seat_limit_reached` when the tenant is over its downgraded cap)
Linked accounts	SET-01..06, DSK-05	`GET /api/auth/logins`, `POST /api/auth/link/{provider}`, `DELETE /api/auth/logins/{provider}`
Localization	I18N-01..04, **DSK-09 / AND-09** (native restart persistence — NATIVE-5)	`PUT /api/auth/locale` (+ resx)
Theme / dark mode (THEME-1 + PREFS-1)	**SET-08** (E2E `ThemeJourneyTests`) + **DSK-15 / AND-14** (native restart persistence)	`PUT /api/auth/theme` ("system" stored verbatim, null = never chose — ADR-022; `theme` JWT claim; pre-paint `theme.js` -> `data-bs-theme`; sign-in reconcile + device adoption)
Budget settings (app BUDGET-1)	BUD-01..03	`GET /api/budget-settings`, `PUT /api/budget-settings` (400 `invalid_request`; household-wide, member-editable)

Feature area	Test cases	Key API endpoints
Catalog: categories + banks (app CATALOG-1/2)	CAT-01..04	`GET/POST /api/categories`, `PUT /api/categories/{id}`, same under `/api/banks` (409 `*_exists` / `*_exists_inactive` + `existing_id` + `existing_name`; uniform 404)
Exchange rate (app FX-1)	FX-01..02 + `Api.Tests` (`ExchangeRateApiClientTests`, `ExchangeRateResolverTests`)	`GET /api/exchange-rate` (200 `{rate, source: live|cache|transaction, as_of}`; 503 `exchange_rate_unavailable`; 401 anonymous)
Envelopes (app ENV-1)	ENV-01..02	`GET/POST /api/envelopes`, `PUT /api/envelopes/{id}` (400 `invalid_request`; 409 `envelope_exists` / `envelope_exists_inactive` + `existing_id` + `existing_name`; uniform 404)
Income lines + month income rows + income by member (app INCOME-1/2 · ADR-V023)	INC-01..04 (04: `Api.Tests` (App/) `IncomeByMemberTests`, `Api.Tests` `ReportSliceTests` / `ReportPdfModelBuilderTests` / `ReportPdfRendererTests`, `Ui.Tests` `ReportsPageTests`) (01–02 E2E `IncomeJourneyTests`) + `Api.Tests` (App/) (`IncomeSnapshotTests`, `IncomeCalculatorTests`) + `Api.Tests` (`IncomeSliceTests`, `IncomeEndpointTests`, `IncomeMigrationTests` on real Postgres, `ArchitectureTests.LegacyIncomeColumns_AreReadOrWrittenByNothing`) + `Ui.Tests` (`IncomesPageTests`, `LedgerPagesTests`)	`GET/POST /api/incomes`, `PUT /api/incomes/{id}`, `PUT /api/incomes/order` (400 `invalid_request`; 409 `income_exists` / `income_exists_inactive` + `existing_id` + `existing_name`; uniform 404); `GET /api/months/{id}` -> `income_rows`; `PUT /api/months/{id}/income` `{rows:[…]}`; `ops/check-income-parity.sql`
Months & transactions (app LEDGER-1/2)	LED-01..04 + `Api.Tests` (`LedgerSliceTests`)	`GET /api/months`, `GET /api/months/resolve?date=`, `GET /api/months/{id}`, `PUT /api/months/{id}/income`, `GET /api/months/{id}/transactions`; `POST /api/transactions`, `GET/PUT/DELETE /api/transactions/{id}` (400 `invalid_request` / `exchange_rate_unavailable` / `derived_transaction`; uniform 404)
Expected refunds & realization (app LEDGER-3, LEDGER-5..8)	LED-05..06, LED-08..09 + `Api.Tests` (`RefundSliceTests`, incl. the two-context concurrency proof)	`refund_expected` / `refund_amount` on `POST/PUT /api/transactions` (409 `refund_status_conflict` on a received refund's purchase — ADR-V026); `GET /api/months/{id}/refunds` (`{ refunds, totals }`); `GET /api/refunds` (400 on a bad status/range); `PUT /api/refunds/{id}` (200; 400 `invalid_request`; 404; 409 `refund_status_conflict`)
Budget lines: fixed + variable (app EXPENSES-1)	EXP-01..03	`GET/POST /api/expenses/{fixed|variable}`, `PUT …/{id}`, `PUT …/order` (400 `invalid_request`; 409 `expense_exists` / `expense_exists_inactive` + `existing_id` + `existing_name`; uniform 404)
Dashboard (app DASH-1)	DASH-01..02 + `Api.Tests` (App/) (`DashboardSummaryServiceTests`, 45 donor cases) + `Api.Tests` (`DashboardSliceTests`)	`GET /api/months/{id}/summary` (200 `{month, exchange_rate, rate_source, rate_as_of, rate_unavailable, summary}`; 401 anonymous; uniform 404)
Reports: category analysis + CSV export + PDF + email + appendix columns (app REPORTS-1/2/7/8/9)	REP-01..02, REP-05..07 + `Api.Tests` (App/) (`CategoryAnalysisCalculatorTests`, `TransactionCsvWriterTests`) + `Api.Tests` (`ReportSliceTests`, `ReportPdfChartsTests`, `ReportPdfModelBuilderTests`, `ReportPdfSliceTests`) + E2E `ReportPdfJourneyTests`	`GET /api/reports/category-analysis`, `POST /api/reports/transactions/export`, `POST /api/reports/pdf`, `POST /api/reports/pdf/email` (`month_id` |`from`+`to`; 400 `period_required` / `period_ambiguous` / `period_incomplete` / `period_invalid`; uniform 404; export -> signed `download_url` served by `GET /api/files/{token}`)
Feature area	**Test cases**	**Key API endpoints**
Email inboxes: connect + readers (app EMAIL-2/3)	EMAIL-01..03 + `Api.Tests` (`MailConsentServiceTests`, `EmailReaderTests`, `EmailConnectionSliceTests`)	`GET /api/email/connections` (+ `/{id}`, `/{id}/folders` 409 `needs_reconsent`), `GET …/authorize?provider=` (400 `invalid_provider` /

Feature area	Test cases	Key API endpoints
		provider_not_configured), anonymous GET …/callback (-> /email?connected= |?email_error=), GET …/suggested-filters, POST … (400 use_consent_flow), PUT /{id} (400 filters_required / invalid_interval), DELETE /{id}; uniform 404
Email ingestion: staging + dedup (app EMAIL-4)	EMAIL-04 + Api.Tests (App/) (VoucherFingerprintTests) + Api.Tests (VoucherStagingSliceTests incl. the poll job)	POST /api/email/connections/{id}/sync (200 {staged, duplicates, unrecognized}; 409 needs_reconsent; uniform 404); the email-poll scheduled job
Email ingestion: merchant suggestions (app EMAIL-5)	EMAIL-05 + Api.Tests (App/) (MerchantMatcherTests) + Api.Tests (MerchantMappingSliceTests incl. the race, VoucherStagingSliceTests suggestion case, ReviewEndpointTests) + Ui.Tests (MerchantMappingsPageTests)	GET/POST /api/merchant-mappings, PUT/DELETE …/{id} (400 invalid_request; 409 mapping_exists; uniform 404)
Email ingestion: review queue + confirm (app EMAIL-6)	EMAIL-06 + Api.Tests (PendingVoucherSliceTests incl. the two-context concurrency proof, ReviewEndpointTests) + Ui.Tests (ReviewPageTests, ReviewBadgeTests)	GET /api/pending-vouchers (+ /count), POST …/{id}/confirm (200 {transaction_id, month_id, amount_crc, amount_usd, remembered}; 400 invalid_request / exchange_rate_unavailable; 409 not_pending), POST …/{id}/discard (204; 409 not_pending); uniform 404
Emails / branding	MAIL-01..04, I18N-04	(SMTP via Mailpit)
Tenant isolation / auth guards	SEC-01..05	(all [Authorize] endpoints; write-stamping + reuse detection are automated)
Platform health / readiness	SMK-07	GET /health, GET /health/ready
Transactional email delivery	(all email cases)	async via the outbox dispatcher (OutboxMessages)
Billing — checkout/portal/webhook + billing page	**BILL-01/02** (§10c, E2E BillingJourneyTests) + **DSK-11 / AND-11** (native refresh-on-return — NATIVE-4) + Api.Tests (Billing*/Entitlement* tests)	POST /api/billing/checkout, …/portal, …/webhook
Billing — quotas (BILLING-5)	**HH-14** (seat limit blocks invite -> 402 upgrade message) + Api.Tests (QuotaServiceTests)	seats (members + pending invites vs Plan.SeatLimit) enforced on POST /api/household/invitations -> 402 seat_limit_reached; metered usage via IQuotaService.TryConsumeAsync (monthly UsageCounter). Limits in PlanCatalog (null = unlimited).
Billing — trial/dunning (BILLING-6)	covered by Api.Tests (BillingWebhookHandlerTests, SubscriptionLapseSweepJobTests); manual via Stripe test triggers	webhook transition into active/trialing from nothing or a lapsed state -> owner **"Subscription active"** notification (billing.activated, plan + renewal date) once — a renewal or a trial converting is silent; transition into past_due/canceled -> owner **notification** (in-app bell + outbox email, NOTIFY) once; SubscriptionLapseSweepJob (6h) nudges the owner once when a paid period lapses without a webhook (LapseNotifiedAt). Verify with stripe trigger invoice.payment_failed (test mode) -> owner sees a billing notification in the bell.
Billing — dissolve cleanup (BILLING-7)	covered by Api.Tests (BillingDissolveTests)	on tenant dissolve, BillingDataContributor wipes the Subscription projection **and** enqueues a "billing.cancel" outbox message -> IBillingProvider.CancelSubscriptionAsync (a deleted tenant stops being billed). HasDataAsync=false (billing never blocks leaving); export gains a billing section (plan/status/period, no Stripe ids). Manual (Stripe test mode): subscribe a throwaway tenant, delete the account, confirm the Stripe subscription is canceled.
Feature area	**Test cases**	**Key API endpoints**
Public API + API keys (PUBAPI, **config-gated off**)	**QA-API-01..04** (curl/Postman) + Api.Tests (ApiKeyServiceTests, RateLimitingTests); boot-verified on/off	PublicApi:Enabled toggles it. Owner-only /api/apikeys (create -> raw pk_… once, list, revoke; Permission.ManageApiKeys); API-key auth scheme mints a tenant_id-scoped principal; demo /api/public/whoami (read scope) +

Feature area	Test cases	Key API endpoints
		`/api/public/echo` (write scope) via `.RequireApiScope`. **PUBAPI-2:** per-key rate limit (60/min, isolated per key -> 429) + a leak-free public OpenAPI doc at `/api/public/openapi.json` (only the public routes). **Off (default) => routes 404.** Manual: `PublicApi__Enabled=true`, mint a key, `curl -H "X-Api-Key: pk_…" /api/public/whoami`; fetch `/api/public/openapi.json`.
Outbound webhooks (HOOKS, **config-gated off**)	**QA-API-01, 05, 06** (curl/webhook.site) + `Api.Tests` (`WebhookSubscriptionServiceTests`, `WebhookDeliveryTests`, `WebhookDeliveryLogTests`) + `Api.Tests` (App/) (`WebhookSignatureTests`); boot-verified on/off	`Webhooks:Enabled` toggles it. Owner-only `/api/webhooks` (register -> signing secret `whsec_…` once, list, delete, **send test**; `Permission.ManageWebhooks`). `IWebhookPublisher.PublishAsync` fans out to matching active subs -> one `"webhook"` **outbox** message each -> signed POST (`X-Webhook-Signature`), retry/dead-letter via the outbox. **HOOKS-2:** a delivery log (`GET /api/webhooks/{id}/deliveries` — one row per attempt, success/status/error) + **replay** (`POST /api/webhooks/deliveries/{id}/replay` — re-enqueue the exact payload). **Off (default) => routes 404.** Manual: `Webhooks__Enabled=true`, register a receiver (e.g. a webhook.site URL), hit **send test**, view deliveries, replay one.
Pre-launch gates (GATES, **both deployment config**)	**QA-GATE-01..06** (§14c) + `Api.Tests` (`BillingGateTests`, `SignupGateTests`, `SignupRefusalSurfacingTests`, `ConfigPostureTests`) + `Ui.Tests` (`BillingGateUiTests`, `SeatLimitCopyTests`, `SignupRefusedCopyTests`)	`Billing:Enabled` off (default) removes the billing controllers from the application model, so `GET /api/billing`, `POST …/checkout`, `…/portal` and `…/webhook` all **404** and every tenant resolves Free; the client reads `GET /api/features` (anonymous) to hide the link and refuse `/billing`, and the seat-limit copy drops the upgrade pitch. `Signup:AllowedEmails` / `Signup:AllowedDomains` (empty = open) gate account **creation** at `UserService.CreateUserWithTenantAsync` — refusal is **403** `signup_not_allowed` on `POST /api/auth/otp/verify` and `?error=signup_not_allowed` on the OAuth / magic-link redirects. An invitation admits its addressee only when that invitation's tenant **owner** is green-listed. ADR-027.
v4 audit — adversarial (§14d)	**ADV-25..35** (all remediated in v4 B3–B7 — each names the task that fixed it)	accept-path dissolve, outbox erasure, logout/grace, impersonation expiry, webhook redirects + error codes, billing-off admin comp, expired-invite seats, native bearer scope, exported-log PII
Audit log (API-only)	covered by `Api.Tests` (`AuditLogTests`)	append-only `IAuditLog` + interceptor
RBAC roles (admin tier)	HH-09/10/11/12 (web roster promote/demote + admin capability/limits); `Api.Tests` (`RolePermissionsTests`, `PermissionServiceTests`, `MemberRoleManagementTests`)	`PUT /api/household/members/{id}/role` (owner-only; admin<->member, owner via transfer only); permission seam gates tenant writes
File storage (API-only)	covered by `Api.Tests` (`LocalDiskFileStorageTests`, `FileDownloadTokenizerTests`, `FilesControllerTests`, `S3FileStorageMinioTests` [real MinIO], `FileStorageRegistrationTests`)	`IFileStorage` (tenant-scoped keys; local disk / S3-compatible — AWS/MinIO/R2/B2, config-gated); local signed `GET /api/files/{token}` (expiring, single-key, tenant-checked -> 404 on any failure); S3 native presigned URLs
GDPR data export	**HH-13** (owner Household -> Data -> download, E2E `GdprExportJourneyTests`) + **DSK-10 / AND-10** (native share — NATIVE-3) + `Api.Tests` (`TenantExportTests`)	`POST /api/household/export` (owner-only `ExportData` -> 403 else; JSON bundle via `IFileStorage`, signed URL; secret-free, tenant-scoped, audited)
GDPR account erasure	**SET-07** (Settings -> Danger zone) + `Api.Tests` (`AccountErasureTests`)	`DELETE /api/auth/me` (wipes identity/PII in one tx; owner-with-members -> 400, solo owner -> 409 without `confirm_dissolve`; member removed not re-homed; audited; audit trail survives)

Feature area	Test cases	Key API endpoints
MFA / TOTP	**MFA-01..05**, **DSK-12 / AND-12** (native) (Settings enroll/QR/confirm/recovery + disable; step-up on OTP, OAuth/magic-link, **and** native logins) + `Api.Tests` (`MfaServiceTests`, `MfaChallengeServiceTests`, `MfaLoginServiceTests`)	`GET|POST /api/auth/mfa[/enroll|/confirm|/disable]` (enroll/manage; secret encrypted, hashed single-use recovery codes) + **login step-up** `POST /api/auth/mfa/verify` (MFA-on logins get a signed challenge instead of a session; verify a TOTP/recovery code to complete). **Every sign-in path enforces it** (web + native): OTP returns the challenge as JSON; OAuth callback + magic-link redirect to `/login?mfa=<challenge>`; native OTP/OAuth-exchange return the challenge in the body and the MAUI client steps up in-app.
In-app notifications	**NOTIF-01..04**, **DSK-13** (header bell: list/unread-count/mark-read/delete/clear; Settings delivery-preference switches) + `Api.Tests` (`NotificationServiceTests`, `NotificationFanOutTests`)	`GET /api/notifications` (+ `?before=&limit=`), `/unread-count`, `POST /{id}/read`, `/read-all`, `DELETE /{id}`, `DELETE /api/notifications?read=true|false` (scope REQUIRED — read-only vs all; omitted -> 400), and `GET|PUT /api/notifications/preferences` — **per-user** (scoped to the caller). `NotifyAsync` fans out to in-app + email (outbox-backed) per prefs (default both on).
Admin back-office	**ADMIN-01..06**, **DSK-14** (native spot) (staff `/admin` console: tenant list/detail + impersonate w/ banner + stop; targeted/broadcast announce; plan comp/revert) + `Api.Tests` (`PlatformStaffServiceTests`, `AdminControllerTests`)	`GET /api/admin/me` (staff probe, 200 `{is_staff}` for any caller — drives the nav/gate), `GET /api/admin/tenants` (+ `/{id}` — returns `plan_key` + `provider_managed`), `POST /api/admin/impersonate/{userId}`, `POST /api/admin/tenants/{id}/announce` (optional `user_ids[]` subset, intersected with membership), `POST /api/admin/announce-all` (202; outbox fan-out to **every** user), `PUT|DELETE /api/admin/tenants/{id}/subscription` (comp/revert; 409 only for a LIVE provider sub — canceled Stripe-backed subs are comp-able) — **platform-staff only** (config `Admin:StaffEmails`; non-staff -> 403). Detail enters the target tenant (filter never loosened); impersonation returns a **short-lived, non-refreshable** token with an `impersonated_by` claim, **audited in the target's tenant**.

Adversarial & tenant-isolation (§14a, QA-ADV-*) — v3-audit hardening probes. **Rows tagged (!) v3 **were authored against then-broken behaviour and sat** Blocked **until their finding landed;** every tagged finding is fixed **(v3 remediation, PRs #147–#191), so ALL rows now expect** Pass**.

Probe (finding)	Test case(s)	Key API endpoint(s) / surface
Cross-tenant read/export/erase (RLS-2/4)	ADV-01	`GET /api/household`, `POST /api/household/export`, `DELETE /api/household/members/{id}`, `POST|DELETE /api/notifications/{id}[/read]` (foreign id -> 404/403)
Cross-tenant isolation, newer tables (LB-TEN-2/RLS-8)	ADV-02	`GET /api/webhooks/{id}/deliveries`, `POST /api/webhooks/deliveries/{id}/replay`, `DELETE /api/apikeys/{id}` (foreign id -> 404)
Export completeness, secret-free (**(!) v3** LB-TEN-1)	ADV-03	`POST /api/household/export` (must cover api-keys/webhooks/usage, no hashes/`whsec_…`)
Dissolve/erasure cleanup (**(!) v3** LB-TEN-1)	ADV-04	dissolve/`DELETE /api/auth/me` -> 0 rows in `ApiKey`/`WebhookSubscription`/`WebhookDelivery`/`UsageCounter`
Impersonation write attribution (**(!) v3** LB-ADM-1)	ADV-05	`POST /api/admin/impersonate/{id}` then `PUT /api/household`, `POST /api/notifications/{id}/read` (audit `impersonated_by`)
Impersonation ≠ staff ladder (**(!) v3** ADM-2)	ADV-06	impersonation token vs `POST /api/admin/impersonate/{x}`, `PUT /api/admin/tenants/{id}/subscription`, `DELETE /api/admin/users/{x}/mfa`, `POST /api/admin/announce-all` (-> 403)
Impersonation role ceiling (TB-ADM-3)	ADV-07	member impersonation vs `POST /api/household/transfer-ownership`, `PUT /api/household/members/{id}/role` (-> 403)

Probe (finding)	Test case(s)	Key API endpoint(s) / surface
Pref bleed: impersonation + shared device (**(!) v3** partial, ADM-8/9, LB-UI-4/5)	ADV-08	`GET /api/auth/me` prefs; localStorage theme/locale bootstrap across accounts
Security notice bypasses prefs (**(!) v3** ADM-1)	ADV-09	`PUT /api/notifications/preferences` (both off) + `DELETE /api/admin/users/{id}/mfa` -> `security.mfa_reset` in-app + email
Per-user MFA lockout (**(!) v3** ADM-3)	ADV-10	`POST /api/auth/mfa/verify` (cumulative cap, not just per-IP 429)
Recovery code single-use (TB-AUTH-6)	ADV-11	`POST /api/auth/mfa/verify` (recovery code burned on first use)
Webhook replay/order/same-second idempotency (LB-BILL-1)	ADV-12	`POST /api/billing/webhook` (dup EventId no-op; same-second created->active applies)
No false dunning on first bad webhook (**(!) v3** LB-BILL-4)	ADV-13	`POST /api/billing/webhook` first-ever `past_due`/`canceled` -> no owner notification
Comp/revert a churned sub (**(!) v3** ADM-5)	ADV-14	`PUT|DELETE /api/admin/tenants/{id}/subscription` (canceled sub should be comp-able, not stuck 409)
Concurrent last-seat accept (TB-BILL-19/BILLING-9)	ADV-15	`POST /api/household/invitations/accept` (one 200, one 402 `seat_limit_reached`)
Magic-link/OTP double-redemption (LB-AUTH-3)	ADV-16	`GET /api/auth/magic-link/verify`, `POST /api/auth/otp/verify` (exactly one session)
Rotated refresh-token replay revokes family (SEC-05 promoted)	ADV-17	`POST /api/auth/refresh` (reuse past the 60 s grace window -> 401 + all sessions revoked; within it, successor live -> 200, nothing revoked — once; a third presentation -> 401 + revoke-all)
Locale-reload preserves deep-link (**(!) v3** UX-1/LB-UI-1/2)	ADV-18 (E2E `LocaleMismatchJoinTests`)	`/join?token=…` under a PREFS-1 locale-mismatch reload
No pref revert after soft sign-in (UX-3/4)	ADV-19	OTP soft-nav sign-in reconcile (`theme`/`locale` claims)
"Clear read" spares unread (LB-UI-10)	ADV-20	`DELETE /api/notifications?read=true` vs `?read=false`; omitted scope -> 400 `scope_required`
Security/cache headers on single-origin (**(!) v3** DEP-2/3)	ADV-21	`curl -I /` + `/_framework/*` (HSTS/nosniff/CSP/Referrer-Policy; cache-control)
Forged XFF ≠ rate-limit bypass (DEP-1/ADM-10)	ADV-22	`POST /api/auth/otp/send` w/ rotating `X-Forwarded-For` (trusted-proxy only)
Release native build HTTPS base URL (**(!) v3** NAT-3)	ADV-23	Release AAB/MSIX base URL + Android network-security-config (no cleartext localhost)
Loopback OAuth state binding (NAT-10)	ADV-24	desktop loopback callback rejects mismatched `state`

Per-client coverage: Web = full (all suites). Desktop = DSK-01..15 (auth + per-feature parity). Android = AND-01..15 (auth + per-feature parity incl. hardware back, share sheet, OAuth kill drill). iOS = IOS-01..04 and macCatalyst = MAC-01..03 (first-run smoke — first passed 2026-07-06; needs a Mac). Magic link is **web-only** by design; the §13c checklist is the per-release native subset.

Automated (E2E CI): the following manual cases have an equivalent Playwright/NUnit journey in `tests/E2E.Tests`, run on every push by the `e2e` job (`.github/workflows/ci.yml`) against a booted Postgres + Mailpit + API + Web stack — so they are continuously regression-guarded on **Web**:

Manual case	E2E test
QA-SMK-01 (OTP sign-in happy path)	`AuthFlowTests.Otp_SignIn_LandsInTheApp` (+ `Login_Page_Renders`)
QA-SMK-03 (sign out)	`AuthFlowTests.SignOut_ReturnsToLogin`
QA-AUTH-09 (email-format validation)	`AuthFlowTests.Invalid_Email_IsRejected_NoCodeStep`
QA-MFA-01 (enable TOTP)	`MfaJourneyTests.Enroll_ThenStepUp_OnNextSignIn` (enroll leg)
QA-MFA-02 (step-up enforced at sign-in)	`MfaJourneyTests.Enroll_ThenStepUp_OnNextSignIn` + `StepUp_WithWrongCode_DoesNotSignIn`
QA-I18N-01 (switch language on login)	`I18nTests.Switching_Language_ReRendersTheUi`
QA-I18N-02 (language follows the user across browsers)	`I18nTests.LocaleChoice_FollowsTheUser_AcrossBrowsers`
QA-SET-08 (dark mode applies/persists/follows, incl. Auto propagation)	`ThemeJourneyTests.ThemeChoice_AppliesLive_PersistsLocally_AndFollowsTheUser`

Manual case	E2E test
QA-INV-10 (accept refused after a downgrade — seat re-check)	`SeatQuotaJourneyTests.Accepting_An_Invite_After_A_Downgrade_Shows_The_HouseholdFull_State`
QA-AUTH-01/05 (magic link happy + single-use)	`MagicLinkJourneyTests`
QA-HH-02/03/05/07/08 (rename, invite/join, leave, dissolve, delete account)	`MembershipLifecycleTests`
QA-HH-09..12 (roster: promote/demote/remove/owner-protection)	`RosterJourneyTests`
QA-HH-13 (data export download)	`GdprExportJourneyTests`
QA-INV-01/02/08 (invite create/accept/regenerate)	`MembershipLifecycleTests` (+ invalid-code inline error)
QA-NOTIF-01..03 (bell list/unread/mark-read via announcements)	`NotificationJourneyTests` + `AnnouncementJourneyTests`
QA-ADMIN-01/04 (staff console gate, announce)	`AnnouncementJourneyTests`
QA-BILL-01/02 (billing page + fake-provider upgrade loop)	`BillingJourneyTests`
QA-ADV-18 (locale-mismatch × invite acceptance)	`LocaleMismatchJoinTests`
QA-DSK-01 (desktop boot)	the `native-smoke-windows` job boots the REAL Windows exe as a process-alive + provider-probe canary (WebView2 150 strips CDP under elevation — PRs #170/#171); the OTP journey is CI-driven on Android only. `NativeSmokeTests` remains for local non-elevated runs
QA-AND-01 (Android OTP sign-in)	`tests/native-smoke-android/smoke.js` — the `native-smoke-android` job boots a real emulator and drives the app via playwright-core's `_android` module

The native smoke jobs run from *Run workflow* -> `devices` (ADR-031) — they are boot-and-sign-in canaries, not the per-feature native regression, which stays manual (§12–13b). All other cases remain manual-only or API-test-backed as noted per row.

16. Sign-off sheet

Record one row per executed case. Build = API/web commit SHA (`git rev-parse --short HEAD`).

Case ID	Client	Result (P/F/Blocked/N-A)	Tester	Build (SHA)	Date	Notes / defect link
QA-SMK-01	Web					
QA-SMK-02	Web					
QA-SMK-03	Web					
QA-SMK-04	Web					
QA-SMK-05	Web					
QA-SMK-06	Web					
QA-SMK-07	Platform					
QA-AUTH-01	Web					
QA-AUTH-02	Web					
QA-AUTH-03	Web					
QA-AUTH-04	Web					
QA-AUTH-11	Web					
QA-AUTH-05	Web					
QA-AUTH-06	Web					
QA-AUTH-07	Web					
QA-AUTH-08	Web					
QA-AUTH-09	Web					
QA-AUTH-10	Web					

Case ID	Client	Result (P/F/Blocked/N-A)	Tester	Build (SHA)	Date	Notes / defect link
QA-ONB-01	Web					
QA-ONB-02	Web					
QA-HH-01	Web					
QA-HH-02	Web					
QA-HH-03	Web					
QA-HH-04	Web					
QA-HH-05	Web					
QA-HH-06	Web					
QA-HH-07	Web					
QA-HH-08	Web					
QA-HH-09	Web					
QA-HH-10	Web					
QA-HH-11	Web					
QA-HH-12	Web					
QA-HH-13	Web					
QA-HH-14	Web					
QA-INV-01	Web					
QA-INV-02	Web					
QA-INV-03	Web					
QA-INV-04	Web					
QA-INV-05	Web					
QA-INV-06	Web					
QA-INV-07	Web					
QA-INV-08	Web					
QA-INV-09	Web					
QA-INV-10	Web					
QA-SET-01	Web					
QA-SET-02	Web					
QA-SET-03	Web					
QA-SET-04	Web					
QA-SET-05	Web					
QA-SET-06	Web					
QA-SET-07	Web					
QA-SET-08	Web					
QA-SET-10	Web + Android					
QA-SET-11	Web + Android					
QA-MFA-01	Web					
QA-MFA-02	Web					
QA-MFA-03	Web					
QA-MFA-04	Web					
QA-MFA-05	Desktop/Android					
QA-NOTIF-01	Web					
QA-NOTIF-02	Web					
QA-NOTIF-04	Web					
QA-NOTIF-03	Web					

Case ID	Client	Result (P/F/Blocked/N-A)	Tester	Build (SHA)	Date	Notes / defect link
QA-I18N-01	Web					
QA-I18N-02	Web					
QA-I18N-03	Web					
QA-I18N-04	Web					
QA-ADMIN-01	Web					
QA-ADMIN-02	Web					
QA-ADMIN-03	Web					
QA-ADMIN-04	Web					
QA-ADMIN-05	Web					
QA-ADMIN-06	Web					
QA-ADMIN-07	Web					
QA-BILL-01	Web					
QA-BILL-02	Web					
QA-BUD-01	Web					
QA-BUD-02	Web					
QA-BUD-03	Web/API					
QA-CAT-01	Web					
QA-CAT-02	Web					
QA-CAT-03	Web					
QA-CAT-04	Web/API					
QA-CAT-05	Web/API					
QA-CAT-06	Web/API					
QA-CAT-07	Web/API					
QA-CAT-08	Web/API					
QA-FX-01	Web/API					
QA-FX-02	Web/API					
QA-ENV-01	Web/API					
QA-ENV-02	Web/API					
QA-INC-01	Web/API					
QA-INC-02	Web/API					
QA-INC-03	API/DB					
QA-INC-04	Web/API					
QA-LED-01	Web/API					
QA-LED-02	Web/API					
QA-LED-03	Web/API					
QA-LED-04	Web/API					
QA-LED-05	Web/API					
QA-LED-06	Web/API					
QA-LED-07	Web/API					
QA-LED-08	Web/API					
QA-LED-09	Web/API					
QA-EMAIL-07	Web/API					
QA-EXP-01	Web/API					
QA-EXP-02	Web/API					
QA-EXP-03	Web/API					

Case ID	Client	Result (P/F/Blocked/N-A)	Tester	Build (SHA)	Date	Notes / defect link
QA-DASH-01	Web/API					
QA-DASH-02	Web/API					
QA-DASH-03	Web/API					
QA-DASH-04	Web					
QA-DASH-05	Web					
QA-REP-01	Web/API					
QA-REP-02	Web/API					
QA-REP-03	Web					
QA-REP-04	Web					
QA-REP-05	Web/API					
QA-REP-06	Web/API					
QA-REP-07	Web/API					
QA-EMAIL-01	Web/API					
QA-EMAIL-02	Web					
QA-EMAIL-03	Web/API					
QA-EMAIL-04	Web/API					
QA-EMAIL-05	Web/API					
QA-EMAIL-06	Web/API					
QA-MAIL-01	Web					
QA-MAIL-02	Web					
QA-MAIL-03	Web					
QA-MAIL-04	Web					
QA-DSK-01	Web					
QA-DSK-02	Desktop					
QA-DSK-03	Desktop					
QA-DSK-04	Desktop					
QA-DSK-05	Desktop					
QA-DSK-06	Desktop					
QA-DSK-07	Desktop					
QA-DSK-08	Desktop					
QA-DSK-09	Desktop					
QA-DSK-10	Desktop					
QA-DSK-11	Desktop					
QA-DSK-12	Desktop					
QA-DSK-13	Desktop					
QA-DSK-14	Desktop					
QA-DSK-15	Desktop					
QA-AND-01	Web					
QA-AND-02	Android					
QA-AND-03	Android					
QA-AND-04	Android					
QA-AND-05	Android					
QA-AND-06	Android					
QA-AND-07	Android					
QA-AND-08	Android					

Case ID	Client	Result (P/F/Blocked/N-A)	Tester	Build (SHA)	Date	Notes / defect link
QA-AND-09	Android					
QA-AND-10	Android					
QA-AND-11	Android					
QA-AND-12	Android					
QA-AND-13	Android					
QA-AND-14	Android					
QA-AND-15	Android					
QA-IOS-01	iOS					
QA-IOS-02	iOS					
QA-IOS-03	iOS					
QA-IOS-04	iOS					
QA-MAC-01	macCatalyst					
QA-MAC-02	macCatalyst					
QA-MAC-03	macCatalyst					
QA-SEC-01	Web					
QA-SEC-02	Web					
QA-SEC-03	Web					
QA-SEC-04	Desktop/Android					
QA-SEC-05	Web					
QA-API-01	curl					
QA-API-02	curl					
QA-API-03	curl/Postman					
QA-API-04	curl					
QA-API-05	curl					
QA-API-06	curl					
QA-GATE-01	Web + curl					
QA-GATE-02	Web					
QA-GATE-03	Web					
QA-GATE-04	Web					
QA-GATE-05	Web					
QA-GATE-06	Web					
…						

§14a adversarial / tenant-isolation (QA-ADV-*). **All rows are Not-run **(blank) until executed. The formerly pre-seeded** Blocked (known defect) **rows were reset when the v3 remediation completed (2026-07, PRs #147–#191) — their Notes record which defect each was blocked on, and every one of those cases now expects** Pass** on re-run.

Case ID	Client	Result (P/F/Blocked/N-A)	Tester	Build (SHA)	Date	Notes / defect link
QA-ADV-01	API					
QA-ADV-02	API					
QA-ADV-03	API					Was pre-seeded Blocked (LB-TEN-1 (export incomplete)) — fixed in v3; re-run
QA-ADV-04	API					Was pre-seeded Blocked (LB-TEN-1 (orphaned rows on dissolve)) — fixed in v3; re-run

Case ID	Client	Result (P/F/Blocked/N-A)	Tester	Build (SHA)	Date	Notes / defect link
QA-ADV-05	API					Was pre-seeded Blocked (LB-ADM-1 (impersonation write attribution)) — fixed in v3; re-run
QA-ADV-06	API					Was pre-seeded Blocked (ADM-2 (staff gate re-escalation)) — fixed in v3; re-run
QA-ADV-07	API					
QA-ADV-08	API/Web					Was pre-seeded Blocked (LB-UI-4/5 shared-device pref bleed) — fixed in v3 (ADM-9 sign-out clear); re-run both legs
QA-ADV-09	API					Was pre-seeded Blocked (ADM-1 (security notice suppressible by prefs)) — fixed in v3; re-run
QA-ADV-10	API					Was pre-seeded Blocked (ADM-3 (no per-user MFA lockout)) — fixed in v3; re-run
QA-ADV-11	Web					
QA-ADV-12	API					
QA-ADV-13	API					Was pre-seeded Blocked (LB-BILL-4 (false dunning on first bad webhook)) — fixed in v3; re-run
QA-ADV-14	API					Was pre-seeded Blocked (ADM-5 (comp stuck 409 on churned sub)) — fixed in v3; re-run
QA-ADV-15	Web					
QA-ADV-16	Web					
QA-ADV-17	API					
QA-ADV-18	Web					Was pre-seeded Blocked (UX-1/LB-UI-1/2 (locale reload drops /join deep-link)) — fixed in v3; re-run
QA-ADV-19	Web					
QA-ADV-20	Web					
QA-ADV-21	API					Was pre-seeded Blocked (DEP-2/3 (no security/cache headers)) — fixed in v3; re-run
QA-ADV-22	API					
QA-ADV-23	Desktop/Android					Was pre-seeded Blocked (NAT-3 (Release build cleartext localhost base URL)) — fixed in v3; re-run
QA-ADV-24	Desktop					
QA-ADV-25	API					
QA-ADV-26	API					
QA-ADV-27	API					
QA-ADV-28	API					
QA-ADV-29	Web					

Case ID	Client	Result (P/F/Blocked/N-A)	Tester	Build (SHA)	Date	Notes / defect link
QA-ADV-30	API					
QA-ADV-31	API					
QA-ADV-32	API					
QA-ADV-33	Web					
QA-ADV-34	Android/Desktop					
QA-ADV-35	Ops					
QA-DEP-01	Operator					
QA-DEP-02	Operator					
QA-DEP-03	Operator					
QA-DEP-04	Operator					
QA-SET-09	Web + Android					
QA-AND-16	Android					

Release gate (suggested): all • Smoke Smoke + all • Core Core cases Pass on Web; the §13c native checklist Pass on every platform being shipped (iOS/macCatalyst once those ship); no open Critical/High defects. • Edge Edge cases triaged (Pass or accepted-known-issue).

17. Notes for maintainers

- This plan is the manual counterpart to the automated `tests/E2E.Tests` (Playwright/NUnit) suite. That suite now covers the **OTP auth happy-path + guards** (`AuthFlowTests`), the **MFA enroll -> step-up** journey incl. the wrong-code negative (`MfaJourneyTests`), and the **language switch** (`I18nTests`) — all over the page objects in `Pages/`, reading codes from Mailpit via the `Mailpit` REST client, and **run in CI** by the `e2e` job (`.github/workflows/ci.yml`, Web only). See `tests/E2E.Tests/README.md` for the run procedure (it documents the same Mailpit SMTP override noted in §1.1). The cases these journeys mirror are marked **Automated in CI** and listed in §15. The Gherkin blocks here are written to be lifted directly into new E2E scenarios — keep the two in sync as automation grows.
- When you add an app-specific domain feature on top of this platform, add a matching suite here and a row in the traceability matrix (§15) so "entire functionality" stays honest.
- `docs/FEATURES.md` describes the same JWT-based flows at the design level; this plan is their step-by-step verification. Keep the two in sync when behavior changes.
- **Updated 2026-06-22** for the security/quality remediation: OTP lockout is now **cumulative per email** and resend-proof (QA-AUTH-04); passwordless send/verify are **rate-limited** (QA-AUTH-11); the Settings **Unlink** now requires a fail-closed confirmation (QA-SET-04); and server-side hardening (write-stamping, refresh-reuse detection, fail-closed takeover guard) is captured as automated coverage (QA-SEC-05).
- **Updated 2026-06-23:** QA-AUTH-02 now documents the **tenant-gated same-email auto-link** rule (Microsoft trusted only on the `consumers` tenant; work/school + unknown providers fail closed — audit MITI-3); and QA-SEC-05 adds the **legacy refresh-cookie self-heal** as automated coverage (`CookieServiceTests`).
- **Updated 2026-06-26** for the platform-foundation work (JOBS/BILLING/OBS, ADR-006/007/008):

- **Transactional email is now delivered asynchronously** via the outbox dispatcher — a few-second delay, and the send request always succeeds (reliability moved to the background). Affects every email-based case; see the §1.1 and §11 notes. The E2E `AuthFlowTests` (which reads OTP codes from Mailpit) now traverses this async path — confirm it waits/polls for the email rather than assuming instant delivery.
- Added **API health/readiness** endpoints + smoke case **QA-SMK-07** (`/health`, `/health/ready`).
- The **billing API** (checkout/portal/webhook), the **append-only audit log**, and **OpenTelemetry** telemetry are API-/operational-level with **no client UI** — covered by `tests/Api.Tests`, E2E pending; manual cases will follow when UI exists (see §2 + §15).
- **Updated 2026-06-30** for RBAC (ADR-009): the tenant role model gains an **`admin` **tier behind a permission seam (owner > admin > member). RBAC-1 added the seam (no behavior change); RBAC-2 added the** owner-only role-change endpoint** (`PUT /api/household/members/{id}/role`, admin<->member; owner is conferred only via transfer) and hardened member-removal so the **owner can't be removed**. This was API-only at first; **RBAC-3 added the web UI** — the Household roster now has owner-only **Make admin / Make member** controls, and the page is admin-aware (admin can rename + invite/remove members, but sees no role/transfer/dissolve controls). New web cases **QA-HH-09..12**; §7 intro updated for the three-tier model. API coverage stays automated (`tests/Api.Tests`).
- **Updated 2026-06-30** for file storage (ADR-010): an `IFileStorage` seam (tenant-scoped keys, local-disk dev default / S3-compatible prod) with a signed, time-limited download endpoint `GET /api/files/{token}`. **API-only** (no UI consumer yet) — covered by `tests/Api.Tests` (`LocalDiskFileStorageTests`, `FileDownloadTokenizerTests`, `FilesControllerTests`); see §2 + §15. Manual cases will follow when a feature (avatars/attachments) wires it to UI. FILES-3 added the **S3-compatible** backend (AWS/MinIO/R2/B2, config-gated by `Storage:S3:Bucket`), tested against a real **MinIO** container (`S3FileStorageMinioTests`); prod config is documented in `.env.example`. **This completes Wave 1** (RBAC + File storage).
- **Updated 2026-07-01** for GDPR data export (ADR-011, Wave 2): owner-only `POST /api/household/export` assembles the tenant's data (core + each feature's contributor section) into a JSON bundle stored via file storage and returns a **signed download URL**; **secret-free** (no token hashes), tenant-scoped, audited. **API-only** (no UI button yet) — covered by `Api.Tests` (`TenantExportTests`); see §2 + §15.
- **Updated 2026-07-01** for GDPR account erasure (ADR-011): `DELETE /api/auth/me` ("delete my account") wipes the caller's identity/PII (`User`/`UserLogin`/`RefreshToken`/`LoginToken`) in one transaction, single-owner-safe (owner-with-members -> transfer first; solo owner -> confirm to dissolve; member removed, not re-homed), audited (the audit trail survives — actor ids, never PII). **API-only** — covered by `Api.Tests` (`AccountErasureTests`). **GDPR epic complete (export + erasure).**
- **Updated 2026-07-01** for MFA enrollment (ADR-012, Wave 2): authenticator-app **TOTP** (Otp.NET) — `/api/auth/mfa/*` (enroll -> provisioning URI/QR; confirm with a code -> enable + one-time recovery codes; disable; status). Secret **encrypted at rest** (Data Protection); recovery codes **hashed + single-use**; MFA rows wiped by account erasure. **API-only** (MFA-1) — covered by `Api.Tests` (`MfaServiceTests`). **MFA-2 (login step-up):** an MFA-on login returns a **signed challenge** instead of a session; `POST /api/auth/mfa/verify` completes it with a TOTP/recovery code. Wired into **OTP-verify + native-exchange**; the OAuth/magic-link **redirect** paths route to a client `/mfa` page (needs the MFA UI) and are a flagged **follow-up** — no platform-web user can enable MFA via those paths today (no enrollment UI). Covered by `MfaChallengeServiceTests` + `MfaLoginServiceTests`. **This completes Wave 2** (GDPR + MFA).
- **Updated 2026-07-01** for in-app notifications (ADR-013, Wave 3): a **per-user** notification center — `GET /api/notifications` (paginated), `/unread-count`, `POST /{id}/read`, `/read-all` — scoped to the caller (never cross-user); features produce via `NotifyAsync` (staged in-app row). Notifications are user PII (wiped by account erasure). **API-only** — covered by `Api.Tests` (`NotificationServiceTests`). **NOTIFY-2:** per-user **delivery preferences** (`GET|PUT /api/notifications/preferences`, default both on) + `NotifyAsync` **fan-out** — in-app row + email via the outbox-backed `IEmailSender`, gated by prefs. Covered by `NotificationFanOutTests`. Bell-menu UI is an API-first follow-up. **NOTIFY epic + Wave 3's first item complete.**
- **Updated 2026-07-01** for the platform-staff admin surface (ADR-014, Wave 3): `GET /api/admin/tenants` (+ `/{id}`) — **staff-only** (config allowlist `Admin:StaffEmails`, out-of-band; non-staff -> 403). Read-only cross-tenant inspection; the per-tenant detail **enters the target tenant** (the global filter is never loosened) and is **audited in that tenant**. **API-only** — covered by `Api.Tests` (`PlatformStaffServiceTests`, `AdminControllerTests`).
- **Updated 2026-07-01** for admin **impersonation** (ADR-014, ADMIN-2): `POST /api/admin/impersonate/{userId}` (staff-only) returns a **short-lived (15-min), non-refreshable** access token carrying the target's identity + an `impersonated_by` claim; **loudly audited in the target's tenant**. Unknown target -> 404. Covered by `AdminControllerTests`. **This completes the ADMIN epic — and the planned platform** (nine epics, ADRs 006–014).

- **Updated 2026-07-01** — UI pass (putting a face on the API-first surfaces). **UI-1 (GDPR):** the owner **Data -> Download household data** button on Household (**QA-HH-13**) and **Settings -> Danger zone -> Delete my account** (**QA-SET-07**) — wired to `POST /api/household/export` and `DELETE /api/auth/me` (single-owner-safe, with the dissolve second-confirm). EN/ES localized.
- **Updated 2026-07-01** — **UI-2 (MFA):** a **Two-factor authentication** card in Settings (`MfaCard` component) — enroll (`POST /api/auth/mfa/enroll`) renders a **client-side QR** of the `otpauth://` URI (vendored `qrcode-generator`, MIT, in `Shared.Ui/wwwroot/js/`; the secret never leaves the browser) alongside a manual key, confirm (`/confirm`) reveals one-time **recovery codes**, and **disable** (`/disable`) needs a live code. The **Login** page now handles the OTP-verify `mfa_required` response with a **step-up code prompt** -> `POST /api/auth/mfa/verify` (TOTP or recovery code) -> `/auth-callback`. **QA-MFA-01..03**; EN/ES localized. Native OTP + OAuth/magic-link step-up remain follow-ups (web-first).
- **Updated 2026-07-01** — **UI-3 (Notifications):** a **header bell** (`NotificationBell` component) — unread-count badge (polled ~60s), a dropdown list (newest-first, unread dot + relative time), click-to-mark-read and **Mark all read** via `GET /api/notifications[/unread-count]`, `POST /{id}/read`, `/read-all`. A **Notifications** card in Settings (`NotificationPrefsCard`) with **In-app/Email** switches (optimistic save, reverts on error) via `GET|PUT /api/notifications/preferences`. **QA-NOTIF-01..03**; EN/ES localized. (No built-in producer — items appear once a feature calls `NotifyAsync`.)
- **Updated 2026-07-01** — **UI-4 (Admin console):** a staff-only `/admin` page (`AdminConsole`) — tenant list + detail (members/subscription/audit count) and **Sign in as** (impersonation). Staff detection uses a new **non-gating** probe `GET /api/admin/me` (`{is_staff}` for any authenticated caller — the only API addition in the UI pass; the allowlist stays config-only, actions still 403 for non-staff), so the header shows an **Admin** link only to staff. Impersonation swaps the in-memory session to the short-lived token (`AuthService.BeginImpersonation`), pins an **impersonation banner** in `MainLayout` (reads the `impersonated_by` claim), and **Stop impersonating** restores the staff identity from the refresh cookie; a reload also reverts (the token is non-refreshable). **QA-ADMIN-01..03**; EN/ES localized. **This completes the UI pass (UI-1..4).**
- **Updated 2026-07-01** — **MFA-3 (redirect step-up, security fix):** OAuth callback and magic-link verify now route through `IMfaLoginService.CompleteOrChallengeAsync` (like the OTP path) instead of issuing a session directly — closing the gap where an MFA-enabled user could sign in via Google/ magic link and **skip the second factor**. When MFA is on, the server redirects to `/login?mfa=<challenge>` (a signed, single-use, 5-min Data-Protection token — no secret), and `Login.razor` reuses the UI-2 step-up prompt -> `POST /api/auth/mfa/verify` -> `/auth-callback`. Property covered by `MfaLoginServiceTests` (MFA-on -> challenge, never a session); **QA-MFA-04**. The dead `IssueRefreshCookieAsync` helper was removed.
- **Updated 2026-07-01** — **MFA-4 (native step-up):** the MAUI client now handles the `{mfa_required, challenge}` response on the native **OTP** and **OAuth-exchange** paths. `AuthService.VerifyOtpAsync`/`SignInWithOAuthAsync` now return a `SignInResult` (Success / Failed / MfaRequired+challenge) and a new `VerifyMfaAsync` completes the step-up (tokens in the body, native transport); `Login.razor`'s native branches reuse the same code prompt. Client-only — no API change; build-verified (native is E2E/manual per the platform's MOBILE_TESTING); **QA-MFA-05**. **MFA is now enforced on every sign-in path, web and native — the epic is fully closed, no open gaps.**
- **Updated 2026-07-01** — **BILLING-5 (quotas):** `IQuotaService` adds plan **seat** limits (members + pending invites vs `Plan.SeatLimit`, enforced on the invite path -> **402 `seat_limit_reached`, with an upgrade message in the Household invite UI) and** metered usage** (`TryConsumeAsync` against a monthly, self-resetting `UsageCounter`). Limits are `PlanCatalog` data — `null`/absent = unlimited, so it's inert until set (platform shipped example caps Free 3/3, Pro 10/100; Free seats were raised to 5 by GATES-1). New entity + migration `AddUsageCounter`. Covered by `QuotaServiceTests` (10 cases); **QA-HH-14**; EN/ES. Only **BILLING-6** (trial/dunning) and a billing-dissolve contributor remain from the BILLING epic.
- **Updated 2026-07-01** — **BILLING-6 (trial/dunning):** the owner-facing reaction to the subscription lifecycle. `IBillingNotifier` notifies the tenant **owner** via the notification center (in-app bell + outbox email). The **webhook** notifies once on a transition into `past_due`/`canceled` (no spam; inbox dedups). A **`SubscriptionLapseSweepJob`** (6h) nudges once when a paid period lapses without a webhook, recording `Subscription.LapseNotifiedAt` (migration `AddSubscriptionLapseNotifiedAt`) — Stripe stays source of truth, no fabricated status. Covered by `BillingWebhookHandlerTests` + `SubscriptionLapseSweepJobTests`; manual via `stripe trigger`. **The BILLING epic is now complete** (1–6); only optional follow-ups remain (advance trial nudge; billing-dissolve contributor).
- **Updated 2026-07-01** — **PUBAPI-1 (public API + API keys, config-gated OFF):** a programmatic surface for machines (the user reversed the earlier "no public API" stance). `ApiKey` (hash-only, `pk_…` revealed once; migration

AddApiKey); a second **API-key auth scheme** mints a tenant_id-scoped principal (so tenant isolation applies for free); owner-only /api/apikeys management (Permission.ManageApiKeys); demo /api/public/whoami (read) + /echo (write) gated by .RequireApiScope. **PublicApi:Enabled (default false) — strong gating: off => the scheme isn't added and the routes 404.** Covered by ApiKeyServiceTests (9); boot-verified on (401 without a key) and off (404). HOOKS (outbound webhooks) is the companion outbound half — next.

- **Updated 2026-07-01** — **HOOKS-1 (outbound webhooks, config-gated OFF):** the outbound integration half. WebhookSubscription (url + event types + **encrypted** signing secret, revealed once; migration AddWebhookSubscription); IWebhookPublisher.PublishAsync fans out to matching active subs -> one "webhook" **outbox** message each (durable, retried, atomic with the change); WebhookOutboxHandler signs (HMAC-SHA256, X-Webhook-Signature) + POSTs, throwing on non-2xx so the outbox retries/dead-letters. Owner-only /api/webhooks (Permission.ManageWebhooks) with a synchronous **send test**. **Webhooks:Enabled (default false) — off => routes 404.** Covered by WebhookSignatureTests (3) + WebhookSubscriptionServiceTests + WebhookDeliveryTests (11 in Webhooks/); boot-verified on (401) and off (404). **This completes the integration story (PUBAPI inbound + HOOKS outbound), both default-off.**
- **Updated 2026-07-01** — **PUBAPI-2 (hardening): per-key rate limiting** (RateLimiting.PublicApiPolicy partitions on the key id — 60/min, one key can't exhaust another's budget -> 429; RateLimitingTests proves per-key isolation) and a **leak-free public OpenAPI doc** (GET /api/public/openapi.json, anonymous, emits only the /api/public routes so the internal v1 surface is never exposed; boot-verified it serves in Production when enabled and 404s when off).
- **Updated 2026-07-01** — **HOOKS-2 (delivery log + replay):** a tenant-facing debug trail. WebhookDelivery records **one row per delivery attempt** (event, success, status/error, and the sent body; not ITenantScoped — written from both the tenant-less outbox dispatcher and the request-scoped send-test, read side filters by TenantId; migration AddWebhookDelivery). Owner routes GET /api/webhooks/{id}/deliveries + POST /api/webhooks/deliveries/{id}/replay (re-enqueue the exact stored payload, same event id). Covered by WebhookDeliveryLogTests. **Candidate HOOKS-3 (not built):** a Blazor management UI for webhooks/API keys.
- **Updated 2026-08-28** — **HOOKS-2 fix (send-test now records a delivery):** the synchronous POST /api/webhooks/{id}/test delivered inline but wrote **no** WebhookDelivery row, and the sample app fires no published events — so GET /api/webhooks/{id}/deliveries was always empty and replay had nothing to replay (QA-API-06 unrunnable). The send-test now records one row per attempt (success **and** failure) via IWebhookSubscriptionService.SendTestAsync, so the log doubles as the in-template debug trail and replay is testable. Response shape unchanged ({ delivered, status_code }, or { delivered:false, error:"delivery_failed" } on a transport error — internal detail stays in the row, GAP-3). New WebhookDeliveryLogTests (SendTest_RecordsDelivery_*).
- **Updated 2026-07-01** — **BILLING-7 (dissolve cleanup):** closed the one real gap — deleting a billing-enabled tenant left the Stripe subscription active (still charging). BillingDataContributor now wipes the Subscription projection on dissolve and **cancels the provider subscription** via a "billing.cancel" outbox message (BillingCancelOutboxHandler -> new idempotent IBillingProvider.CancelSubscriptionAsync) — out-of-band, not an external call inside the teardown tx. HasDataAsync=false so billing never blocks leaving; export gains a secret-free billing section. Covered by BillingDissolveTests (6). **Closes the BILLING epic (1–7).**
- **Updated 2026-07-01** — added **§14b — manual QA for the API surfaces (PUBAPI + HOOKS)**: curl/Postman cases (QA-API-01..06) for the config gate, minting/using API keys (scopes, tenant-scoping, rate limit), and registering webhooks (send-test, signature verification, delivery log, replay). These surfaces have **no web UI by design** (they're for machines), so this is the human-testable complement to the automated tests — the Postman path is one import of /api/public/openapi.json away. Referenced from the §15 PUBAPI/HOOKS rows and the §2 "no client UI" note.
- **Updated 2026-07-02** — **E2E-in-CI (v2 audit B8-5/B8-6):** the Playwright suite is now booted and run on every push (the e2e job in .github/workflows/ci.yml — Postgres + Mailpit + API + Web) and was expanded beyond the auth happy-path to the **MFA enroll -> step-up** journey (MfaJourneyTests, incl. a wrong-code negative) and the **login-page language switch** (I18nTests). Six manual cases now have a continuously-run Web equivalent and are marked **Automated in CI**: QA-SMK-01, QA-SMK-03, QA-AUTH-09, QA-MFA-01, QA-MFA-02, QA-I18N-01 (mapping table added under §15; how-to note in §2/§1 "How to use"). These stay in the manual plan for **Desktop/Android** (CI runs Web only) and area-change re-runs; human QA can spot-check them on Web rather than run them in full each cycle. data-testid hooks were added to MfaCard and LanguageSwitcher to keep the selectors stable.
- **Updated 2026-07-03** for NATIVE Wave 2 (ADR-018, the platform's NATIVE_PARITY): the parity audit's six gaps were fixed (join-by-code, culture persistence, export download/share, billing return-refresh, Android hardware back — plus **G7**, iOS/macCatalyst crashing at boot, found while writing this expansion) and this plan grew the per-feature

native coverage that verifies them on hardware: **QA-DSK-08..14**, **QA-AND-07..13**, the first-ever **iOS/macCatalyst smoke** (§13b, QA-IOS-01..04 + QA-MAC-01..03), and the **per-release native checklist** (§13c). The web halves of the fixes are already -automated (`Member_Joins_By_Pasting_The_Invite_Code`, `Owner_Downloads_The_Data_Export`); the OS-chrome halves (share sheets, hardware back, real focus-return, safe areas) are exactly what these manual cases exist for.

- **Updated 2026-07-06** — **first Apple run of §13b** (maintainer's MacBook Air M1, iOS 26.5 simulator + Mac Catalyst): **QA-IOS-01 PASS** (boots to login — validates the G7 fix on a real Apple runtime), **QA-IOS-02 PASS**, **QA-IOS-04 PASS** (first-ever exercise of the `ASWebAuthenticationSession` -> `perezosoft://auth` path; also verified on iPhone 17 Pro Max + iPad Air 11" simulators), **QA-MAC-01 PASS**, **QA-MAC-02 PASS** and the OAuth leg of QA-MAC-03 PASS. Remaining: the core-flows spot-checks (QA-IOS-03, rest of QA-MAC-03 — share sheet, language + restart persistence). The pass surfaced two platform gaps, fixed in the same PR as this entry: (1) macOS trust evaluation fails Brevo's SMTP TLS handshake ("incomplete certificate revocation check") -> new `Email:Smtp:CheckCertificateRevocation` setting, default **on**, dev-box opt-out documented in `.env.example` (`SmtpSettingsTests`); (2) sign-in on ad-hoc-signed Mac Catalyst Debug builds died storing the refresh token — MAUI SecureStorage needs the restricted `keychain-access-groups` entitlement (MissingEntitlement without it, SIGKILL at launch with it) -> store entitlement added to `Entitlements.plist` for signed builds, Debug builds swap to `Entitlements.Debug.plist` (unsandboxed) + a `DebugFileSessionStore` fallback (`MACCATALYST && DEBUG` only); SecureStorage must be re-verified under real signing at the downstream first native release (ADR-024; the platform's NEW_APP_GUIDE Phase 9).
- **Updated 2026-07-09** — first findings + features from the manual QA pass (`bugfix/qa-manual-pass`): (1) **rate-limit split** — passwordless *verify* endpoints got their own per-IP budget (attempt cap + headroom, default 10/min) so the cumulative-lockout 401 (QA-AUTH-04) surfaces before the 429 can mask it, and the login UI now shows a dedicated "Too many requests…" message on 429 (QA-AUTH-11 names the exact copy; §1.1 pacing note updated). (2) **MFA recovery codes fixed** — they were 88-char opaque tokens that overflowed the maxlength-14 inputs (unusable); now short `xxxxx-xxxxx` codes, matched case-/separator-insensitively (QA-MFA-01/03). (3) **Notification delete/clear** — per-row trash + "Clear read"/"Clear all" in the bell, backed by new per-user `DELETE /api/notifications` endpoints (new **QA-NOTIF-04**). (4) **Staff announce upgrades** — optional member targeting on the per-tenant announce (checkbox column -> `user_ids[]`) and a platform-wide **Announce to everyone** card backed by an outbox fan-out (`POST /api/admin/announce-all`, 202 queued) (QA-ADMIN-04 extended, new **QA-ADMIN-05**). (5) **Staff plan comp** — `PUT|DELETE /api/admin/tenants/{id}/subscription` + console buttons simulate a completed checkout (Pro) and revert to Free; refused 409 for Stripe-backed subs (new **QA-ADMIN-06**). Suite 117 -> **120** cases.
- **Updated 2026-07-10** — **THEME-1 (dark mode)**: per-user Light/Dark/System theme on Bootstrap's `data-bs-theme` — header + login switcher, pre-paint `theme.js` bootstrap (no flash), device persistence (`localStorage["app_theme"]`), server sync (`PUT /api/auth/theme`, `theme` JWT claim, cold-start reconcile like locale). New **QA-SET-08** (web, `ThemeJourneyTests`) + **QA-DSK-15** / **QA-AND-14** (native restart persistence — also verifies WebView localStorage survives a restart per platform). Suite 120 -> **123** cases.
- **Updated 2026-07-10** — **staff MFA reset (ADR-021 addendum, `feat/admin-mfa-reset`)**: a user who loses both the authenticator and the recovery codes was locked out permanently (self-serve disable demands a valid code; every sign-in path steps up). New staff-gated `DELETE /api/admin/users/{userId}/mfa` wipes `UserMfa` + recovery codes (no code required — out-of-band identity verification first), audited in the target's tenant (`admin.mfa.reset`) with the user notified in-app + email (`security.mfa_reset`); confirm-gated **Reset MFA** button on the admin member row (new **QA-ADMIN-07**). Suite 123 -> **124** cases.
- **Updated 2026-07-14** — **PREFS-1 (ADR-022, per-user preference sync)**: fixed the QA-I18N-02 failure (locale was never persisted server-side — the only switcher lived on the anonymous login page) and the "theme applies only after a manual reload" instability (the reconcile ran only on cold starts, missing OTP/MFA soft-navigation sign-ins). Language + theme now live in a **Settings -> Preferences** card; sign-in reconciles both ways (server value wins; a never-set server value adopts the device choice); a locale mismatch persists + reloads once (WASM satellite assemblies); **"system" is stored verbatim** so Auto propagates across devices. QA-I18N-02 is now automated (`I18nTests.LocaleChoice_FollowsTheUser_AcrossBrowsers`); QA-SET-08 updated (no workaround reload; Auto-propagation leg added). No new manual cases — suite stays **124**.
- **Updated 2026-07-14** — **BILLING-9 (ADR-006 addendum, seat re-check at accept)**: a downgrade (dunning lapse, cancel, or an ADR-021 comp revert) left pending invitations that could each still join — BILLING-5 checked seats only at invitation *creation*, so a Pro->Free tenant could grow past its cap by redeeming stale invites. `AcceptAsync` now refuses when the tenant is already over its limit (402 `seat_limit_reached`; accepts at exactly the cap stay allowed — the joiner consumes the seat their invite reserved) and `/join` shows a "This household is full" state (EN/ES); the

token stays pending and self-heals on re-upgrade. New **QA-INV-10** (automated — `SeatQuotaJourneyTests`, fake-provider webhook downgrade). Suite 124 -> **125** cases.

- **Updated 2026-07-14** *(recorded 2026-08-25 — the branch carrying this entry never merged and was recovered during branch housekeeping)* — **FULL MANUAL PASS COMPLETE**: the maintainer finished the entire manual QA process as the plan stood that day — the web suite (the 2026-07-09/10 sessions' findings all fixed and merged), the §12–13 native columns (Android + Windows device pass), and the remaining §13b Apple spot-checks (QA-IOS-03 + rest of QA-MAC-03, on top of the 2026-07-06 first run) — **all 125 cases passing, no open findings**. With epic NATIVE closed the same day (ADR-024: distribution is downstream work), this pass is the platform's verification baseline; future passes follow §13c per release and the full plan on native-glue/toolchain changes. *Rider:* everything added below this entry postdates the baseline — the §14a adversarial cases (12 §16 re-run rows) and QA-AND-15 (NATIVE-12) are the open device items on the current plan.
- **Updated 2026-07-15** — **§14a Adversarial & tenant-isolation (QA-ADV-*)**: 24 new curl/Postman + two-browser-context cases from the** v3 audit**, probing cross-tenant read/write isolation at the** API **layer (RLS-2/4, LB-TEN-1/2), impersonation attribution/confinement (LB-ADM-1, ADM-2/3/5), billing-webhook idempotency + false-dunning (LB-BILL-1/4), session/token lifecycle (LB-AUTH-3, refresh-reuse), preference bleed on shared devices + the locale-reload deep-link break (UX-1, LB-UI-1/2/4/5/10), and deploy/native hardening (DEP-1/2/3, NAT-3/10).** 12 cases are EXPECT-FAIL **(assert not-yet-fixed behaviour): ADV-03, 04, 05, 06, 08 (partial), 09, 10, 13, 14, 18, 21, 23 — each formerly carried a** PENDING v3 REMEDIATION **banner (now ■ v3-landed notes) and their §16 rows are reset for a re-run (never Pass while the finding is open). The other 12 should Pass on current code. §15 gains a QA-ADV traceability block; §16 gains 24 sign-off rows. Suite 125 ->** 149** cases.
- **Updated 2026-07-17** — **NATIVE-12 (OAuth process-death resilience)** merged onto develop: an OS kill mid-consent no longer loses the sign-in — an `IOAuthResumeStore` marker (MAUI Preferences) brackets the browser round-trip, the cold-started callback activity stashes the redirect, and `AuthService.TryCompletePendingOAuthAsync` completes the exchange on startup (MFA handoff + 5-min TTL guard; interrupted links land on Settings' banner). New **QA-AND-15** (on-device kill test; renumbered from the branch's QA-AND-14 — that slot went to THEME-1's restart test in the interim). Suite 149 -> **150** cases.
- **Updated 2026-09-17** — **No income-by-member chart (owner).** The "Income by member" donut is gone from the Reports page and from the PDF; the PDF keeps its income by member table. **QA-INC-04** rewritten. Case count unchanged.
- **Updated 2026-09-17** — **Choose the PDF's transaction columns (REPORTS-9; owner request).** The PDF dialog lists the appendix's nine optional columns under "Include the transactions", all ticked each time; date and payee always print. Both PDF endpoints take `appendix_columns`. New **QA-REP-07** (— `ReportPdfJourneyTests` unticks a column before downloading). **Case count 203 -> 204.**
- **Updated 2026-09-17** — **A one-off month income is the adder's (owner).** "Add income for this month" now makes the row the signed-in member's income instead of the household's. **QA-INC-02** gains the check. Case count unchanged.
- **Updated 2026-09-17** — **Whose income it is follows the line (owner).** Changing an income line's member also re-labels the month rows copied from it that still had the previous member, so migrated months can be attributed; amounts and names never change. **QA-INC-02** gains the step; the edit form says so. Case count unchanged.
- **Updated 2026-09-16** — **Income by member (INCOME-2).** The month report cuts its income by whose it is — each member by name, the household, former members, inflows: `income_by_member` on the category analysis, an **Income by member** donut in the chart view, and in the PDF the same donut plus a table with shares and a total. New **QA-INC-04**; Postman's category-analysis description names the field. **Case count 202 -> 203.**
- **Updated 2026-09-16** — **Income lines (INCOME-1, ADR-V023; owner decision).** Income is no longer two 4-week / 5-week defaults on the budget settings: **Budget -> Edit income** keeps a list of lines (whose, currency, fixed/variable, weekly / twice a month / monthly, amount per payment), and each new month starts with one editable income row per line, derived by its pay period; a month can add a one-off or drop a row. The migration copied every household's defaults into lines and every month's two incomes verbatim into rows (`ops/check-income-parity.sql` proves it). New §10g2 with **QA-INC-01** and **QA-INC-02** (— `IncomeJourneyTests`) and **QA-INC-03** (the migration rehearsal and post-deploy parity check); QA-BUD-01..03, QA-LED-01 and QA-LED-04 and QA-EXP-01 follow the new shape; Postman gains folder **25 · Income**. **Case count 199 -> 202.**
- **Updated 2026-09-16** — **Email me this report (REPORTS-8; owner request).** The PDF dialog gains **Email me**: `POST /api/reports/pdf/email` renders the same file and queues one email through the outbox to the caller's own address with the PDF attached (the platform's JOBS-4 attachment seam, synced from perezosoft-platform #235), capped at 10 a day per person (429). Both PDF endpoints now speak the **language saved in the account**

unless the request names one; the app no longer sends it. New **QA-REP-06** (— `ReportPdfJourneyTests` now also emails the PDF and finds it attached in Mailpit); Postman folder 20 gains **Email the report to me (PDF attached)**. **Case count 198 -> 199.**

- **Updated 2026-09-16** — **The report as a PDF (REPORTS-7, ADR-V022; owner request).** Reports gains a **PDF** button beside Export CSV: a small dialog (include the transactions, ticked; the amounts, charts and language it will use) and **Download**. The API renders it with QuestPDF (`POST /api/reports/pdf`, Nunito embedded) from the very figures the page reads — tiles, pace, the donuts, month by month, the method bars, the category tables — plus a landscape appendix of exactly the CSV export's rows, and delivers it through the CSV's 15-minute signed link and launcher. New **QA-REP-05** (— `ReportPdfJourneyTests` downloads a date-range PDF on every push); §15 names the new tests and endpoint; Postman folder 20 gains **Report as PDF (link)**. **Case count 197 -> 198** (the "191" in earlier entries predates the GATES cases).
- **Updated 2026-09-16** — **Android chrome, ported from JiggerJot's emulator pass.** The same platform shell code showed three defects on a real Android 16 device there: the status bar wore the platform template's sage green, the top inset was applied twice (an empty band under the status bar), and a theme or language picked in the app came undone at the next WebView reload (a stale token claim). All fixed here too — the status bar now follows the page's theme (indigo over the header, the page ground on the sign-in screen). **QA-AND-09**, **QA-AND-13** and **QA-AND-14** carry the new checks. Suite count unchanged.
- **Updated 2026-09-12** — **The two API additions the redesign needed (app-owned backend, additive).** `GET /api/months/resolve` now carries `week_number` — the week of the month's window the date falls in, from the stored weeks for an existing month and from the boundaries that would create them for a new one — and the summary's line rows (`fixed_expenses`, `variable_expenses`) carry `category_id`. With them the transaction form's rail reads "Goes to September 2026 · week 3" and, for budgeted spending with a line, "Groceries: ■8,000.00 spent of ■60,000.00 planned — after this, ■58,000.00"; the review queue's "Confirming will" sentence names the week and the same line impact (only when the voucher's currency is the line's — the queue holds no rate). This lifts the two limits recorded under SKIN-6 and SKIN-7 below. QA-LED-01 and QA-EMAIL-06 extended. **Case count unchanged at 191.**
- **Updated 2026-09-12** — **The fourteen screens the handout never drew, conformed (SKIN-11, UI redesign).** Household, Settings, Billing, Admin console, Email settings, Cards, Envelopes, Merchant mappings, Banks and Categories (through the shared catalog component), Join, Home and the two auth pages take the redesigned screens' composition: one page head, the hairline card shell with the eyebrow section heading, the ledger's table treatment, status chips instead of Bootstrap badges, the red-border invalid state, and tables that fold their secondary columns under the name on phone (Cards, Envelopes, Merchant mappings, the admin roster). Envelopes' two target columns stack as one. Decision 5 lands on the destructive actions: "This will" consequence panels above transfer, leave and dissolve on Household, delete account on Settings, and comp/revert on Admin — the browser confirm behind each stays as the last gate (the CI journeys accept it). QA-HH-07, QA-SET-07 and QA-ADMIN-06 gain a *Then* for the stated consequence. **Case count unchanged at 191.**
- **Updated 2026-09-12** — **Reports: four tiles, the pace chart promoted, one category table (SKIN-10, UI redesign).** The page opens on Total spend / Budgeted / Discretionary / Unplanned tiles (share of income or of spend; the month's refundable amount on Unplanned) and the pace chart full width, then a Table | Chart switch over the detail. Table is one "By category" card with a class switcher, a spent-vs-budget bar where a budget exists, the # count, Budget and Spent. Chart keeps the eight charts (plan §7.1: promote one, demote the rest, delete none) minus the pace, which is always above. The old StackedBar component is gone (nothing drew it since SKIN-5). QA-REP-01/03/04 reworded. **Case count unchanged at 191.**
- **Updated 2026-09-12** — **Budget: a commitment header, reorderable grid rows, one dialog (SKIN-9, UI redesign).** The page opens on "Planned every month ■…" with "N% of a typical income" (the four-week defaults, at today's rate — no share without defaults, no conversion without a rate) and a Fixed/Variable bar. The two tables become cards of grid rows: ■ handle, name, amount in the line's own currency, category, a "bank · method" chip, Edit; inactive lines are struck through with no handle. ▲▼ are gone: reorder by drag, or by the handle's move menu (up / down / to position — the keyboard and phone path), optimistic with rollback. Creating and editing move into a dialog behind one **+ Add a line** button with a Fixed/Variable switch. **QA-EXP-02 rewritten** (its ▲▼ steps stopped existing); QA-EXP-01/03 reworded for the dialog. **Case count unchanged at 191.**
- **Updated 2026-09-12** — **Months as a card grid, the month page as one ledger (SKIN-8, UI redesign).** The months list-group becomes cards (3/2/1 columns) that are single links: chip (Current = the window holding today / Closed / Upcoming), window and week count, an 8px spent-vs-planned bar, "Spent ■…" and a green/red result — fed from each month's existing summary after the grid renders, so no API change and a rate-less month still shows. The month page: "← All months" + Dashboard link, week CHIPS, income as ONE row with **Save income**, and a

six-column ledger (Date · Payee · Category · Paid with · Class · Amount) with class chips, a stacked amount that follows "Show in", and Paid with = bank + card alias. Below tablet width Category, Paid with and Class hide into the payee cell (sub-line + chip) and the filters fold behind a **Filters** button; no sideways scroll. Refund rows: amber/green status pills, stacked amount, buttons that name the merchant. Edit/Delete stay on every row (the handout drew none; the delete flow is tested and walked). QA-LED-01/02/04/05/06/08 reworded. **Case count unchanged at 191.**

- **Updated 2026-09-12** — **Catch-up: the login split (SKIN-3) and the app shell (SKIN-4).** These two slices shipped their code without their QA prose, against the plan's own rule that the prose travels with the screen. Corrected here: QA-SMK-01 step 6 and QA-SMK-03 now describe the user menu (Household, Billing, Settings and Sign out live behind the tenant chip; the bell stays in the bar), QA-AND-05 the same inside the phone sheet, and QA-I18N-01 / QA-AUTH-10 the form pane of the split sign-in. **Case count unchanged at 191.**
- **Updated 2026-09-12** — **The transaction form, amount-first (SKIN-7, UI redesign).** Twelve stacked fields become the amount at display size (currency toggle inside the input group, live conversion beneath), two named groups — What it was / How it was paid — and a **Before you save** rail naming the pay-cycle month and both sides of the money. The class picker becomes five chips in a radio group; ALL FIVE stay, because each opens a path the others do not (unplanned -> expected refund, envelope -> bucket picker, inflow -> income). CARDS-3's silent method change now says so. QA-LED-01/02 and QA-CAT-07 extended. **Case count unchanged at 191.** Save deliberately stays ENABLED and surfaces validation on submit — the opposite rule from the review queue, where the blocker is a parsed blank the user cannot argue with. Limit recorded at the time: the handout's rail also shows the budget line's new total, unreachable while the summary's line rows carried no category id — **lifted the same day by the API additions entry above.**
- **Updated 2026-09-12** — **The review queue says what confirming will do (SKIN-6, UI redesign).** Each staged email becomes a two-pane row: the draft, and a "Confirming will" panel stating the amount, the category, the class and the pay-cycle month the date lands in. Confirm is disabled while anything required is empty and the panel names it — blocked visibly rather than failing on submit — and the parser's blanks are named in the user's words (Payee / Amount / Date) with red borders and aria wiring. The class picker becomes three chips in a radio group; ALL THREE classes stay, because picking Unplanned is what opens the expected-refund path. QA-EMAIL-06 extended. **Case count unchanged at 191.** Two limits recorded rather than papered over at the time: the handout's sentence also names the WEEK and the budget line's new total, and neither was reachable — `/api/months/resolve` returned no week and the summary's line rows no category id — **both lifted the same day by the API additions entry above.**
- **Updated 2026-09-11** — **The dashboard as one verdict (SKIN-5, UI redesign).** The eleven-row waterfall becomes a verdict card, a pace bar and four steps; the separate week / bank / card cards become ONE "Where it went" panel behind a By week | By bank | By card | Unbudgeted switch (the old Other-spending card is that fourth option); envelopes become a strip rendered only when a bucket is due by its cadence. The pace legend carries each class's AMOUNT beside its share, in the selected display currency. QA-DASH-01/02/04/05 rewritten — 04 and 05 substantially, because their Gherkin described rows and cards that no longer exist. **Case count unchanged at 191.** Untouched, and still asserted: the waterfall arithmetic and its order, the frozen per-transaction rates, and the exclusion of expected refunds from the forecast.
- **Updated 2026-09-04** — **Email settings: Connect greys out once a provider is connected.** The page always rendered both Connect buttons, so a second Outlook/Gmail attempt only surfaced as the `already_connected` bounce. With the one-inbox-per-provider rule (EMAIL-2) now reflected in the UI, the button is disabled while a connection for that provider exists (the row's **Reconnect** is the way back through consent); the API guard is unchanged and stays reachable by re-running a consent URL. QA-EMAIL-02 Gherkin + walkthrough updated; `EmailSettingsPageTests.Connect_IsDisabled_ForAProviderThatIsAlreadyConnected` pins it. **Folder picker: Apply/Cancel + named chips.** "Load folders" used to leave the checklist open until Save, and the selection read only as a count because a connection stored provider ids alone (opaque Graph ids / Gmail `Label_n`). Folders now travel as `{id, name}` pairs (`EmailConnection.FolderNames`, migration `AddEmailConnectionFolderNames`; readers still use the id): the edit form shows the selection as chips, the list opens under them with **Apply** (adopt the draft) / **Cancel** (drop it), and the collapsed row carries a **Folders:** line. Rows saved before names were stored are **back-filled once** from the provider's folder list on the next read (`BackfillFolderNamesAsync`, best effort); a name the server cannot resolve (dead token) is `null` on the wire and shows an "Unnamed folder" placeholder — the opaque id is never presented. QA-EMAIL-03 updated; `Folders_RowShowsTheNames_AndCancelDropsTheDraft` + the reshaped `Edit_LoadsFolders_AndPutsTheSettings` + `BackfillFolderNames_ResolvesLegacyIdsOnce_AndLeavesDeadTokensAlone` pin it. Suite count unchanged (180).

- **Updated 2026-09-04** — **ADR-V017: a realized refund lands in the month the money arrives.** The donor's placement rule booked the derived inflow into the purchase's month with the purchase's date, rewriting a past month's income. `PUT /api/refunds/{id}` now takes `received_date` (default today; before the purchase -> 400); the inflow is dated with it and filed in that day's month through the ordinary anchor-window resolution (auto-created, retired on revert if emptied). The refund stays under its purchase's month with `received_date` + `inflow_month_id`; the month page gains a **Received on** date next to **Mark received**, a "Received <date>" badge and a link to the inflow's month. QA-LED-06 extended (cross-month branch); `MarkReceived_WithADateInALaterMonth_*`, `MarkReceived_DefaultsToToday_*` and the two `MonthDetail_*Refund*` UI cases pin it. Found by the walkthrough and fixed in the same change: the month page loaded only once per component instance, so a link from one month page to another (the new "view" link, or any month-to-month link) changed the URL but kept the old month on screen until a reload — it now reloads when its route id changes (`MonthDetail_ReloadsWhenTheRouteIdChanges`). Suite count unchanged (180).
- **Updated 2026-09-04** — **Inline category creation (owner request).** Categorising a voucher from the queue or entering a manual transaction no longer needs a trip to Settings: a shared `CategoryPicker` (select + **+ New**) replaces the plain selects on the transaction form and every review card. Create posts to the existing categories endpoint and selects the result; an active clash selects the existing entry, an inactive clash offers **Reactivate "<stored name>"** (the Catalog page's rules, reused); Enter creates, Esc cancels. The page owns one category list per page, so a category created on one review card is offered on all of them. No API, schema or Postman change. QA-LED-01 and QA-EMAIL-06 gain the inline step; `CategoryPickerTests` (4), `NewTransaction_CanCreateACategoryInline_AndSavesWithIt`, `Confirm_CanCreateTheCategoryInline_AndEveryCardSeesIt` pin it. Suite count unchanged (180).
- **Updated 2026-09-04** — **Expected refund on confirm (owner request).** Confirming a queued voucher as an unplanned essential can now carry the refund the manual form offers: `POST /api/pending-vouchers/{id}/confirm` takes `refund_expected` + `refund_percentage`, threaded into the same ledger create (its rules: 0 < p ≤ 100 or 400 `invalid_request` with nothing written; ignored on any other class), so the pending refund lands in the voucher's month at once instead of after a confirm-then-edit detour. The review card shows the switch, the percentage and the "Expected back" preview only while the class is Unplanned. QA-EMAIL-06 gains the step; `Confirm_AsUnplannedWithAPercentage_SpawnsThePendingRefund_WithTheManualRules`, `Confirm_RefundFlagOnAnotherClass_IsIgnored_NoRefund` and the two `Confirm_*Refund*` UI cases pin it. Suite count unchanged (180).
- **Updated 2026-09-04** — **Inline category creation on Budget lines (owner request, follow-up to the transaction form / review queue).** `ExpenseLinesSection` uses the shared `CategoryPicker`; the Budget page owns the category list and appends what either section creates, so a category created on the fixed list is offered on the variable list at once. Also (owner walkthrough): **Edit** on a line now scrolls the form card into view — it renders above the table, so a row far down left it off-screen (new shared `js/ui.js` helper `appUi.scrollIntoView`, loaded by BOTH hosts' index.html like `theme.js`; the card carries a scroll margin so the fixed header never covers its title). QA-EXP-01 gains the step; `Create_CanCreateTheCategoryInline_AndTheLineSavesWithIt` and `Edit_ScrollsTheFormCardIntoView_NewDoesNot` pin it. Suite count unchanged (180).
- **Updated 2026-09-04** — **"Sync inboxes" on the Review queue (owner request).** New `POST /api/email/connections/sync` (`EmailConnectionHandler.SyncAllAsync`): runs EMAIL-4's staging over every inbox of the caller in turn and sums the counts; a dead inbox is counted under `needs_reconsent` (its row flagged) and never stops the others; no inboxes -> zeros, not an error. The Review page gains the button in its header: green summary, red when an inbox needs reconnecting, a hint when nothing is connected; the queue and the header badge refresh afterwards. QA-EMAIL-04 gains the step; Postman **Sync all inboxes**; `SyncAll_StagesEveryInboxOfTheCaller_*`, the anonymous/zero integration asserts and the two `SyncAll_*` UI cases pin it. Suite count unchanged (180).
- **Updated 2026-09-04** — **Dashboard total rows (owner request).** The Fixed expenses, Variable expenses, Other spending and Week by week tables end with a **Total** row — the sum of exactly the rows shown, each side in its own currency, computed on the page from the summary already served (no API change); the lines total carries the same over/under tone as its rows. QA-DASH-01 gains the line; the totals are asserted in `DashboardPageTests`. Suite count unchanged (180).
- **Updated 2026-09-04** — **Household snapshot (hidden operator tool, owner request).** `ops/snapshot-household.sql` writes one household — the members' identity rows plus every budget table, ids preserved, FK order, `ON CONFLICT DO NOTHING` — as a restorable SQL file, so a household built up locally moves to staging/production without starting over (the platform's DEPLOYMENT §9). Inbox tokens are left out on purpose

(key-ring bound: reconnect on the target); billing/ops tables too. No page, no route, no QA case: `HouseholdSnapshotTests` proves the round-trip on Postgres and gates the table list. Suite count unchanged (180).

- **Updated 2026-09-04** — **Reports: over/under tone in the line's own currency (owner walkthrough).** A budget line is single-currency, so the category analysis compared a $18.99 line's *colón* actual against ■0 and painted every dollar line red. The tone now follows the currency the line is budgeted in (■ budget -> compare ■, $ budget -> compare $; no budget -> no tone). QA-REP-01 gains the line; `ReportsPageTests` covers a dollar line under and over. Suite count unchanged (180).
- **Updated 2026-09-04** — **REPORTS-3: charts (owner request).** The category analysis gains a **Table / Chart** view and a **■/$** switch (remembered per device via `appUi.getPref/setPref`, never account data). Charts are **inline SVG components** (`Components/Charts`: `BarChart`, `DonutChart`) — no JS library, same markup on web and MAUI, theme-aware through Bootstrap tokens, assertable in bUnit: one horizontal bar chart per class (largest first; a budgeted line shows its budget as a muted track and turns red past it — in the line's own currency, so a $ line only gets a track when the chart is in $) with the total underneath, and a "Spend by class" donut with shares. The tables are unchanged and the report API is untouched. QA-REP-01 gains the chart steps; `ChartComponentsTests` (3) + `ReportsPageTests.ChartView_*` pin it. Suite count unchanged (180).
- **Updated 2026-09-04** — **The dashboard is the home page (owner decision).** The signed-in welcome card (greeting, household name, three buttons) is gone: the root `/` renders the Dashboard for a signed-in member (its own empty state for a fresh household), the public hero stays for anonymous visitors, the **Home** nav item is removed and **Dashboard** points at `/` (`/dashboard` deep links still resolve). The exchange-rate badge moved to the dashboard header (under the month selector) and its empty state. QA-FX-01/02, QA-I18N-03, QA-LED-01 and QA-AND-04 wording updated ("Home" -> the dashboard); `HomePageTests.SignedIn_TheRootIsTheDashboard` + `ExchangeRateBadgeTests.Dashboard_MountsTheBadge_*` pin it. Suite count unchanged (180).
- **Updated 2026-09-05** — **Reports: "Income vs spend" and "Income vs budget" donuts (owner request).** In Chart view, month mode, two more donuts beside "Spend by class": the three class slices against the month's income (the dashboard's definition, now the shared `IncomeCalculator`) with a muted Remaining slice; and the active budget lines (each converted at the same rate — the shared `BudgetTotals`, also behind the dashboard's budget column) against the income with an Uncommitted slice; the income in both holes; over -> a red "Over income by …" / "Budget exceeds income by …" line; no resolvable rate -> the cards say so; date range -> no cards. `GET /api/reports/category-analysis` gains `income` and `budget_total` (`{crc, usd}` | null). QA-REP-01 gains the steps and the Postman checks; `ReportSliceTests` (+1 case, asserts), `ReportsPageTests.ChartView_IncomeDonut_*` (3), `IncomeCalculatorTests` (4), `BudgetTotalsTests` (4), `ChartComponentsTests` (center text) pin it. Suite count unchanged (180).
- **Updated 2026-09-05** — **Reports wave 2: Pace, Month by month, Spend by bank / Card vs account (owner request, REPORTS-4).** Chart view gains a cumulative **Pace** line (step line through the spend days, plan line to the budget total, dashed Today marker clamped to the month, red past the plan, "N% elapsed · M% of the plan spent" caption), a **Month by month** bar chart (new `GET /api/reports/months-trend?count=`, oldest first, spend on an income track, red when a month overspent, loaded on entering Chart view) and two donuts by **bank** and by **payment method** that follow a date range too. `GET /api/reports/category-analysis` gains `by_bank`, `by_method` and `spend_by_day` (single month only). QA-REP-01 gains the steps and the Postman checks (new **Months trend** request); `CategoryAnalysisCalculatorTests` (+3), `MonthTrendCalculatorTests` (3), `ReportSliceTests` (+2 cases, asserts), `ReportEndpointTests` (trend call), `ReportsPageTests` (+4), `ChartComponentsTests.LineChart_*` pin it. Suite count unchanged (180).
- **Updated 2026-09-07** — **Catalogs: Edit scrolls the form card into view (owner request).** On the Categories and Banks pages (shared `CatalogPage`) the edit card renders above the list, so a row far down left it off-screen; Edit now scrolls it into view with the same `appUi.scrollIntoView` helper and scroll margin the budget lines use (New still opens in place). QA-CAT-03 gains the line; `CatalogPageTests.Edit_ScrollsTheFormCardIntoView_NewDoesNot` pins it. Suite count unchanged (180).
- **Updated 2026-09-07** — **Month page: sort and filter the transactions (owner request).** Clickable headers sort by Date, Payee, Category, Bank or Class (click again flips; `aria-sort` + ▲/▼; ties keep newest-first); a filter row narrows by date range, payee text (contains, case-insensitive), category, bank and class, with "Showing n of m", a no-match row and Clear. All on the rows already loaded — no request; the export is unaffected. QA-LED-01 gains the Gherkin + walkthrough lines; `LedgerPagesTests.MonthDetail_SortsByAnyHeader_AndFiltersBy…` pins it. Suite count unchanged (180).

- **Updated 2026-09-07 — Fix: inbox "Import mail from" was one day off (owner report).** The page sent the picked day as midnight UTC and read it back in local time — in Costa Rica 6 PM of the previous day — so the form showed one day earlier than set and re-saving "the same" day sent nothing; users had to pick the day before. `ImportFromDate` (Shared.Ui) now sends the day's local midnight with the device's offset and shows the stored instant's local date, so the day round-trips and is the first day fetched. Rows saved before the fix still show the evening-before day (truthful to their window) until re-saved. QA-EMAIL-03 gains the line; `ImportFromDateTests` (3) + `EmailSettingsPageTests.Edit_ChangingImportFrom_*` pin it. Suite count unchanged (180).
- **Updated 2026-09-07 — Dashboard: over/under judged in the line's own currency (owner report; the same fix Reports got in PR #28).** A budget line is set on one side and its other side is a projection at today's rate, so a $2.99 line paid at $2.99 painted red whenever its colón projection landed a few colones under the purchase's frozen colón amount. The summary now carries `budget_currency` per line and the dashboard compares on that side; converted pairs (line totals, bank × method) turn red only when over on BOTH sides. QA-DASH-01 gains the line; `DashboardSummaryServiceTests.LineSummary_CarriesTheCurrency…` + `DashboardPageTests.LinesAreJudgedInTheirOwnCurrency…` pin it. Suite count unchanged (180).
- **Updated 2026-09-07 — Reports table mode: a transaction count per row (owner request).** Each category row of Budgeted / Discretionary / Unplanned shows how many transactions sit behind its sum (# column, total row adds them); `GET /api/reports/category-analysis` entries gain `transaction_count`. QA-REP-01 gains the column; `CategoryAnalysisCalculatorTests`, `ReportSliceTests`, `ReportsPageTests` (count assertions) and the Postman month test pin it. Suite count unchanged (180).
- **Updated 2026-09-07 — Dashboard redesign: one "This month" waterfall replaces the Expenses and Balance cards (owner decision, ADR-V018).** Income -> – Budgeted spent -> – Discretionary spent -> – Unplanned spent -> = Spent so far -> = Left now -> – Still planned (pace hint "N% of the month elapsed") -> = Forecast at month end (red + warning line below zero). The card/account split lives on in the bank × method table; "Remainder for debts" is retired from the UI (still on the API). The summary gains `spent_budgeted` / `spent_extraordinary` / `spent_unplanned` (the class cut, reconciled with `expenses_total` by the Postman test). QA-DASH-01 rewritten for the waterfall; `DashboardSummaryServiceTests` (class cut), `DashboardPageTests.Loads_*` + `Waterfall_ForecastBelowZero_*` pin it. Suite count unchanged (180).
- **Updated 2026-09-07 — Dashboard: the waterfall gets its picture (owner decision, same day).** The Income card is folded into the "This month" card (Primary/Secondary as muted sub-rows, Secondary hidden when zero) and a **stacked bar** heads it: full width = income, filled left to right by the three class spends and Still planned, the green rest = Forecast, a dashed Today marker at the month's elapsed share, and a red tail past the income when the plan does not fit (`StackedBar` component; ■/$ switch sharing the Reports charts' per-device preference). QA-DASH-01 gains the bar; `ChartComponentsTests.StackedBar_*` + the `DashboardPageTests` bar assertions pin it. Suite count unchanged (180).
- **Updated 2026-09-07 — Two exchange rates from the Banco Central (owner decision, ADR-V019).** The default provider is now the BCCR reference pair via the Finance Ministry mirror (no key, no quota; `ExchangeRate__Provider=bccr`), so a fresh checkout has a live rate. The app carries buy (compra) and sell (venta): a $ purchase or voucher converts and freezes at sell, a ■ one at buy; income the other way round; budget lines like spending; a single-rate source (manual override, last transaction, the world feed kept behind `ExchangeRate__Provider=exchangerate-api`) is both sides equal. `GET /api/exchange-rate` gains `buy` / `sell`, the month summary `exchange_rate_buy`; the dashboard's Today's-rate badge reads "buy ■… · sell ■… per $1" (the month header no longer repeats the rate); the transaction form pre-fills the side for the currency. QA-FX-01 rewritten around the pair (badge, form prefill, a $ purchase), QA-FX-02 now uses the world-feed override to reach the empty chain; `FxRatesTests`, `BccrExchangeRateClientTests`, the ledger / voucher / dashboard direction tests and the bUnit badge / form / dashboard tests pin it. Suite count unchanged (180).
- **Updated 2026-09-07 — Reports table mode: the amount column of Discretionary / Unplanned (and of any class without a budget column) is headed "Spent"; "Actual" stays only beside "Budgeted" (owner request).** QA-REP-01 names the column; `ReportsPageTests` header assertions pin it. Suite count unchanged (180).

- **Updated 2026-09-07** — **"Show in" ■ · $ · both on the dashboard and the Reports tables (owner request).** One per-device preference (`display.currency`, shared by both pages; picking a single currency also points the charts and the stacked bar at it): converted pairs and totals show the chosen side(s); a budget line always shows on the side it is set in; the Reports Budgeted total becomes ONE figure at today's rate (colón lines at buy, dollar lines at sell — ADR-V019) instead of a per-side split; the dashboard's stacked bar loses its own ■/$ buttons and follows the page (with "both", its legend lists each segment in ■ and $). `GET /api/reports/category-analysis` adds `exchange_rate` / `exchange_rate_buy` for that. QA-REP-01 and QA-DASH-01 gain the switch; the `CurrencySwitch` component + `MoneyDisplay` helper; `ReportsPageTests.ShowIn_*`, `DashboardPageTests.ShowIn_*` and the Postman keys test pin it. Suite count unchanged (180).
- **Updated 2026-09-07** — **"Show in" follows the account (owner decision, ADR-V020).** The ■ · $ · both choice is now kept like the theme: a device copy for the first paint plus an account copy in an app-owned user-keyed table (`UserDisplaySettings`, `GET`/`PUT /api/display-settings`, erased with the account, refused under impersonation); the account wins once chosen, a never-chosen account adopts the device's choice. New QA-DASH-03 (suite 181); Postman folder 23; `DisplaySettingsSliceTests`, `DisplaySettingsEndpointTests`, the impersonation theory and `DashboardPageTests.ShowIn_FollowsTheAccount_AndSavesThere` pin it.
- **Updated 2026-09-07** — **Sync of the platform's billing return-page fix + Stripe walkthrough.** Stripe now returns the browser to `/billing/success` / `/billing/cancel` and both route to the Billing page with a banner (success refetches on its own until the webhook has flipped the plan) — found on this app's staging, where the first real test-mode checkout ended on the 404 page. QA-BILL-02 rewritten around the return; `NotifyBillingTests.Billing_ReturnFromCheckout_*` pin it; the platform's DEPLOYMENT §3 gains the real-Stripe walkthrough. Suite count unchanged (181). Also the lifecycle's good-news notice, `billing.activated` ("Subscription active", plan + renewal date) on a transition into a granting status — the owner had received the cancellation email but never a confirmation. The cancelled state reads honestly: "Your paid subscription ended on <date>" instead of "renews", and no portal button (nothing live to manage; Upgrade is the way back) — `NotifyBillingTests.Billing_CancelledSubscription_*`.
- **Updated 2026-09-08** — **"How much is budgeted on cards vs the bank account?" (owner question).** The dashboard's bank × method table is grouped by payment method with a subtotal row per method and a grand total; Reports chart view gets "Budgeted vs spent, by payment method" under the Card vs account donut (single month with a rate). `GET /api/reports/category-analysis` adds `budget_by_method[]` (Core `BudgetTotals.PlannedByMethod`). QA-DASH-01 and QA-REP-01 name them; `BudgetTotalsTests.PlannedByMethod_*`, `ReportSliceTests`, `DashboardPageTests` (method totals) and `ReportsPageTests` (bars) pin it. Suite count unchanged (181).
- **Updated 2026-09-08** — **Inflows are visible as income, not only as a row (owner question).** The dashboard's Income gains an "Other income (inflows)" sub-row (total – primary – secondary, shown when non-zero) so the sub-rows add up; the month page's Income card lists "Other income this month" with the inflows' frozen sum and a link that filters the table to them. Client only. QA-LED-06 names both; `DashboardPageTests.Income_ShowsInflows*` and `LedgerPagesTests.MonthDetail_IncomeCard_ListsInflows*` pin it. Suite count unchanged (181).
- **Updated 2026-09-10** — **App-side rebalance (owner question: "I don't want only platform stuff sitting there").** The app's own families had grown by appending to existing cases rather than adding them, so the biggest walkthroughs had swollen past 40 lines and nobody would run them. Split into one case per feature: **QA-CAT-05** keeps the cards catalog, **QA-CAT-06** takes renewals and merging, **QA-CAT-07** takes credit vs debit and the backfill; **QA-DASH-01** keeps lines vs actuals, **QA-DASH-04** takes the This-month bar and waterfall, **QA-DASH-05** takes the bank × method / By card pair; **QA-REP-01** keeps the table view, **QA-REP-03** takes the chart donuts, **QA-REP-04** takes pace, trend and the where-from charts. Suite 184 -> 190, app-side 34 -> 40. The **§16 sign-off sheet** listed 58 of 184 cases (it had silently stopped being filled in — QA-CAT-05 and QA-DASH-03 were both missing); it now lists every case, and `check_qa_artifacts.py` fails when a case has no row or a row has no case, so it cannot drift again.

- **Updated 2026-09-10** — **Where the money left from, read as one idea (owner request).** "By card" had been appended to whichever grid had room, so it sat half-width and alone on both pages. The dashboard now pairs **By bank and payment method** (7 cols) with **By card** (5 cols), and By card gains the card's **kind** and its **share** of the month. Reports pairs **Spend by card** with **Spend by bank** as two donuts — one shape for one question — and drops **Card vs account** below them at full width, donut left and the budgeted-vs-spent bars right, where they finally fit. The review queue also calls out cards a voucher named but nobody has renamed, with a link to Manage cards, so an automatic alias and the credit default stop sitting wrong unseen. Presentation only; `summary.by_card[]` gains `kind`.
- **Updated 2026-09-10** — **Credit or debit on a card (CARDS-3; owner question).** Every voucher confirm booked `credit_card`, so debit purchases were counted as card spending everywhere the card-versus-account split appears. `Card.Kind` (`credit` default | `debit`) now decides: the confirm and the manual picker derive `payment_method` from the card, BN payment receipts set the kind at creation when the row names it, and the edit form offers an opt-in backfill that corrects the card's past transactions and reports the count. Migration `AddCardKind`. QA-CAT-05 gains the kind walkthrough; story CARDS-3; Postman folder 24 carries `kind`.
- **Updated 2026-09-10** — **The 12-hour voucher date, and clearing the review queue (owner request).** Banco Nacional started printing "Sep 1, 2026 - 10:13 a.m."; no culture reads the dotted Spanish meridiem, so the whole date failed and the draft sat blocked with "Could not read: Date". `SpanishDateParser` now cuts the time off before parsing (the date is all we keep), which covers every meridiem spelling at once; the real body rides along as the `bn-voucher-12h` fixture. Settings -> Email gains a two-step **Clear the review queue** (`POST /api/pending-vouchers/clear`, 409 without `confirm`): pending drafts and their tombstones go, each inbox's cursor is pulled back to just before the oldest of them, and confirmed/discarded vouchers and every transaction are untouched. New QA-EMAIL-07 (suite 184); story EMAIL-7; Postman folder 22.
- **Updated 2026-09-09** — **Per-card summaries (CARDS-2 / REPORTS-6; owner request).** The dashboard gains a **By card** table (alias, transaction count, spend; "No card" last; Total) and the Reports chart view a **Spend by card** bar chart beside Card vs account — both shown once a card has paid something, both over one Core cut (`CardSpend.Calculate`: expense rows by `card_id`, largest first, all-states names). API: `summary.by_card[]` and `by_card[]` on the analysis (key `"none"` = no card). QA-DASH-01 and QA-REP-01 name them; `CardSpendTests`, the dashboard/analysis Core tests, `ReportSliceTests` and the bUnit pages pin it. No entity, no migration.
- **Updated 2026-09-08** — **Transaction notes (owner request).** An optional `notes` (≤ 250 characters, trimmed, blank = null, over the cap = 400) on create/update/get, the month list and the CSV (trailing `notes` column); the voucher confirm accepts it. New/Edit show a Notes box with a `0/250` counter; the month page shows a note icon on the payee whose hover text is the note and whose tap opens the transaction; the review card has the same box. Migration `AddTransactionNotes`. New QA-LED-07 (suite 183); `LedgerSliceTests.Notes_*`, `LedgerEndpointTests`, `PendingVoucherSliceTests`, `TransactionCsvWriterTests.Notes_*` and the bUnit pages pin it.
- **Updated 2026-09-08** — **Cards (CARDS-1, ADR-V021; owner request).** The card a voucher prints (brand + last four) becomes a household catalog entry, created as `VISA-1234` on the first confirm and renamed by the household on Settings -> Cards; transactions carry an optional `card_id` (voucher confirm fills it, manual entry may pick one), the month page shows/sorts/filters by card, the CSV gains a trailing `card` column, the review queue shows the card. A card owns every number the bank has printed (a renewal is merged with "Same card as…" — identities and transactions move, history stays whole). Rows without a card are a "no card" bucket — no LEGACY row. New QA-CAT-05 (suite 182); QA-EMAIL-06 and QA-REP-02 name the card; Postman folder 24; migration `AddCards`; `CardIdentityTests`, `CardSliceTests`, `CardEndpointTests`, the ledger/voucher tests and the bUnit pages pin it.
- **Updated 2026-10-02** — **CI on billed minutes (ADR-031).** GitHub is the only forge again (ADR-030). A pull request runs the web gates only; the MAUI builds and native smokes run from *Run workflow* -> `devices`; deploys run from *Run workflow* -> `deploy` behind every web gate. The deploy gate paragraph says GitHub; the Apple-cadence note became the device-legs note.
- **Updated 2026-10-04 (v4 Later D, ported from the platform)** — new **§14d**: eleven adversarial cases **QA-ADV-25..35** (each names the v4 finding and the task that fixed it; all expected to **Pass**), four operator drills **QA-DEP-01..04** for the deploy-on-request pipeline (ADR-031), and two regressions, **QA-SET-09** (a theme save across a reload) and **QA-AND-16** (an API base with a trailing slash). On the platform these were first recorded Blocked while the findings were open; every remediation had landed here before the cases did, so they arrive unseeded. QA-ADV-15 now counts seats relative to the cap (T47). 204 -> 221 cases.

- **Updated 2026-10-09 (owner feedback, milestone "Owner feedback · 2026-10")** — refunds: QA-LED-05 covers a discretionary purchase (#201) and a refund typed as ■ or % and stored as its amount (#202); QA-LED-06 the received / pending totals (#206) and the lock on a received refund (#202); QA-LED-08 no longer expects a purchase edit to re-derive a refund; new **QA-LED-09**, the cross-month Refunds page (#208). QA-DASH-05: the week cut's Unplanned column (#211). QA-DASH-03: the Show in switch on the month page, Months and Budget (#207). Income moved from Settings to the Budget page (#203): QA-BUD-01, QA-INC-01 and every "Settings -> Manage income" step now read "Budget -> Edit income". New **QA-CAT-08**, a half-hidden card number asked about once and remembered (#210). QA-DSK-10 and the CSV/PDF download steps: Windows saves through a Save As dialog, not the share flyout (#204). New **QA-SET-10**, cards that fold and stay folded on the device (#205). New **QA-SET-11**, no page scrolls sideways on a phone (#209, automated by `PhoneLayoutTests`). 221 -> 225 cases.